



**SEGURIDAD Y CUMPLIMIENTO: AUDITORÍA Y
BASTIONADO BAJO EL ESQUEMA NACIONAL DE
SEGURIDAD**

Administración de Sistemas Informáticos en Red

Modalidad Online

Lidia Gallardo Díaz-Cacho

Tutor: Daniel Espinosa

PROMETEO

A mi madre y a mi hermana, por ser el lugar seguro donde siempre pude volver cuando el camino se ponía cuesta arriba. Gracias por creer en mí y por apoyarme incondicionalmente en cada paso que doy.

A mis amigas, por estar siempre, por motivarme a seguir, por vuestra ayuda constante y por recordarme que todo este esfuerzo tendrá su recompensa.

Y, sobre todo, se lo dedico a esa Lidia pequeña. Esa niña que un día se convenció de que no valía para estudiar este tipo de cosas, que no era capaz. Esto es por ti, para demostrarte que siempre pudiste, que siempre fuiste capaz.

CONTENIDO

GLOSARIO	12
1 Justificación del proyecto	20
1.1 Motivación y origen del proyecto	20
1.2 Estado de la cuestión y público objetivo	20
1.3 Descripción de la empresa	21
1.4 Alcance del proyecto.....	22
2 Introducción	23
2.1 Principales funciones y problemas que resuelve	23
2.2 Requisitos del Proyecto	24
3 Objetivos.....	25
3.1 Tabla RFTP	27
4 Descripción.....	29
4.1 Marco normativo y categorización (ENS).....	29
4.1.1 Identificación de activos críticos	29
4.1.2 Valoración de las dimensiones de ciberseguridad	30
4.1.3 Determinación de la categoría del sistema	33
4.1.4 Análisis de riesgos	33
4.1.5 Selección de medidas de seguridad y salvaguardas.....	37
4.2 Arquitectura de Red y Segmentación	39
4.2.1 Arquitectura de red inicial.....	39
4.2.2 Arquitectura de red tras la implantación	40
4.3 Despliegue e Implementación.....	41
4.3.1 Arquitectura inicial	41
4.4 Auditoría inicial	68
4.4.1 Auditoría inicial Directorio Activo	68
4.4.2 Auditoría inicial Ubuntu Server 22.04	78
4.4.3 Resumen comparativo de las auditorías iniciales	86
4.5 Hardening	88
4.5.1 Instalación y configuración de OPNsense.....	88
4.5.2 Ubuntu Server 22.04	96
4.5.3 Windows Server 2022 (SERVER-AD-01).....	113
4.6 Post-auditoría y verificación.....	128
5 Tecnologías	138
6 Metodología.....	141

6.1	Planificación.....	142
6.2	Diagrama de Gantt	143
6.3	Presupuesto.....	145
6.3.1	Gastos de personal	145
6.3.2	Infraestructura de hardware	146
6.3.3	Software y licencias.....	146
6.3.4	Resumen del presupuesto total.....	146
6.4	Readme y GIT	147
6.4.1	Estructura del repositorio	147
6.4.2	Contenido del README.md	149
7	Trabajos futuros	151
8	Conclusiones	152
8.1	Resultados objetivos obtenidos	153
8.2	Vulnerabilidades resueltas y no resueltas.....	154
8.3	Resumen de controles ENS aplicados	155
9.	Referencias	157

ÍNDICE DE ILUSTRACIONES

Ilustración 1 - Diagrama de red inicial.....	40
Ilustración 2 - Diagrama de red tras aplicar ENS	41
Ilustración 3 - Asignación de nombre al servidor Windows Server	42
Ilustración 4 - Asignación IP estática Windows Server	43
Ilustración 5 - Pantalla de inicio previo a promoción a controlador de dominio	44
Ilustración 6 - Agregar roles y características	44
Ilustración 7 - Selección de roles del servidor.....	45
Ilustración 8 - Progreso de la instalación de roles y características	45
Ilustración 9 - Resultados de instalación de roles y características	46
Ilustración 10 - Configuración de implementación	47
Ilustración 11 - Opciones del controlador de dominio	47
Ilustración 12 - Comprobación de requisitos previos	48
Ilustración 13 - Pantalla de inicio del controlador de dominio	48
Ilustración 14 - Panel del Administrador del servidor I	49
Ilustración 15 - Panel del Administrador del servidor II	49

Ilustración 16 - Comprobación configuración controlador de dominio en consola PowerShell	50
Ilustración 17- Creación de usuarios en consola PowerShell	51
Ilustración 18- Usuarios y equipos Active Directory	51
Ilustración 19 – Configuración de perfil de Ubuntu Server	52
Ilustración 20 - Configuración de red de Ubuntu Server	53
Ilustración 21- Comandos configuración de IP.....	53
Ilustración 22 - Contenido archivo 99-manual-config.yaml	53
Ilustración 23- Comprobación en consola de la IP	54
Ilustración 24 - Instalación stack LAMP	54
Ilustración 25 - Comprobación de estado de apache.....	55
Ilustración 26 - Comprobación de estado de mariadb.....	55
Ilustración 27 - Comprobación de la instalación de PHP	55
Ilustración 28 - Login de phpMyAdmin.....	59
Ilustración 29 – Tablas de la base de datos.....	59
Ilustración 30 - Tabla stock	59
Ilustración 31 - Tabla empleados	60
Ilustración 32 - Tabla clientes	60
Ilustración 33 - Página web Saniter I	61
Ilustración 34 - Página web Saniter II	61
Ilustración 35 - Fortalecimiento de Kali Linux	62
Ilustración 36 - Comprobación de estado firewall kali linux.....	62
Ilustración 37 - Asignación IP estática a Kali Linux.....	63
Ilustración 38 - Comprobación IP configurada	63
Ilustración 39 - Instalación GVM OpenVAS	63
Ilustración 40 - Comprobación instalación GVM OpenVAS	63
Ilustración 41 - Login de OpenVAS.....	64
Ilustración 42 - Actualización de Feed OpenVAS	65
Ilustración 43 - Feed Status OpenVAS sin actualizar	65
Ilustración 44 - Feed Status OpenVAS actualizando	66
Ilustración 45 - Feed Status OpenVAS actualizado	66
Ilustración 46 - Ping Windows Server a Kali Linux y a Ubuntu Server	66
Ilustración 47 - Ping Ubuntu Server a Kali Linux y a Windows Server	67
Ilustración 48 - Ping Kali Linux a Windows Server y a Ubuntu Server	67

Ilustración 49 - Creación de usuario openvas para auditoria	69
Ilustración 50 - Asignación de grupo a usuario openvas.....	69
Ilustración 51 - comprobación de grupos del usuario openvas	69
Ilustración 52 - Habilitación de las reglas de firewall (WMI), protocolo ICMP,SMB.	70
Ilustración 53 - Comprobación de habilitación correcta	70
Ilustración 54 - Ruta a permisos WMI	70
Ilustración 55 - Permisos asignados a usuario openvas	71
Ilustración 56 - Generación credenciales en OpenVAs para Windows Server	72
Ilustración 57 - Target SERVER-AD-01 (Autenticado) en OpenVAS.....	72
Ilustración 58 - Configuración task Auditoria autenticada Windows Server I	73
Ilustración 59 - Configuración task Auditoria autenticada Windows Server II.....	73
Ilustración 60 - Estados del escaneo inicial Windows Server	74
Ilustración 61 - Resultados auditoría Windows Server en OpenVAS.....	77
Ilustración 62 - Detalle vulnerabilidad nivel medio I	77
Ilustración 63 - Detalle vulnerabilidad nivel medio II	77
Ilustración 64 - Estados de auditoría Ubuntu Server.....	79
Ilustración 65 - Credenciales en OpenVAs para Ubuntu Server	79
Ilustración 66 - Configuración de Target UbuntuServer Authenticated	80
Ilustración 67 - Configuración Task Auditoria inicial Ubuntu Server autenticada	81
Ilustración 68 - Resultados auditoría en OpenVAS.....	84
Ilustración 69 - Vulnerabilidades de nivel medio en la auditoría de Ubuntu Server	85
Ilustración 70 - Detalle de la vulnerabilidad de nivel medio I	85
Ilustración 71 - Detalle de la vulnerabilidad de nivel medio II	86
Ilustración 72 - Vulnerabilidades de nivel bajo en auditoría Ubuntu Server	86
Ilustración 73 - Adaptador 1 VM OPNsense	89
Ilustración 74 - Adaptador 2 VM OPNsense	89
Ilustración 75 - OPNsense installer UFS Configuration I	90

Ilustración 76 - OPNsense installer UFS Configuration II	90
Ilustración 77 - OPNsense installer Instalation progress I.....	91
Ilustración 78 - OPNsense installer Instalation progress II.....	91
Ilustración 79 - OPNsense installer Final configuration.....	91
Ilustración 80 - Consola OPNsense: inicio	92
Ilustración 81 - OPNsense LAN y WAN inicial	92
Ilustración 82 - OPNsense LAN y WAN configuradas.....	93
Ilustración 83 - Comprobación de conectividad	94
Ilustración 84 - Plataforma OPNsense: interfaces	95
Ilustración 85 - Reglas LAN firewall OPNsense	96
Ilustración 86 - Reglas WAN firewall OPNsense.....	96
Ilustración 87 - Configuración de la IP de Ubuntu Server	97
Ilustración 88 - Contenido archivo 99-manual-config.yaml	97
Ilustración 89 - Comprobación de asignación IP Ubuntu Server.....	97
Ilustración 90 - Comprobación conectividad Ubuntu Server con OPNsense	98
Ilustración 91 - Comprobación conectividad Ubuntu Server con Windows Server	98
Ilustración 92 - Configuración firewall Ubuntu Server UFW	99
Ilustración 93 - Comprobación reglas aplicadas UFW	99
Ilustración 94 - Configuración SSH.....	99
Ilustración 95 – Contenido archivo sshd_config I.....	100
Ilustración 96 - Contenido archivo sshd_config II.....	100
Ilustración 97 - - Contenido archivo sshd_config III	100
Ilustración 98 - Cambio de regla puerto SSH.....	100
Ilustración 99 - Algoritmos MAC en sshd_config.....	101
Ilustración 100 - Resumen comandos empleados en configuración SSH	101
Ilustración 101 - Comprobación puerto 3306	102
Ilustración 102 - Creación de usuarios en MariaDB.....	103
Ilustración 103 - Respuestas script MariaDB I	105
Ilustración 104 - Respuestas script MariaDB II	105
Ilustración 105 - Configuración seguridad Apache.....	106
Ilustración 106 - Contenido archivo security.conf.....	106

Ilustración 107 - Configuración de los headers en apache	107
Ilustración 108 – Contenido archivo 000-default.conf	107
Ilustración 109 - Reinicio de Apache y comprobación de medidas	108
Ilustración 110 - Contenido archivo sysctl.conf	109
Ilustración 111 - Comprobación de aplicación de medidas	109
Ilustración 112 - Comprobación estado rsyslog	110
Ilustración 113 - Extracto de logs	110
Ilustración 114 - Contenido archivo logrotate.conf	111
Ilustración 115 - Script backup_saniter.sh	112
Ilustración 116 - Contenido archivo crontab	113
Ilustración 117 - Ejecución manual scrip backups y comprobación generación archivo	113
Ilustración 118 - Información tarjeta de red	114
Ilustración 119 - Cambio de dirección IP y default gateway	114
Ilustración 120 - Información de la tarjeta de red	114
Ilustración 121 - Comprobación conectividad con OPNsense	115
Ilustración 122 - Creación de nuevas Unidades Organizativas	116
Ilustración 123 - Cambio de ubicación de los usuarios a sus nuevas Uso	117
Ilustración 124 - Unidades organizativas y sus usuarios	117
Ilustración 125 - Creación GPO en dominio saniter.local	119
Ilustración 126 - Directiva de contraseñas actualizada	119
Ilustración 127 - Directiva de bloqueo de cuenta actualizada	119
Ilustración 128 - Vínculos de la GPO ENS- Política de contraseñas	119
Ilustración 129 - Actualización forzada correcta	120
Ilustración 130 - Vínculos de GPO ENS-Mínimo privilegio	120
Ilustración 131 - Grupos restringidos	121
Ilustración 132 - Agregación grupo Administradores en grupos restringidos	121
Ilustración 133 - Opciones de seguridad de directivas locales	122
Ilustración 134 - Habilitación de UAC	122
Ilustración 135 - Actualización forzada correcta	122
Ilustración 136 - GPO ENS -Auditoria	123
Ilustración 137 - Configuración Directiva de auditoría I	123

Ilustración 138- Configuración Directiva de auditoría II.....	124
Ilustración 139 - Actualización forzada correcta.....	124
Ilustración 140 - Visor de eventos de Windows	124
Ilustración 141 - Desactivación Print Spooler y Remote Registry	125
Ilustración 142 - Deshabilitación de TCP Timestamps.....	126
Ilustración 143 - Edición de regla firewall OPNsense puerto 135	127
Ilustración 144 - Regla firewall bloqueo puerto 135	127
Ilustración 145 - Snapshot Post-Hardening Windows Server	128
Ilustración 146 - Configuración nueva IP en Kali Linux.....	129
Ilustración 147 - Comprobación dirección IP	129
Ilustración 148 - Comprobación conectividad con OPNsense y servidores	129
Ilustración 149 - Fijación de dirección IP	130
Ilustración 150 - Diagrama de Gantt con planificación inicial.....	144
Ilustración 151 - Diagrama de Gantt con planificación final	144

ÍNDICE DE TABLAS

Tabla 1 - Requisitos del proyecto.....	24
Tabla 2 - Tabla RFTP	27
Tabla 3 - Identificación de activos críticos	29
Tabla 4 - Leyenda categorías ENS	31
Tabla 5 - Análisis de riesgos.....	31
Tabla 6 - Matriz de riesgo MAGERIT V3.....	35
Tabla 7 - Nivel de riesgo de las amenazas	36
Tabla 8 - Controles ENS técnicos.....	38
Tabla 9 - Características técnicas de la VM del Directorio Activo	41
Tabla 10 - Características técnicas de la VM de Ubuntu Server.....	52
Tabla 11 - Paquetes del stack LAMP.....	54
Tabla 12 - Características de la VM de Kali Linux - equipo auditor.....	62
Tabla 13 - Configuración del escaneo autenticado de Windows server...	74
Tabla 14 - Sistema detectado en auditoría inicial AD	75
Tabla 15 - Puertos detectados en auditoría inicial AD	75
Tabla 16 - Vulnerabilidades identificadas en auditoría inicial AD.....	76

Tabla 17 - Configuración del escaneo autenticado a Ubuntu Server	78
Tabla 18 - Sistemas y aplicaciones detectadas en auditoria autenticada a Ubuntu Server	82
Tabla 19- Puertos detectados en auditoría inicial a Ubuntu Server	82
Tabla 20 - Vulnerabilidades detectadas en auditoría autenticada inicial de Ubuntu Server	83
Tabla 21 - Comparativa de auditorías iniciales	87
Tabla 22 - Direcciones IP de los equipos.....	88
Tabla 23 - Características de la VM de OPNsense.....	89
Tabla 24 - Reglas de firewall aplicadas	95
Tabla 25 - Respuestas ejecución script MariaDB	104
Tabla 26 - Parámetros a configurar en Política de contraseñas	118
Tabla 27 - Parámetros a habilitar en Directiva de auditoría	123
Tabla 28 - Configuración del escaneo de post-auditoria de Windows Server	130
Tabla 29 - SO y puertos detectados en post-auditoría AD.....	131
Tabla 30 - Vulnerabilidades detectadas post-auditoria AD	132
Tabla 31 - Configuración del escaneo de post-auditoria de Ubuntu Server	132
Tabla 32 - Puertos detectados en post-auditoría Ubuntu Server	133
Tabla 33- Vulnerabilidades detectadas en post-auditoría Ubuntu Server	134
Tabla 34 - Comparativa resultados auditorías AD	135
Tabla 35 - Comparativa resultados auditorías Ubuntu Server	136
Tabla 36 - Soluciones tecnológicas empleadas en el proyecto	138
Tabla 37 - Plan de trabajo.....	142
Tabla 38 - Gastos de personal.....	145
Tabla 39 - Gasto infraestructura de hardware	146
Tabla 40 - Gasto de software y licencias	146
Tabla 41 - Presupuesto total.....	146
Tabla 42 - Estructura repositorio GIT	147
Tabla 43 - Resultados obtenidos	153
Tabla 44 - Controles ENS aplicados	155

RESUMEN

Este proyecto muestra cómo una pequeña empresa del sector de la sanidad ambiental puede adaptarse al Esquema Nacional de Seguridad (ENS) para seguir trabajando con la Administración Pública. El punto de partida es una infraestructura funcional pero insegura, y el objetivo es llevarla a la Categoría MEDIA del ENS, que es la que le corresponde según el análisis de sus activos.

Para ello se ha seguido el ciclo PDCA: primero se analiza la situación real, luego se despliega la infraestructura y se audita con OpenVAS, después se aplican las medidas de bastionado y finalmente se verifica si han funcionado. Las tecnologías principales son OPNsense como firewall, Windows Server 2022 para el Directorio Activo y Ubuntu Server para los servicios web y de base de datos.

ABSTRACT

This project shows how a small environmental health company can adapt its infrastructure to meet the requirements of Spain's National Security Framework (ENS), specifically at the Medium Category level. Starting from a working but insecure setup, the project follows a PDCA approach: risk analysis, deployment, initial audit with OpenVAS, hardening, and post-audit verification. The main technologies used are OPNsense as the perimeter firewall, Windows Server 2022 for Active Directory, and Ubuntu Server for web and database services.

GLOSARIO

Active Directory (AD): Servicio de directorio de Microsoft que centraliza la gestión de usuarios, equipos y políticas de seguridad en una red Windows. Permite controlar quién puede acceder a qué recursos.

Apache HTTP Server: Servidor web de código abierto ampliamente utilizado. En este proyecto gestiona las peticiones HTTP dirigidas a la web corporativa de Saniter.

Auditoría de seguridad: Proceso sistemático de evaluación de la seguridad de un sistema. En el proyecto se realiza con OpenVAS antes y después del bastionado para medir la reducción de vulnerabilidades.

BBDD (Base de Datos): Conjunto organizado de datos almacenados y gestionados por un sistema gestor. En Saniter, contiene el inventario de biocidas, datos de clientes y empleados.

Bastionado (Hardening): Proceso de configuración de un sistema para reducir su superficie de ataque: deshabilitar servicios innecesarios, restringir accesos y aplicar configuraciones seguras.

Biocida: Sustancia o mezcla destinada a destruir, contrarrestar o neutralizar cualquier organismo nocivo (plagas, bacterias, hongos). Su uso y trazabilidad están regulados por el RD 830/2010.

CERT (Computer Emergency Response Team): Equipo de respuesta a emergencias informáticas. En el contexto de OpenVAS, es la base de datos de alertas y avisos de seguridad emitidos por organismos oficiales.

CCN (Centro Criptológico Nacional): Organismo adscrito al CNI responsable de la seguridad de los sistemas de información de las Administraciones Públicas españolas. Publica las guías CCN-STIC de referencia para el ENS.

CVE (Common Vulnerabilities and Exposures): Sistema de identificación estandarizado para vulnerabilidades de seguridad conocidas. Cada CVE tiene un identificador único (p.ej. CVE-2023-XXXX) y una puntuación de gravedad CVSS.

CVSS (Common Vulnerability Scoring System): Sistema de puntuación que mide la gravedad de una vulnerabilidad en una escala de 0 a 10. Puntuaciones ≥ 9 se consideran críticas.

DCE/RPC: Distributed Computing Environment / Remote Procedure Call. Protocolo de Microsoft para la comunicación entre procesos en red. El puerto 135/tcp es el endpoint mapper de RPC, empleado por los servicios del Controlador de Dominio.

DDD (Desinfección, Desinsectación y Desratización): Conjunto de servicios de control de plagas. Es la actividad principal de Saniter.

DNS (Domain Name System): Sistema que traduce nombres de dominio a direcciones IP. En el proyecto, el propio Controlador de Dominio actúa como servidor DNS para la red interna saniter.local.

DoS (Denial of Service): Ataque informático cuyo objetivo es interrumpir un servicio dejándolo inaccesible para sus usuarios legítimos, normalmente saturando el sistema con tráfico o peticiones.

ENS (Esquema Nacional de Seguridad): Marco normativo español regulado por el RD 311/2022 que establece los requisitos mínimos de seguridad para los sistemas de información de las Administraciones Públicas y sus proveedores.

Firewall: Sistema de seguridad que controla el tráfico de red entrante y saliente aplicando reglas definidas. En el proyecto se usa OPNsense como firewall perimetral.

GVM (Greenbone Vulnerability Manager): Plataforma de gestión de vulnerabilidades que incluye OpenVAS como motor de escaneo. Es la herramienta de auditoría utilizada en el proyecto.

GPO (Group Policy Object): Directiva de grupo en entornos Windows. Permite aplicar configuraciones de seguridad de forma centralizada a usuarios y equipos del dominio (políticas de contraseñas, restricciones de acceso, etc.).

ICMP (Internet Control Message Protocol): Protocolo de red utilizado para diagnóstico y control, incluido el comando ping. En el proyecto se habilita de forma controlada para permitir la detección del host durante las auditorías.

IDS (Intrusion Detection System): Sistema de detección de intrusiones que analiza el tráfico de red en busca de patrones sospechosos. En OPNsense se integra mediante el módulo Suricata.

IP estática: Dirección IP asignada manualmente a un dispositivo que no cambia. Todos los servidores del proyecto tienen IP estática para garantizar su localización constante en la red.

Kali Linux: Distribución de Linux orientada a la seguridad informática y las pruebas de penetración. En el proyecto se usa como equipo auditor con OpenVAS instalado.

LAN (Local Area Network): Red de área local. En el proyecto, la zona LAN es la red interna donde residen los servidores de Saniter, protegida por OPNsense.

LAMP: Acrónimo del conjunto de software: Linux, Apache, MySQL/MariaDB y PHP. Es la base del servidor web del proyecto.

LDAP (Lightweight Directory Access Protocol): Protocolo para acceder y gestionar servicios de directorio. Es el protocolo subyacente que usa Active Directory.

Logrotate: Herramienta de Linux para la gestión automática de archivos de log: rotación, compresión y eliminación según política de retención configurable.

MAGERIT V3: Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información, desarrollada por el Consejo Superior de Administración Electrónica y recomendada por el CCN para el cumplimiento del ENS.

MariaDB: Sistema gestor de bases de datos relacionales de código abierto, bifurcación de MySQL. En el proyecto almacena el inventario de biocidas y los datos de Saniter.

MITM (Man In The Middle): Tipo de ataque en el que un tercero se interpone en la comunicación entre dos partes sin que éstas lo sepan, pudiendo interceptar o modificar los datos.

NTDS (NT Directory Services): Base de datos del Directorio Activo (ntds.dit) donde se almacenan todos los objetos del dominio: usuarios, grupos, políticas y credenciales cifradas.

NVT (Network Vulnerability Tests): Scripts de prueba que OpenVAS ejecuta contra los sistemas objetivo para detectar vulnerabilidades conocidas.

OpenVAS: Escáner de vulnerabilidades de código abierto integrado en la plataforma GVM. En el proyecto realiza las auditorías de seguridad antes y después del bastionado.

OPNsense: Distribución de firewall y router de código abierto basada en FreeBSD. En el proyecto actúa como firewall perimetral, implementando la segmentación WAN/LAN y las reglas de filtrado de tráfico.

PDCA (Plan-Do-Check-Act): Ciclo de mejora continua también conocido como Ciclo de Deming. El proyecto sigue este enfoque: planificación, despliegue, verificación y ajuste.

PHP: Lenguaje de programación del lado servidor ampliamente usado en desarrollo web. En el proyecto actúa como intermediario entre Apache y la base de datos MariaDB.

phpMyAdmin: Interfaz web para la administración de bases de datos MySQL/MariaDB. En el escenario inicial de Saniter está accesible desde cualquier equipo de la red, lo que representa una vulnerabilidad.

PYMES (Pequeñas y Medianas Empresas): Empresas que no superan ciertos umbrales de empleados y facturación. Saniter es una PYME del sector de la sanidad ambiental.

QoD (Quality of Detection): Porcentaje de confianza de un resultado en OpenVAS. Un $QoD \geq 70\%$ indica que la vulnerabilidad ha sido confirmada de forma fiable. Resultados con QoD inferior se consideran informativos.

RD 311/2022: Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. Establece los principios y requisitos mínimos de seguridad para los sistemas de información de las Administraciones Públicas y sus proveedores.

RD 830/2010: Real Decreto 830/2010, de 25 de junio, que regula la capacitación y los requisitos para realizar tratamientos con biocidas en España, incluyendo la obligación de trazabilidad de los productos.

RFTP: Metodología de documentación de requisitos utilizada en el TFG: Requisito (coloquial) → Función (técnico) → Tarea (alcance) → Prueba (verificación).

SaaS (Software as a Service): Modelo de distribución de software en el que las aplicaciones se alojan en la nube y se accede a ellas a través de internet, sin instalación local.

SCAP (Security Content Automation Protocol): Protocolo que estandariza la nomenclatura de vulnerabilidades y configuraciones de seguridad. Es una de las bases de datos que actualiza OpenVAS antes de cada escaneo.

SIEM (Security Information and Event Management): Plataforma que centraliza y correlaciona logs de múltiples fuentes para detectar incidentes de seguridad en tiempo real. Wazuh es el ejemplo citado en trabajos futuros.

SMB (Server Message Block): Protocolo de red para compartir archivos, impresoras y otros recursos en redes Windows. En el proyecto se habilita de forma controlada para permitir el escaneo autenticado de OpenVAS.

Snapshot (Instantánea): Copia del estado completo de una máquina virtual en un momento dado, incluyendo memoria, disco y configuración. Permite restaurar el sistema a ese punto en caso de fallo o incidente.

Sniffing: Técnica de captura y análisis del tráfico de red. En redes planas sin cifrado, permite interceptar información sensible que viaja entre dispositivos.

SoA (Statement of Applicability): Declaración de Aplicabilidad. Documento que recoge qué controles del ENS se han implementado, cuáles no y por qué. Citado en la tabla RFTP como prueba de verificación de RNF-01.

Spoofing: Técnica de suplantación de identidad en redes: un equipo se hace pasar por otro (router, servidor DNS) para engañar a otros dispositivos.

SQL Injection: Tipo de ataque que inserta código SQL malicioso en campos de entrada de una aplicación web para manipular la base de datos subyacente.

SSB (Speculative Store Bypass): Vulnerabilidad de canal lateral en procesadores modernos (CVE-2018-3639) que permite a procesos malintencionados leer datos de memoria de otros procesos mediante ejecución especulativa.

SSH (Secure Shell): Protocolo de red para acceso remoto seguro a sistemas. En el proyecto se usa para administrar los servidores Ubuntu y se bastiona deshabilitando el acceso por contraseña.

UFW (Uncomplicated Firewall): Interfaz simplificada para gestionar el firewall iptables en sistemas Linux. En el proyecto se configura en Ubuntu Server para restringir el tráfico entrante a los puertos estrictamente necesarios.

UO (Unidad Organizativa): Contenedor en Active Directory que agrupa usuarios, equipos u otros objetos para facilitar la aplicación de políticas de grupo (GPOs). En el proyecto se crean UOs por perfil (Dirección, Administración, Técnicos, Sistemas).

VLAN (Virtual Local Area Network): Red de área local virtual que permite segmentar lógicamente una red física en múltiples redes independientes. Citada en trabajos futuros como mejora de segmentación interna.

VM (Virtual Machine / Máquina Virtual): Entorno de computación que emula un sistema físico dentro de otro. En el proyecto se usan VMs en VirtualBox para desplegar los servidores sin necesidad de hardware dedicado.

VirtualBox: Software de virtualización de código abierto de Oracle. Es el hipervisor sobre el que se despliega toda la infraestructura del proyecto.

WAN (Wide Area Network): Red de área amplia, generalmente internet. En el proyecto, la zona WAN representa la conexión exterior, separada de la LAN interna por OPNsense.

Windows Server 2022: Sistema operativo de servidor de Microsoft. En el proyecto actúa como Controlador de Dominio de la red de Saniter.

WMI (Windows Management Instrumentation): Infraestructura de Microsoft para la gestión y monitorización de sistemas Windows de forma remota. Se habilita en el proyecto para permitir el escaneo autenticado de OpenVAS sobre el servidor Windows.

1 Justificación del proyecto

1.1 Motivación y origen del proyecto

La idea de este proyecto surge de una situación que se da con bastante frecuencia: empresas que llevan años funcionando bien en lo operativo, pero que nunca han prestado demasiada atención a la seguridad de su infraestructura porque, hasta ahora, nadie se lo había exigido. Eso cambia cuando empiezan a prestar servicios a la Administración Pública.

En el caso de Saniter, la empresa ya tiene montado un Directorio Activo y un servidor web con base de datos. El problema no es que les falte tecnología, sino que la tienen mal configurada: sin segmentación de red, con contraseñas compartidas entre empleados y con servicios expuestos que no deberían estarlo. Nada que no tenga solución, pero hay que hacerlo bien y documentarlo.

El proyecto se divide en dos partes: primero se monta la infraestructura inicial con todos esos fallos a propósito, para tener un punto de partida realista. Luego se audita, se corrige y se verifica que los cambios han funcionado. El resultado final tiene que demostrar que la empresa cumple con la Categoría MEDIA del ENS.

1.2 Estado de la cuestión y público objetivo

Actualmente, muchas de las PYMES del sector de la sanidad ambiental no sitúan la seguridad de su infraestructura como una prioridad. Es habitual encontrar empresas que consideran que con el hecho de alojar su información en servidores ya son seguras. Sin embargo, no son conscientes de la importancia de una configuración adecuada en la seguridad de su infraestructura, ya que las opciones por defecto priorizan la operatividad sobre la protección y se convierten en sistemas muy fáciles de atacar. Estas configuraciones mantienen activos servicios que no se utilizan realmente, lo que hace que la superficie de ataque sea mayor.

En el mercado actual, existen soluciones SaaS y plataformas Cloud que facilitan el cumplimiento de normativas de seguridad, si bien el control sobre

ciertos elementos de la infraestructura se pierde. Por ello, en este proyecto se propone una infraestructura propia para garantizar un mayor control, empleando tecnologías como:

- Directorio Activo: Cambiar la gestión de usuarios actual (plana y sin control) hacia una estructura jerárquica basada en Unidades organizativas y aplicación de Directivas de Grupos (GPOs) de seguridad.
- OPNsense: sustituir la gestión básica del router por un firewall profesional que implemente la separación entre red externa e interna, controlando el tráfico mediante reglas de firewall.

Este proyecto está dirigido a administradores de sistemas, consultores de ciberseguridad o dueños de PYMES que estén en la misma situación que la empresa creada. Este documento pretende servir de guía metodológica, mostrando el paso a paso para transformar una infraestructura básica en una infraestructura madura y alineada con el cumplimiento normativo.

1.3 Descripción de la empresa

Saniter es una PYME con un recorrido de más de 25 años en el sector de la sanidad ambiental. Sus principales servicios son el tratamiento de aguas y los servicios de desinfección, desinsectación y desratización (DDD). Históricamente, su modelo de negocio ha dependido de una cartera de clientes variada, que incluye clientes particulares, pequeñas y medianas empresas (restauración, oficinas, talleres, etc.) y Administraciones Públicas, siendo éstas últimas las que generan mayores ingresos en la empresa.

En el panorama actual, aunque Saniter ha modernizado su infraestructura recientemente, no llega a cumplir con los requisitos de seguridad necesarios, aumentando el riesgo ante ciberamenazas. Además, la entrada en vigor de nuevas exigencias de seguridad, obliga a que cualquier empresa que colabore con el sector público, debe estar alineado con el esquema Nacional de Seguridad (ENS).

Saniter cuenta con una sede física dividida en dos áreas operativas diferenciadas:

- Almacén de productos químicos: espacio destinado al almacenamiento de productos biocidas conforme a la normativa vigente. Requiere un control de stock riguroso para garantizar la trazabilidad del producto (exigencia legal). El personal accede a través del navegador web a la base de datos de la empresa, donde se alojan los datos del stock, y desde ahí registran los diferentes movimientos (compras, retirada, devolución) de los productos. Todos los empleados usan el mismo usuario y contraseña para facilitar el día a día.
- Oficina: área donde se gestiona toda la documentación y la relación con los clientes. Cuenta con diversas terminales de trabajo, servicios centralizados recientemente instalados y un router básico que actúa como única barrera entre la red externa y la interna. No existe segmentación ni control de accesos.

1.4 Alcance del proyecto

El presente proyecto abarca el diseño, despliegue y securización del núcleo crítico de la infraestructura tecnológica de Saniter.

Dentro del alcance:

- Seguridad perimetral y red.
- Gestión centralizada de identidades.
- Servicios de aplicación y datos.
- Auditoría técnica inicial de los servicios para identificar vulnerabilidades.

Fuera del alcance:

- Configuración de equipos cliente (Endpoints).
- Desarrollo de software a medida.

2 Introducción

2.1 Principales funciones y problemas que resuelve

El sistema resultante de este proyecto cumple las siguientes funciones:

- Gestión centralizada de identidades y accesos.
- Protección perimetral mediante firewall.
- Auditoría técnica de vulnerabilidades.
- Bastionado de servidores.
- Garantía de la trazabilidad de los datos críticos.

Los problemas mostrados a continuación son aquellos que actualmente tiene Saniter que las funciones mencionadas anteriormente resuelven:

- Incumplimiento normativo: actualmente no se cumple con el Real Decreto 311/2022. No cumplir con dicha normativa, podría acarrear la pérdida del contrato con la Administración Pública, además de la imposibilidad de conseguir nuevos contratos, lo que derivaría en pérdidas económicas significativas. Aplicando las medidas adecuadas, se conseguirá cumplir con la normativa.
- Trazabilidad de biocidas descontrolada: la integridad de los datos registrados en el stock no está garantizada, ya que no hay diferenciación de usuarios ni limitación de permisos. La incorrecta gestión de los registros de consumo de ciertos biocidas puede acarrear sanciones. Configurando adecuadamente los permisos y usuarios de la base de datos, se conseguirá proteger la integridad de los registros.
- Red plana sin aislar: no existe segmentación de la red ni protección en la entrada. Si uno de los terminales se ve infectado, toda la infraestructura se vería comprometida. La instalación de OPNSense con función de router, firewall, y segmentación de red solucionará este riesgo.
- Inexistencia de control de accesos y permisos: al no haber control sobre qué usuarios acceden a cada servicio y con todos los permisos disponibles, el riesgo de seguridad es muy alto. Si se comprometen

las credenciales de uno de los empleados, se podría alterar o eliminar toda la base de datos de la empresa. La reorganización del Directorio Activo en Unidades Organizativas y la aplicación de políticas de grupo, permitirá corregir este problema.

2.2 Requisitos del Proyecto

La siguiente tabla recoge los requisitos funcionales y no funcionales identificados para el proyecto:

Tabla 1 - Requisitos del proyecto

ID	Requisito	Tipo	Descripción	Control ENS*
RF-01	Gestión de Identidad	Funcional	Centralizar el control de acceso y la autenticación de usuarios mediante un servicio de directorio activo.	[op.acc.1], [op.acc.2], [op.acc.4]
RF-02	Auditoría Técnica	Funcional	Capacidad de identificar y evaluar debilidades en los sistemas mediante escaneos de vulnerabilidades.	[op.vig.1]
RF-03	Servicio Web y BBDD	Funcional	Implementación de un entorno LAMP con acceso restringido a la base de datos.	[mp.s.1]
RF-04	Registro y Trazabilidad	Funcional	Generación de registros de eventos (logs) que permitan monitorizar la	[op.mon.1], [op.exp.8]

			actividad crítica del sistema.	
RF-05	Continuidad y Backup	Funcional	Asegurar la recuperación de la información ante fallos mediante políticas de copias de seguridad automatizadas.	[op.cont.2], [mp.info.6]
RNF-01	Adecuación al ENS	No Funcional	El diseño y configuración de los sistemas deben cumplir las salvaguardas del Anexo II del RD 311/2022 para Categoría MEDIA.	RD 311/2022
RNF-02	Mínimo Privilegio	No Funcional	Restringir los permisos de administración solo a los perfiles necesarios para cada función.	[op.acc.2], [op.acc.4]
RNF-03	Segmentación de Red	No Funcional	Aislamiento lógico de los servicios críticos mediante filtrado de tráfico y uso de redes internas.	[op.net.1], [mp.com.1]

3 Objetivos

El objetivo principal de este proyecto es habilitar legal y técnicamente a la organización para poder operar como proveedora de servicios de la Administración Pública. Para conseguirlo, se trabaja en la implementación

de diferentes controles para lograr así la Categoría MEDIA del Esquema Nacional de Seguridad (ENS).

Los objetivos específicos serían los siguientes:

- Desplegar un entorno virtualizado seguro compuesto por controladores de dominio Windows Server 2022, un servidor de servicios Ubuntu Server y un firewall OPNsense interconectados.
- Evaluar el estado de la seguridad inicial mediante herramientas de auditoría técnica (OpenVAS) para identificar vulnerabilidades.
- Fortalecer los sistemas operativos mediante técnicas de bastionado (Hardening) alineadas con los controles del ENS.
- Verificar el cumplimiento de las medidas de seguridad mediante un proceso de post-auditoría y análisis de resultados.

PROMETEO

3.1 Tabla RFTP

A continuación, se desglosan los requisitos operativos del proyecto mediante la metodología RFTP (Requisito, Función, Tarea y Prueba):

Tabla 2 - Tabla RFTP

ID Req	R	F	T	P
RF-01	Gestión de Identidad: Control de accesos	Servicios de Dominio (AD DS) con GPOs de seguridad	Promoción de DC, creación de UOs, asignación de GPOs, gestión de usuarios con mínimo privilegio	Inicio de sesión con cuenta de dominio. Verificación de GPOs aplicadas.
RF-02	Auditoría Técnica: Detección de agujeros de seguridad	Auditoría con OpenVAS (caja blanca)	Configuración de escaneos, actualización de feeds, análisis de informes pre y post hardening	Reporte de vulnerabilidades en PDF. Comparativa antes/después.
RF-03	Servicio Web y BBDD: Web segura y base de datos aislada	Stack LAMP con hardening. Acceso a BBDD restringido a localhost	Instalación de Apache/MariaDB, configuración de UFW, restricción de acceso a puerto 3306	Acceso web exitoso. Verificación de que el puerto 3306 no es accesible desde red.
RF-04	Registro y Trazabilidad: Conocimiento sobre la actividad en servidores	Gestión de logs y trazabilidad de eventos	Configuración de auditoría en Windows (visor de sucesos).	Verificación de eventos de inicio de sesión en visor de sucesos y en /var/log/auth.log.

PROMETEO

			Configuración de auth.log y syslog en Ubuntu	
RF-05	Continuidad y Backup: Evitar pérdida de datos ante fallos	Plan de backup y recuperación	Programación de backup automático de BBDD con mysqldump. Snapshot de VMs en VirtualBox	Restauración exitosa de una tabla de la base de datos desde el backup.
RNF-01	Adecuación al ENS: Cumplir el ENS Categoría MEDIA	Adecuación al Anexo II del RD 311/2022	Valoración de activos, categorización, selección de salvaguardas, implementación y verificación	Declaración de Aplicabilidad (SoA). Post-auditoría con OpenVAS.
RNF-02	Mínimo Privilegio: Cada usuario solo puede hacer lo estrictamente necesario	Mínimo privilegio en AD y en BBDD	GPOs de restricción de permisos. Usuarios de BBDD con permisos limitados por tabla	Verificación de que el usuario de almacén solo puede INSERT/SELECT en tabla stock.
RNF-03	Segmentación de Red: Aislamiento de los servicios críticos	Segmentación WAN/LAN con OPNsense	Instalación de OPNsense, configuración de interfaces WAN/LAN, reglas de firewall según ENS	Verificación de que desde WAN solo es accesible el puerto 443 del servidor web.

4 Descripción

4.1 Marco normativo y categorización (ENS)

4.1.1 Identificación de activos críticos

A continuación, se identifican los activos críticos de la infraestructura de Saniter, clasificados por tipo de activo (Hardware, software, servicio, datos y personal):

Tabla 3 - Identificación de activos críticos

ID	Activo	Tipo	Descripción
HW-01	VM Servidor Web/BBDD	Hardware	Máquina virtual que aloja conjuntamente el servidor web y la base de datos. En la fase inicial ambos servicios residen en la misma máquina virtual. La separación en dos máquinas independientes se contempla como mejora futura.
HW-02	VM Controlador de Dominio	Hardware	Máquina virtual para la gestión centralizada de identidades mediante Windows Server 2022.
SW-01	Ubuntu Server 22.04 (Web/BBDD)	Software	Sistema operativo base del servidor web y de base de datos.
SW-02	Windows Server 2022	Software	Sistema operativo del controlador de dominio.
SW-03	Servicios Apache / PHP	Software	Stack tecnológico para la ejecución de la web corporativa.
SW-04	Motor MariaDB	Software	Gestor de base de datos relacional.
S-01	Servicio de Navegación Web	Servicio	Disponibilidad de la web de Saniter hacia el exterior.

S-02	Servicio de Gestión de Datos	Servicio	Consulta y edición de tablas de stock de biocidas.
S-03	Servicio de Autenticación	Servicio	Gestión de identidades y acceso centralizado mediante Active Directory.
D-01	Base de Datos de Inventario	Datos	Información crítica de biocidas y trazabilidad legal.
D-02	Datos de Clientes y Contratos	Datos	Información sensible sobre servicios prestados a centros públicos y administraciones.
D-03	Credenciales y GPOs	Datos	Datos de acceso y políticas de seguridad del dominio.
D-04	Contenido Web Corporativo	Datos	Código fuente e información pública de la empresa.
P-01	Administradora de Sistemas	Personal	Beatriz. Único perfil con acceso total a la infraestructura.
P-02	Usuarios de Oficina y Almacén	Personal	Personal con acceso a los servicios según su función operativa diaria.

Nota: como resultado del proceso de adecuación al ENS, una vez terminado el proceso, se incorporarán dos nuevos activos a la infraestructura: el firewall OPNsense y el equipo auditor Kali Linux.

4.1.2 Valoración de las dimensiones de ciberseguridad

La siguiente tabla recoge la valoración de cada activo en las cinco dimensiones de seguridad definidas por el ENS. Los posibles niveles son: BAJO, MEDIO y ALTO, según el impacto que tendría sobre la organización la pérdida de cada dimensión en ese activo. Los activos de tipo software de soporte (SW-01, SW-02) se valoran de forma indirecta a través de los servicios que sustentan, por lo que no se incluyen como filas independientes en esta tabla.

PROMETEO

Tabla 4 - Leyenda categorías ENS

CATEGORÍAS ENS		
Baja	Media	Alta

Tabla 5 - Análisis de riesgos

ID	Activo	Confidencialidad	Integridad	Disponibilidad	Autenticidad	Trazabilidad	Justificación
HW-01	Máquina Virtual Web/BBDD	Media	Media	Media	Media	Media	Aloja los activos más críticos: la base de datos de biocidas y el servidor web. Su caída implica la pérdida de todos los servicios dependientes.
HW-02	Máquina Virtual Controlador de Dominio	Media	Media	Media	Media	Media	Sin este activo no hay autenticación de usuarios ni aplicación de políticas de seguridad.
SW-03	Servicios Apache / PHP	Baja	Media	Media	Baja	Baja	Su integridad y disponibilidad son necesarias para el funcionamiento de la web corporativa.

PROMETEO

SW-04	Motor MariaDB	Baja	Media	Media	Media	Media	Garantiza la integridad y trazabilidad de los datos sobre productos químicos con exigencia legal.
S-01	Servicio de Navegación Web	Baja	Baja	Media	Baja	Baja	Vital para la imagen pública y los pedidos de clientes. Una caída prolongada afecta al negocio.
S-02	Servicio de Gestión de Datos	Baja	Media	Media	Media	Media	Operativa diaria del stock de biocidas. Su integridad es exigencia legal (RD 830/2010).
S-03	Servicio de Autenticación (AD)	Media	Media	Media	Media	Media	Sin el Directorio Activo no hay acceso controlado a ningún recurso de red.
D-01	Base de Datos de Inventario	Baja	Media	Media	Media	Media	Información crítica de biocidas. La trazabilidad es exigencia legal (RD 830/2010).
D-02	Datos de Clientes y Contratos	Media	Media	Baja	Baja	Baja	Datos sensibles de centros críticos (centros públicos y administraciones).
D-03	Credenciales y GPOs	Media	Media	Media	Media	Media	Clave para el control de acceso. Su compromiso permitiría el acceso no autorizado a toda la infraestructura.
D-04	Contenido Web Corporativo	Baja	Media	Baja	Baja	Baja	Su alteración podría provocar desinformación pública o daño reputacional.
P-01	Administradora de Sistemas	Media	Media	Media	Media	Media	Acceso total a la infraestructura.
P-02	Usuarios de Oficina y Almacén	Baja	Baja	Baja	Media	Media	Acceso limitado. Su compromiso afecta principalmente a la integridad del stock de biocidas.

4.1.3 Determinación de la categoría del sistema

Según el Anexo I del Real Decreto 311/2022, la categoría de un sistema de información se determina en función del nivel más alto alcanzado por cualquier activo en alguno de los cinco pilares de la seguridad: Confidencialidad, Integridad, Disponibilidad, Autenticidad y Trazabilidad.

Tras analizar la tabla de activos de Saniter, se comprueba que:

- Ningún activo alcanza nivel ALTO en ninguno de los apartados.
- Varios activos críticos alcanzan nivel MEDIO en todos los apartados (D-03, S-03, HW-01, HW-02, P-01).
- Ningún activo se mantiene en nivel BAJO por completo.

Por lo tanto, el nivel más alto alcanzado por los activos es MEDIO, lo que determina que la infraestructura de Saniter corresponde a un *"sistema de información de Categoría MEDIA"* según el Anexo I del RD 311/2022. Esta asignación es lógica, teniendo en cuenta que Saniter presta servicios a Administraciones Públicas y gestiona datos de biocidas con exigencia legal de trazabilidad.

4.1.4 Análisis de riesgos

Una vez identificados los activos, el siguiente paso es analizar qué amenazas les afectan y qué pasaría si alguna de ellas se materializara. Para este análisis se ha seguido la metodología MAGERIT v3, que es la que recomienda el CCN para cumplir con el ENS. El análisis se centra en el entorno *"Red_saniter_inicial"*, que es el escenario inseguro de partida antes de aplicar ninguna medida de seguridad.

4.1.4.1 Identificación de amenazas

Se han identificado las amenazas más relevantes para cada uno de los activos críticos del sistema:

Windows Server 2022 – Controlador de dominio (HW-02):

1. Acceso no autorizado: intentos de intrusión para obtener privilegios de administrador de dominio.
2. Ataques de fuerza bruta: sobre los servicios de autenticación de Active Directory.
3. Configuración incorrecta: errores en las GPOs que permitan elevación de privilegios.

Ubuntu Server 22.04 -Servidor Web y BBDD (HW-01):

1. Explotación de vulnerabilidades: fallos conocidos en Apache o MariaDB sin parchear.
2. Inyección SQL: ataques de SQL injection contra la base de datos a través de phpMyAdmin.
3. Interrupción del servicio (DoS): ataques intencionados que paralicen el servidor web.

Factor Humano (P-01, P-02):

1. Uso indebido de privilegios: Ausencia de la regla del mínimo privilegio, por lo que todos los empleados tienen el mismo nivel de acceso al sistema.
2. Credenciales compartidas: todos los usuarios del almacén usan el mismo usuario y contraseña para acceder a la base de datos, lo que impide la trazabilidad individual y facilita el uso indebido.

Red interna (*Red_saniter_inicial* - entorno compartido):

La red no se considera un activo como tal, pero se tiene en cuenta para la identificación de amenazas.

1. Intercepción de datos (Sniffing): al no existir segmentación de red, puede capturarse el tráfico entre servidores si hay acceso a la red interna.
2. Suplantación de identidad (Spoofing): un equipo malintencionado haciéndose pasar por el router o el servidor DNS.

4.1.4.2 Matriz de riesgo

Una vez identificados los activos y sus amenazas, se calcula el riesgo de cada una de estas últimas. El resultado obtenido indicará el estado de la seguridad del sistema de información y de la infraestructura de Saniter.

Para el cálculo del riesgo, se emplea la siguiente fórmula:

$$\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$$

Probabilidad expresa la frecuencia o posibilidad de que una amenaza se materialice mientras que el impacto muestra el daño resultante sobre ese activo si se llega a producir dicha amenaza.

En MAGERIT V3, los dos factores mencionados se valoran en una escala cualitativa de cinco niveles (Muy bajo, Bajo, Medio, Alto y Muy Alto), que dan lugar a la siguiente matriz de riesgo al cruzar ambos factores:

Tabla 6 - Matriz de riesgo MAGERIT V3

RIESGO		PROBABILIDAD				
		Muy Bajo	Bajo	Medio	Alto	Muy Alto
IMPACTO	Muy Alto	Alto	Muy Alto	Muy Alto	Muy Alto	Muy Alto
	Alto	Medio	Alto	Alto	Muy Alto	Muy Alto
	Medio	Bajo	Medio	Medio	Alto	Alto
	Bajo	Muy Bajo	Bajo	Bajo	Medio	Medio
	Muy Bajo	Muy Bajo	Muy Bajo	Muy Bajo	Bajo	Bajo

La siguiente tabla muestra el cálculo del riesgo de cada amenaza identificada anteriormente:

Tabla 7 - Nivel de riesgo de las amenazas

Amenaza	Activo afectado	Prob.	Impacto	Nivel de riesgo
Acceso no autorizado al Directorio Activo	HW-02 D-03	Baja	Muy Alto	Alto
Fuerza bruta en servicios de autenticación	S-03 D-03	Muy Alta	Bajo	Medio
Error humano en configuración, escalada de privilegios por GPOs erróneas	P-01	Media	Medio	Medio
Explotación de vulnerabilidades en servidor web	HW-01 S-01	Alta	Alto	Muy Alto
Inyección SQL (phpMyAdmin expuesto en LAN)	D-01 SW-04	Media	Alto	Alto
Ataque DoS interrupción del servicio	HW-01 S-01	Media	Alto	Alto
Intercepción de tráfico (Sniffing)	D-01 D-02	Media	Alto	Alto
Suplantación de identidad (Spoofing)	S-03 S-01	Baja	Medio	Bajo
Pérdida de VM / fallo de hardware	HW-01 HW-02	Baja	Alto	Medio
Credenciales compartidas / uso indebido	D-01 S-02	Alta	Medio	Alto

4.1.4.3 Evaluación del riesgo intrínseco

El riesgo intrínseco es el nivel de riesgo existente previo a la aplicación de medidas de seguridad. Se observa que únicamente una de las amenazas tiene un riesgo bajo, mientras que las demás tienen riesgos medios y altos en su mayoría, llegando a existir riesgo Muy Alto en el caso de explotación de vulnerabilidades del servidor web. Por lo tanto, el nivel de riesgo intrínseco del sistema es demasiado alto y se considera inadmisibles para una Categoría MEDIA del ENS.

El objetivo es reducir ese nivel de riesgo a uno razonable para una empresa de este tipo. Para lograrlo se propone la aplicación de las siguientes medidas:

1. Bastionado (hardening): reducción de la superficie de ataque cerrando servicios innecesarios y aplicando configuraciones seguras.
2. Segregación de red: implementación de OPNsense para aislar los activos críticos del tráfico externo mediante reglas de firewall perimetral.
3. Segregación de funciones: limitando el acceso total únicamente al perfil de administración y creando usuarios individuales con permisos mínimos en la base de datos.
4. Auditoría continua: uso de OpenVAS para verificar que el nivel de riesgo no aumenta con el tiempo debido a nuevas vulnerabilidades.

Estas medidas se describen más detalladamente en puntos posteriores del presente documento.

4.1.5 Selección de medidas de seguridad y salvaguardas

Tras llevar a cabo la categorización del sistema y evaluarlo, se han seleccionado los controles del Anexo II del Real Decreto 311/2022 que resultan de aplicación para Categoría MEDIA.

En este punto del proyecto ya se han aplicado controles pertenecientes al apartado de marco organizativo y gestión de riesgos:

- [op.pl.1] Análisis de riesgos: Se han evaluado las amenazas que afectan a los activos críticos.
- [op.exp.1] Inventario de Activos: Se ha creado un registro detallado de los activos críticos de la organización.

En cuanto a los controles que requieren actuaciones técnicas, se muestran en la siguiente tabla:

Tabla 8 - Controles ENS técnicos

Código ENS	Medida (Anexo II – RD 311/2022)	Implementación técnica en el proyecto
[op.acc.1]	Identificación: usuarios de forma única	Cuentas nominales en Active Directory. Se elimina el uso de credenciales compartidas.
[op.acc.2]	Gestión de privilegios: mínimo privilegio	Restricción de permisos sudo en Ubuntu y delegación de control en AD según rol.
[op.acc.4]	Autenticación: contraseñas robustas	GPOs para complejidad y rotación de contraseñas en el dominio.
[op.exp.8]	Registro de actividad: logs del sistema	Configuración de auditoría de inicio de sesión en Windows y auth.log en Ubuntu.
[op.mon.1]	Detección de intrusiones	Registro y revisión de eventos del sistema en ambos servidores.

[op.vig.1]	Detección de deficiencias: escaneos de vulnerabilidades	Auditorías técnicas con OpenVAS antes y después del bastionado.
[op.net.1]	Segregación de redes	Configuración de OPNsense con zonas WAN/LAN y reglas de firewall. UFW en Ubuntu.
[op.cont.2]	Continuidad: copias de seguridad	Tareas automáticas de backup de la BBDD y snapshots de VMs en VirtualBox.
[mp.s.1]	Instalación y aceptación: configuración segura inicial	Aplicación de guías CCN-STIC sobre los sistemas operativos desplegados.
[mp.com.1]	Perímetro seguro	Interfaces y reglas de firewall OPNsense para aislar la red interna del tráfico externo.
[mp.info.6]	Protección de la información: copias de seguridad	Backups automatizados de la base de datos de productos de Saniter.

4.2 Arquitectura de Red y Segmentación

4.2.1 Arquitectura de red inicial

En el escenario inicial, todos los equipos están en la misma red (172.16.0.0/24): el servidor del Directorio Activo, el servidor web con la base de datos y el equipo auditor. El único elemento que hay entre la red interna e internet es un router básico que no filtra nada.

Esto significa que si un empleado del almacén realiza alguna acción y compromete su equipo y se infecta, éste tiene acceso directo al servidor de base de datos, al Directorio Activo, a todo. No hay ninguna barrera que lo impida.

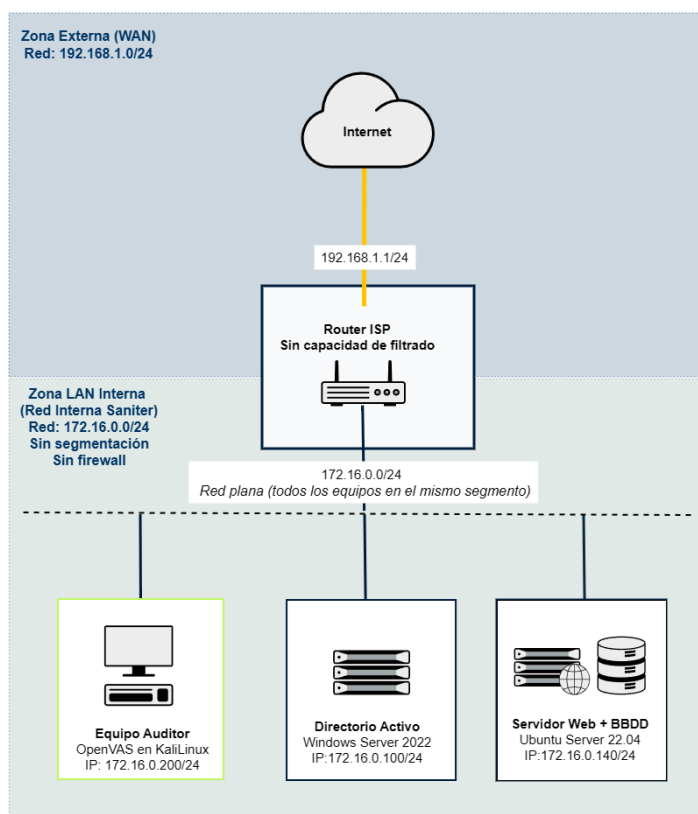


Ilustración 1 - Diagrama de red inicial

4.2.2 Arquitectura de red tras la implantación

La solución gira en torno a OPNsense, que pasa a ser la puerta de entrada y salida de toda la red. A partir de ahí, la red queda dividida en dos partes:

- Zona WAN (Red Externa) (192.168.1.0/24): representa la conexión a internet y es el punto de entrada de las peticiones externas hacia el servidor web.
- Zona LAN (Red Interna) (10.0.0.0/24): representa la red privada, donde se encuentran todos los activos críticos. El acceso desde la zona WAN está restringido mediante reglas de firewall acordes a los controles del ENS.

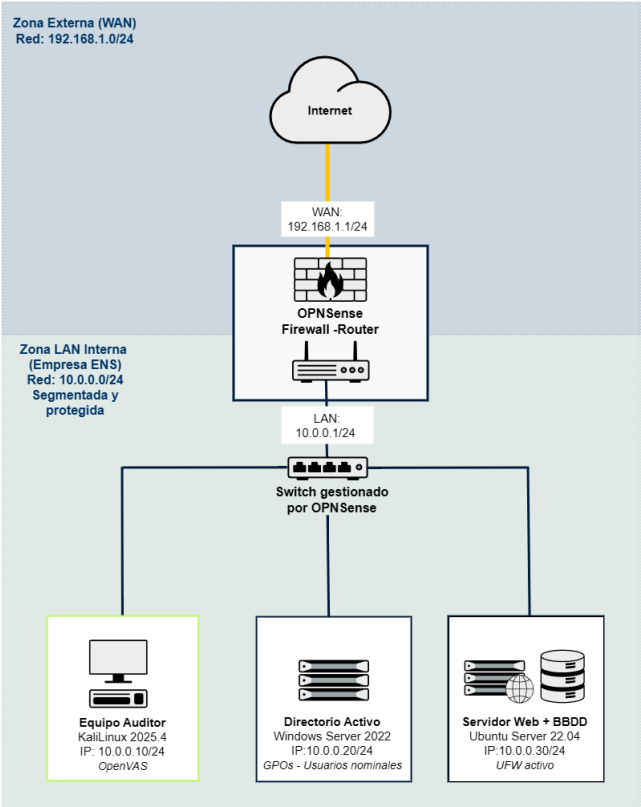


Ilustración 2 - Diagrama de red tras aplicar ENS

4.3 Despliegue e Implementación

4.3.1 Arquitectura inicial

4.3.1.1 Directorio Activo

Tabla 9 - Características técnicas de la VM del Directorio Activo

Software	
Sistema operativo	Windows server 2022
Hardware	
Disco duro	50 GB
Memoria RAM	4096 MB
Procesador	2 CPU
Memoria de video	128 MB
Controlador gráfico	VBoxSVGA
Red	
Adaptador 1	Red interna (Red_saniter_inicial)

** No se muestra el proceso de instalación en el proyecto, ya que se quiere poner el foco en la configuración posterior y en las medidas de mejora.*

Configuración del servidor

Una vez realizada la instalación del sistema operativo, realizaremos los siguientes pasos:

1º Asignación de nuevo nombre al servidor: Se le asigna un nombre fácil de identificar: SERVER-AD-01.

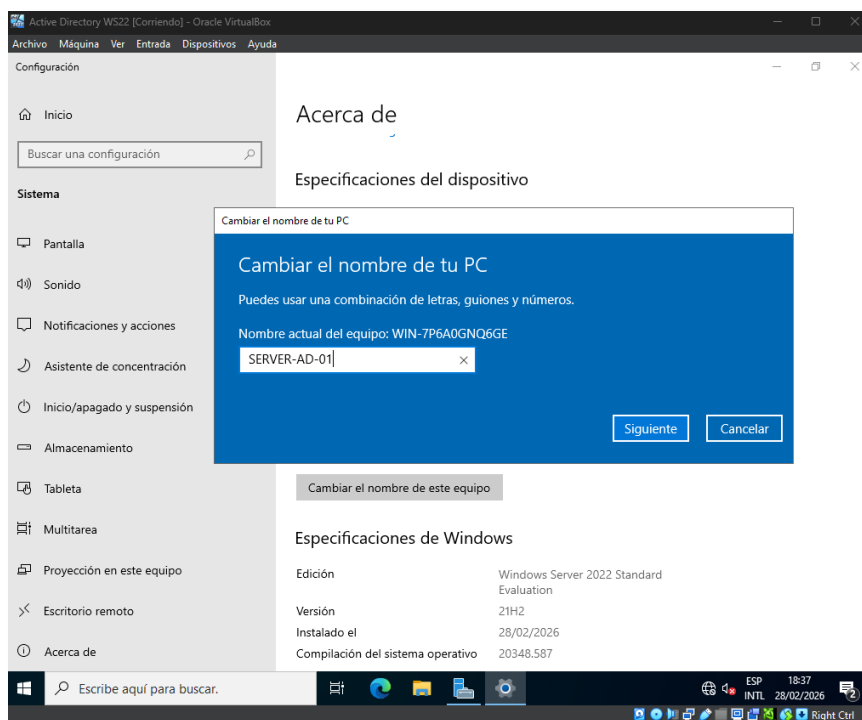


Ilustración 3 - Asignación de nombre al servidor Windows Server

2º Asignación IP estática

Se accede al Centro de redes y recursos compartidos → Cambiar configuración del adaptador. Clic derecho en tu tarjeta de red → **Propiedades.**

Seleccionamos la opción de protocolo de Internet versión 4 (TCP/IPv4) y entramos a sus Propiedades. En esta ventana se

selecciona “Usar la siguiente dirección IP” y se le asigna la IP que se considere.

Para el proyecto se ha determinado que la dirección de red de Saniter es 172.16.0.0/24. Se asigna al Directorio Activo la IP 172.16.0.100.

El DNS será este mismo servidor, por ello se indica la dirección de loopback en el apartado de Servidor DNS preferido.

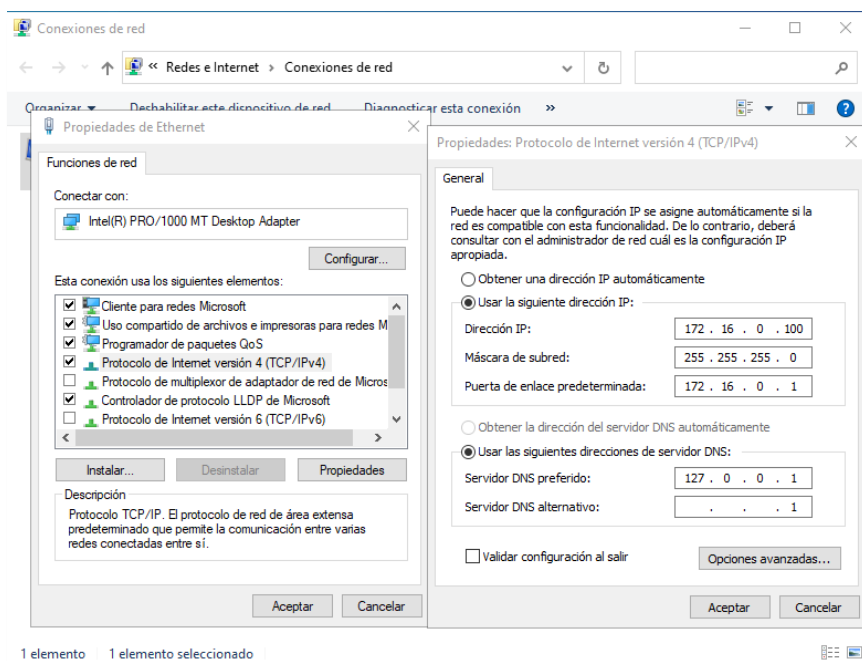


Ilustración 4 - Asignación IP estática Windows Server

3º Promoción a controlador de dominio

Tras la configuración inicial, se realiza la promoción a controlador de dominio del servidor. Se emplea la interfaz gráfica. En el apartado de selección de roles se elige la opción “Servicios de dominio de Active Directory”. Al marcar esta opción se marcarán todas aquellas relacionadas. No se selecciona Servidor DNS en un primer momento, ya que Windows lo detecta automáticamente y lo instala.

Se muestran las pantallas de inicio de sesión previa y posterior a la promoción a controlador de dominio.

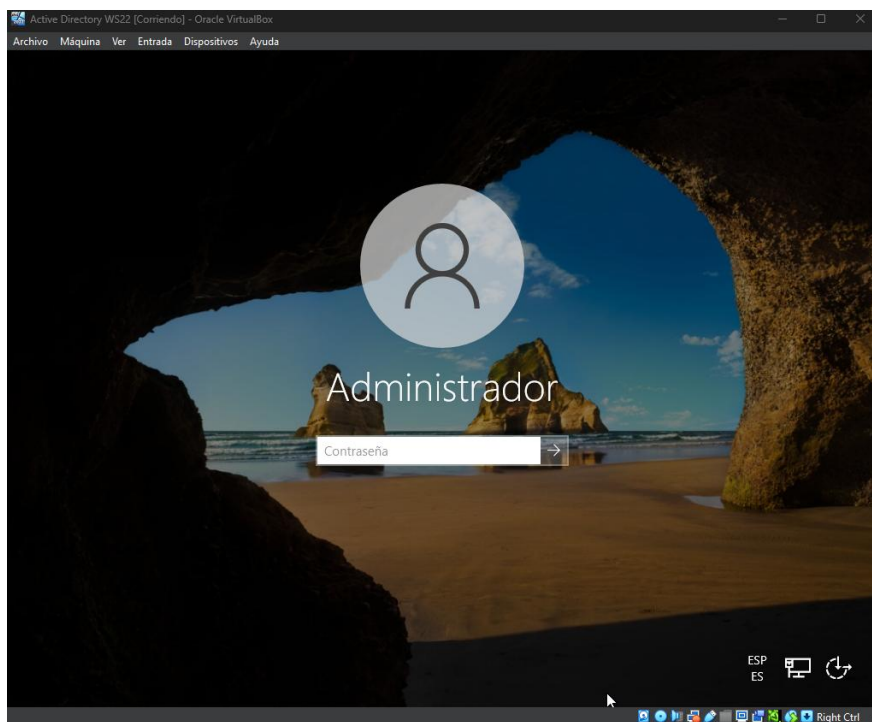


Ilustración 5 - Pantalla de inicio previo a promoción a controlador de dominio

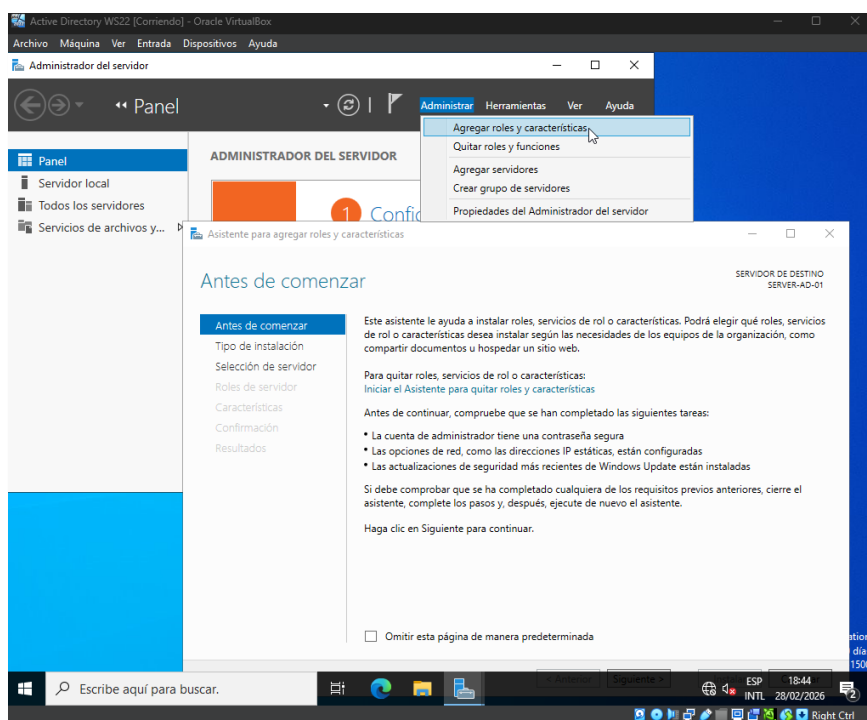


Ilustración 6 - Agregar roles y características

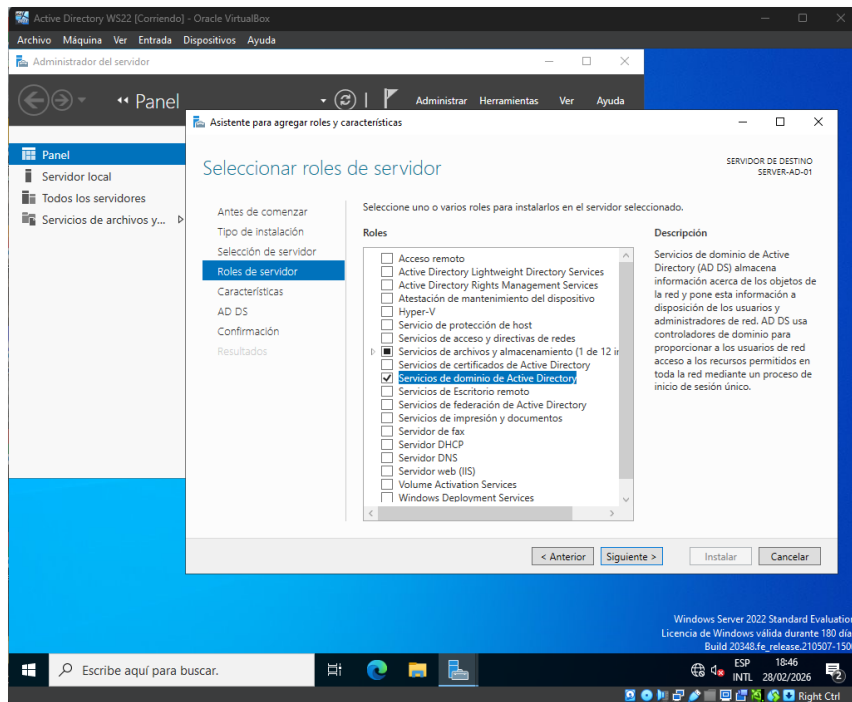


Ilustración 7 - Selección de roles del servidor

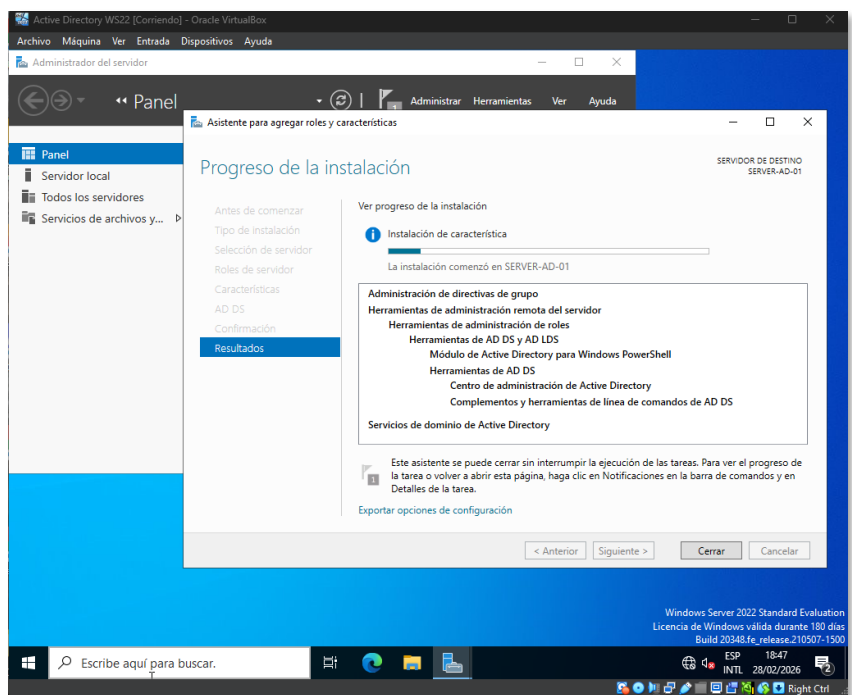


Ilustración 8 - Progreso de la instalación de roles y características

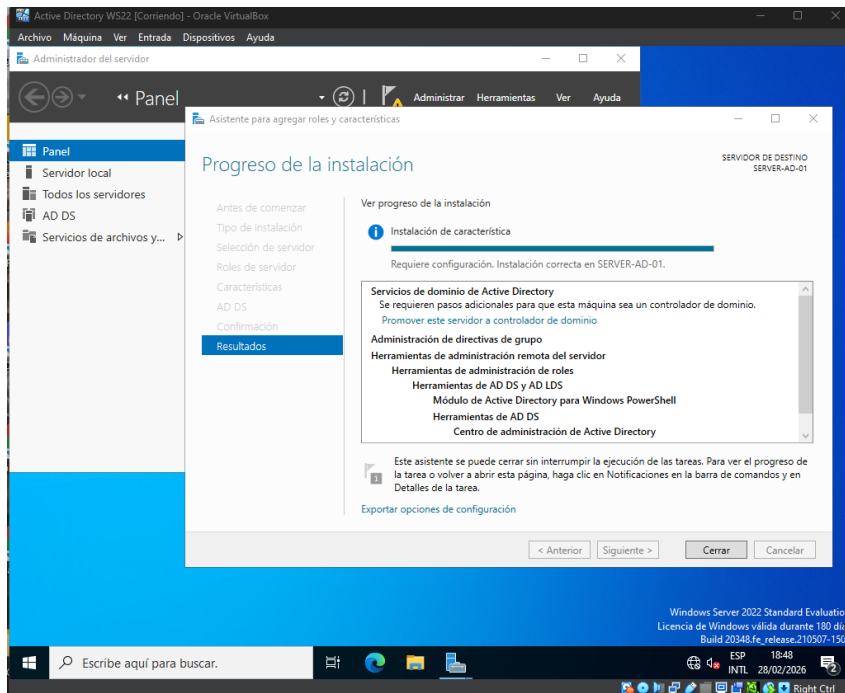


Ilustración 9 - Resultados de instalación de roles y características

Una vez se ha llevado a cabo la instalación de los roles, aparece en pantalla el asistente para configurar los servicios de dominio de Active Directory. En este paso se selecciona la opción de agregación de un nuevo bosque, cuyo dominio raíz será saniter.local, se asignará una nueva contraseña para el modo de restauración, y tras comprobación de requisitos, instalación y reinicio, el servidor ya es un controlador de dominio.

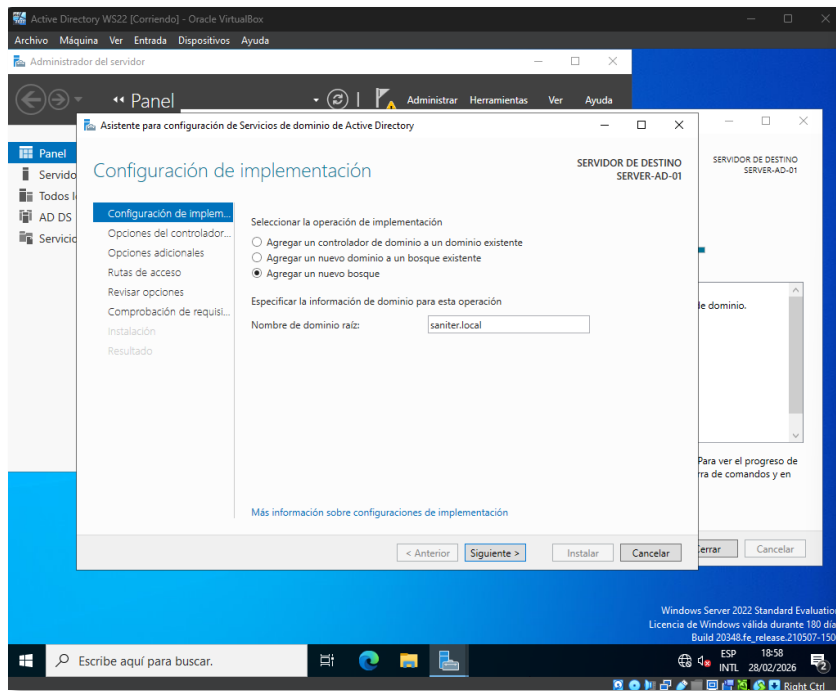


Ilustración 10 - Configuración de implementación

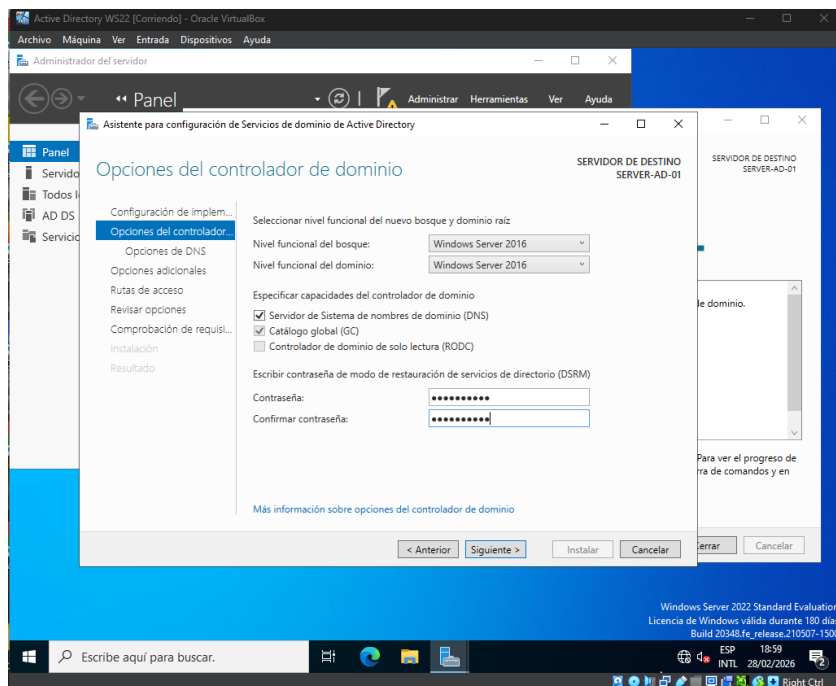


Ilustración 11 - Opciones del controlador de dominio

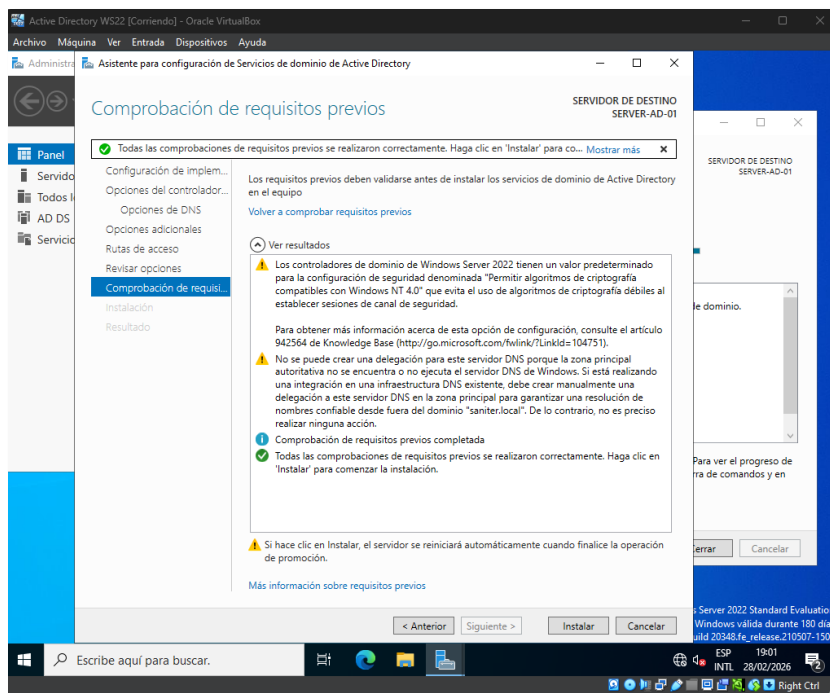


Ilustración 12 - Comprobación de requisitos previos

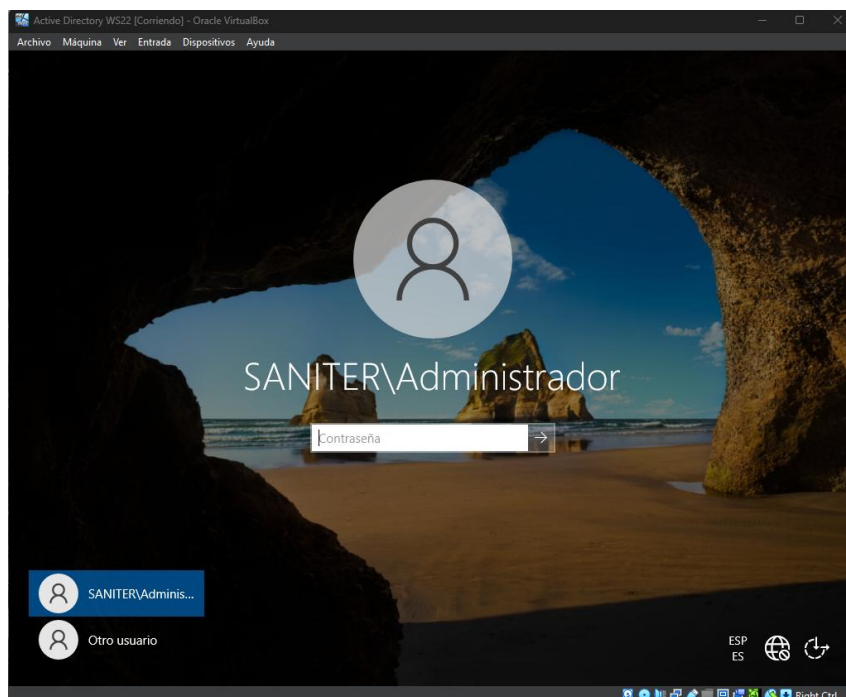


Ilustración 13 - Pantalla de inicio del controlador de dominio

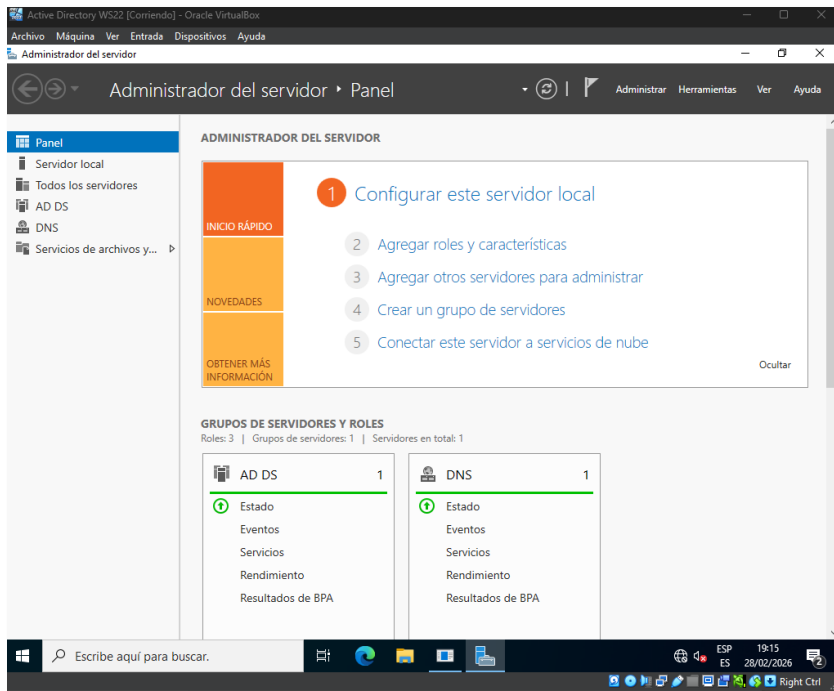


Ilustración 14 - Panel del Administrador del servidor I

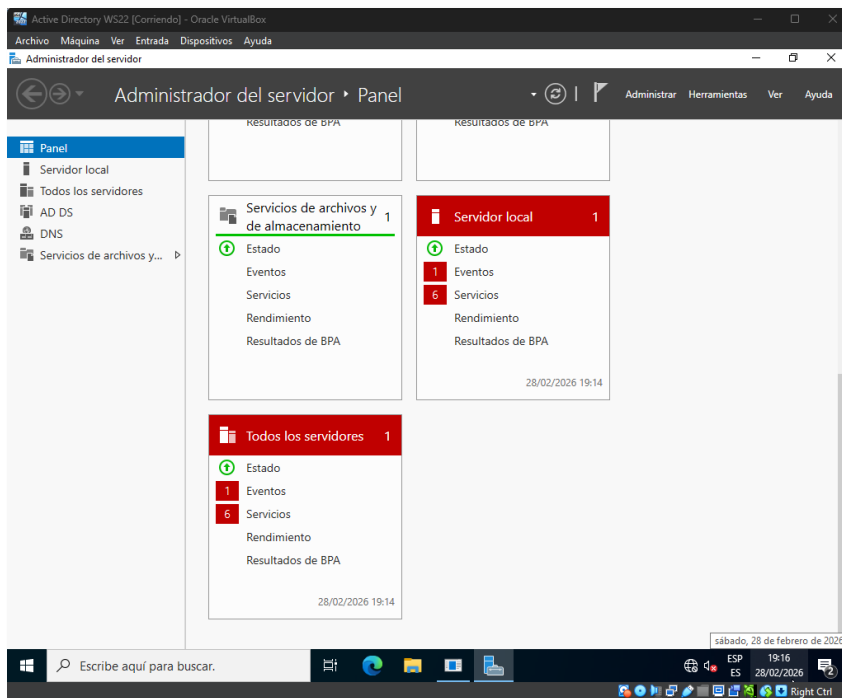
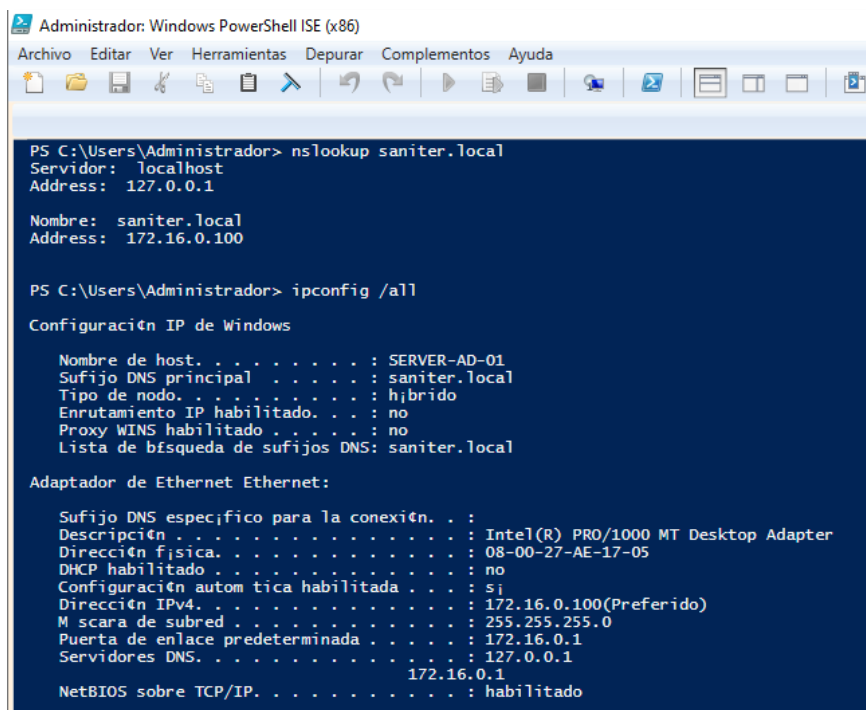


Ilustración 15 - Panel del Administrador del servidor II

* Se aprecian alertas rojas en el Administrador del Servidor, esto es debido a la latencia de inicio de los servicios de directorio.

Se comprueba a través de la consola PowerShell la configuración realizada:



```

Administrador: Windows PowerShell ISE (x86)
Archivo  Editar  Ver  Herramientas  Depurar  Complementos  Ayuda

PS C:\Users\Administrador> nslookup saniter.local
Servidor: localhost
Address: 127.0.0.1

Nombre: saniter.local
Address: 172.16.0.100

PS C:\Users\Administrador> ipconfig /all

Configuración IP de Windows

Nombre de host. . . . . : SERVER-AD-01
Sufijo DNS principal . . . . : saniter.local
Tipo de nodo. . . . . : híbrido
Enrutamiento IP habilitado. . . : no
Proxy WINS habilitado . . . . : no
Lista de búsqueda de sufijos DNS: saniter.local

Adaptador de Ethernet Ethernet:

Sufijo DNS específico para la conexión. . . :
Descripción . . . . . : Intel(R) PRO/1000 MT Desktop Adapter
Dirección física. . . . . : 08-00-27-AE-17-05
DHCP habilitado . . . . . : no
Configuración automática habilitada . . . : sí
Dirección IPv4. . . . . : 172.16.0.100(Preferido)
Máscara de subred . . . . . : 255.255.255.0
Puerta de enlace predeterminada . . . . : 172.16.0.1
Servidores DNS. . . . . : 172.0.0.1
                          172.16.0.1
NetBIOS sobre TCP/IP. . . . . : habilitado
  
```

Ilustración 16 - Comprobación configuración controlador de dominio en consola PowerShell

Creación de usuarios

En el escenario inicial, los usuarios del Directorio Activo se crean en la carpeta de usuarios por defecto, sin ninguna organización ni diferenciación en cuanto a permisos. Todos poseen la misma contraseña para “facilitar” la operativa diaria. El siguiente script de PowerShell automatiza la creación de usuarios:

```
$pass = ConvertTo-SecureString "Saniter2026" -
AsPlainText -Force

$nombres = "Alberto", "Alejandra", "Beatriz",
"Carlos", "Cristian", "JoseRamon", "Lidia"

foreach ($n in $nombres) {
    New-ADUser -Name $n -SamAccountName $n -
AccountPassword $pass -Enabled $true -
PasswordNeverExpires $true -Path
"CN=Users,$((Get-ADDomain).DistinguishedName)"
    Write-Host "Usuario $n creado correctamente
en CN=Users" -ForegroundColor Green}
```

Ilustración 17- Creación de usuarios en consola PowerShell

Nombre	Tipo	Descripción
Administrador	Usuario	Cuenta integrada para la...
Administradores clave	Grupo de seguridad - G...	Los miembros de este gr...
Administradores clave de la org...	Grupo de seguridad - U...	Los miembros de este gr...
Administradores de empresas	Grupo de seguridad - U...	Administradores design...
Administradores de esquema	Grupo de seguridad - U...	Administradores design...
Admins. del dominio	Grupo de seguridad - G...	Administradores design...
Alberto	Usuario	
Alejandra	Usuario	
Beatriz	Usuario	
Carlos	Usuario	
Controladores de dominio	Grupo de seguridad - G...	Todos los controladores ...
Controladores de dominio clon...	Grupo de seguridad - G...	Se pueden clonar los mi...
Controladores de dominio de s...	Grupo de seguridad - G...	Los miembros de este gr...
Cristian	Usuario	
DnsAdmins	Grupo de seguridad - D...	Grupo de administrador...
DnsUpdateProxy	Grupo de seguridad - G...	Clientes DNS que tienen...
Enterprise Domain Controllers d...	Grupo de seguridad - U...	Los miembros de este gr...
Equipos del dominio	Grupo de seguridad - G...	Todos los servidores y es...
Grupo de replicación de contras...	Grupo de seguridad - D...	Los miembros de este gr...
Grupo de replicación de contras...	Grupo de seguridad - D...	Los miembros de este gr...
Invitado	Usuario	Cuenta integrada para el...
Invitados del dominio	Grupo de seguridad - G...	Todos los invitados del d...
JoseRamon	Usuario	
krbtgt	Usuario	Cuenta de servicio de ce...
Lidia	Usuario	
Propietarios del creador de dire...	Grupo de seguridad - G...	Los miembros de este gr...
Protected Users	Grupo de seguridad - G...	Los miembros de este gr...
Publicadores de certificados	Grupo de seguridad - D...	Los miembros de este gr...
Servidores RAS e IAS	Grupo de seguridad - D...	Los servidores de este gr...
Usuarios del dominio	Grupo de seguridad - G...	Todos los usuarios del d...

Ilustración 18- Usuarios y equipos Active Directory

4.3.1.2 Servidor web y servidor de base de datos.

Tabla 10 - Características técnicas de la VM de Ubuntu Server

Software	
Sistema operativo	Ubuntu Server 22.04
Hardware	
Disco duro	25 GB
Memoria RAM	2048 MB
Procesador	2 CPU
Memoria de video	16 MB
Controlador gráfico	VMSVGA
Red	
Adaptador 1	Red interna (Red_saniter_inicial)

Instalación sistema operativo.

Se realiza la instalación del sistema operativo. Se instala en una versión por defecto, con openSSH y con asignación de IP por DHCP.

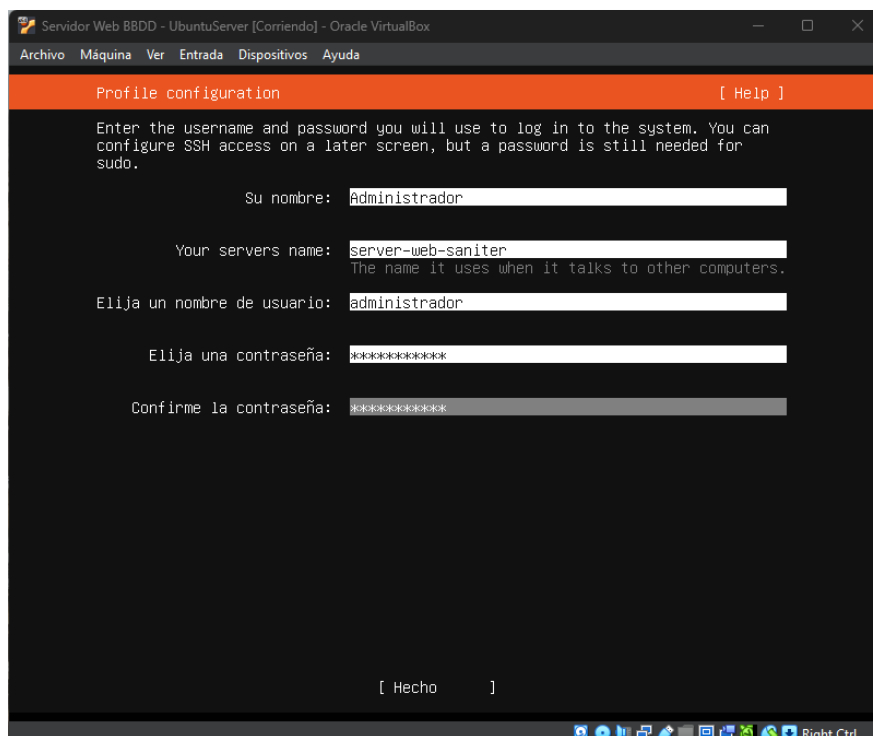


Ilustración 19 – Configuración de perfil de Ubuntu Server

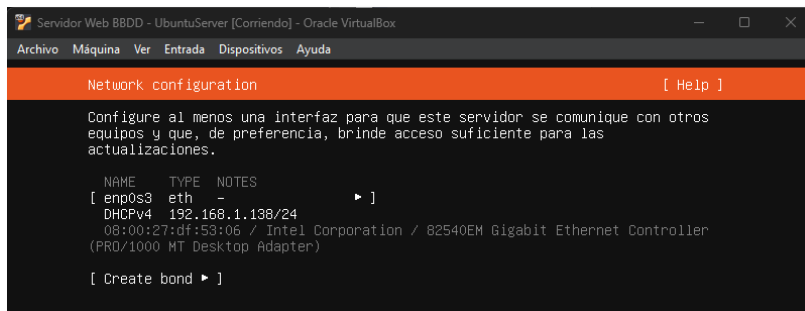


Ilustración 20 - Configuración de red de Ubuntu Server

Configuración del servidor

Una vez instalado el sistema operativo, se sigue una serie de pasos para dejar configurado el servidor.

1° Asignación IP estática

Con permisos de administración, se crea y configura el archivo de configuración de las IPs (*99-manual-config.yaml*) que se encuentra en la ruta */etc/netplan*. Este servidor se encuentra en la misma red que el directorio activo (*Red_saniter_inicial* (172.16.0.0/24)) y por ello se le asigna la IP 172.16.0.140.

```
191 cd /etc/netplan
192 sudo nano 99-manual-config.yaml
193 sudo netplan apply
```

Ilustración 21- Comandos configuración de IP

```
GNU nano 6.2 99-manual-config.yaml
network:
  version: 2
  renderer: networkd
  ethernet:
    enp0s3:
      dhcp4: no
      addresses:
        - 172.16.0.140/24
      routes:
        - to: default
          via: 172.16.0.1
      nameservers:
        addresses: [8.8.8.8, 8.8.4.4]
```

Ilustración 22 - Contenido archivo 99-manual-config.yaml

Se comprueba el correcto direccionamiento IPv4 estático en la interfaz enp0s3.

```
administrador@server-web-saniter:/etc/netplan$ ip a | grep 172.16.0.140
    inet 172.16.0.140/24 brd 172.16.0.255 scope global enp0s3
```

Ilustración 23- Comprobación en consola de la IP

Instalación stack LAMP

[mp.s.1] Configuración segura inicial

Se instala el conjunto de paquetes necesarios para el servidor web y la base de datos con el siguiente comando:

```
sudo apt update && sudo apt install apache2
mariadb-server php libapache2-mod-php php-mysql -
yGreen}
```

Tabla 11 - Paquetes del stack LAMP

Paquete	Función
apache2	Servidor web.
mariadb-server	El motor de base de datos.
php	Lenguaje programación del lado de servidor.
libapache2-mod-php	Módulo que permite a Apache interpretar PHP.
php-mysql	Extensión para que PHP se comunique con la BBDD.

```
administrador@server-web-saniter:/etc/netplan$ apache2 -v
Server version: Apache/2.4.52 (Ubuntu)
Server built: 2025-12-09T15:50:28
administrador@server-web-saniter:/etc/netplan$ mariadb --version
mariadb Ver 15.1 Distrib 10.6.23-MariaDB, for debian-linux-gnu (x86_64) using EditLine wrapper
administrador@server-web-saniter:/etc/netplan$ php -v
PHP 8.1.2-1ubuntu2.23 (cli) (built: Jan 7 2026 08:37:41) (NTS)
Copyright (c) The PHP Group
Zend Engine v4.1.2, Copyright (c) Zend Technologies
    with Zend OPcache v8.1.2-1ubuntu2.23, Copyright (c), by Zend Technologies
administrador@server-web-saniter:/etc/netplan$ _
```

Ilustración 24 - Instalación stack LAMP

```
administrador@server-web-saniter:/etc/netplan$ systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
   Active: active (running) since Sun 2026-03-29 17:27:44 UTC; 27min ago
     Docs: https://httpd.apache.org/docs/2.4/
  Main PID: 782 (apache2)
    Tasks: 6 (limit: 2218)
   Memory: 20.7M
      CPU: 302ms
   CGroup: /system.slice/apache2.service
           └─782 /usr/sbin/apache2 -k start
             └─822 /usr/sbin/apache2 -k start
               └─823 /usr/sbin/apache2 -k start
                 └─824 /usr/sbin/apache2 -k start
                   └─825 /usr/sbin/apache2 -k start
                     └─827 /usr/sbin/apache2 -k start
```

Ilustración 25 - Comprobación de estado de apache

```
administrador@server-web-saniter:/etc/netplan$ systemctl status mariadb
● mariadb.service - MariaDB 10.6.23 database server
   Loaded: loaded (/lib/systemd/system/mariadb.service; enabled; vendor preset: enabled)
   Active: active (running) since Sun 2026-03-29 17:27:45 UTC; 28min ago
     Docs: man:mariadb(8)
           https://mariadb.com/kb/en/library/systemd/
  Main PID: 778 (mariabdd)
    Status: "Taking your SQL requests now..."
    Tasks: 8 (limit: 14639)
   Memory: 93.0M
      CPU: 996ms
   CGroup: /system.slice/mariadb.service
           └─778 /usr/sbin/mariabdd
```

Ilustración 26 - Comprobación de estado de mariadb

```
administrador@server-web-saniter:~$ apache2ctl -M | grep php
php_module (shared)
```

Ilustración 27 - Comprobación de la instalación de PHP

Creación del contenido de la base de datos

En la base de datos se crean tres tablas (Stock, empleados y clientes) con varios registros de prueba para representar la operativa real de Saniter:

```
CREATE DATABASE saniter_db;
USE saniter_db;
CREATE TABLE stock (
    id INT AUTO_INCREMENT PRIMARY KEY,
    producto VARCHAR(40),
    cantidad INT,
    proveedor VARCHAR(40)
);
CREATE TABLE empleados (
    id INT AUTO_INCREMENT PRIMARY KEY,
    nombre VARCHAR(30),
    puesto VARCHAR(30),
    email VARCHAR(50)
);
CREATE TABLE clientes (
    id INT AUTO_INCREMENT PRIMARY KEY,
    nombre VARCHAR(30),
    NIF VARCHAR(30),
    email VARCHAR(50)
);
```



```
INSERT INTO stock (producto, cantidad, proveedor)  
VALUES
```

```
('Mascarillas FFP2', 500, 'MedicalCorp'),  
( 'Guantes de Nitrilo (Caja 100u)', 200,  
  'ProtecSa'),  
( 'Mochila de pulverizacion 16L', 15, 'AgroTools'),  
( 'Rodenticida Muridox 20', 100, 'Masso Control'),  
( 'Insecticida Massocide Delta', 50, 'Masso  
Control'),  
( 'Insecticida Massocide Alpha Plus', 40, 'Masso  
Control');
```

```
INSERT INTO empleados (nombre, puesto, email)  
VALUES ('Alberto', 'Gerente',  
  'alberto@saniter.local'), ('Jose Ramon',  
  'Administracion', 'joseramon@saniter.local'),  
( 'Lidia', 'Administracion', 'lidia@saniter.local'),  
( 'Beatriz', 'Sistemas', 'beatriz@saniter.local'),  
( 'Carlos', 'Tecnico Aplicador',  
  'carlos@saniter.local'), ('Cristian', 'Tecnico  
Aplicador', 'cristian@saniter.local'),  
( 'Alejandra', 'Tecnico Aplicador',  
  'alejandra@saniter.local');
```

```
INSERT INTO clientes (nombre, NIF, email) VALUES
('Juan Pérez García', '01234567X',
'juan.perez@gmail.com'),
('Restaurante La Casina de Lola', 'B28756322',
'gestiones@lacasinadelola.com'),
('Centro de Salud Rigoberta Menchú', 'Q667898737',
'mantenimiento@salud.madrid.es'),
('Ayuntamiento de Bureba', 'P89736555',
'servicios@ayto-bureba.com'),
('Colegio Publico María Zambrano', 'S53677897',
'info@cpmariamazambrano.edu');
```

Para simular la operativa de Saniter, se genera un usuario que tiene acceso desde cualquier IP a la base de datos a través de phpMyAdmin, y tiene todos los permisos sobre la base de datos. Este es el escenario inseguro inicial que el proyecto busca corregir:

```
CREATE USER 'admin_stock'@'%' IDENTIFIED BY
'Saniter2026!';

GRANT ALL PRIVILEGES ON saniter_db.* TO
'admin_stock'@'%;

FLUSH PRIVILEGES;
```

Para comprobar la conexión, se emplea la máquina del directorio Activo, ya que es otro equipo en la misma red y posee navegación web. En la operativa de Saniter, esta conexión se realizaría a través de un equipo de usuario localizado en el propio almacén. En la barra de búsqueda del navegador se introduce: <http://172.16.0.140/phpmyadmin> (Dirección IP del servidor Ubuntu). Se introducen las credenciales del usuario creado y se puede observar que se puede acceder sin problema y observar la base de datos y las tablas creadas.



Ilustración 28 - Login de phpMyAdmin

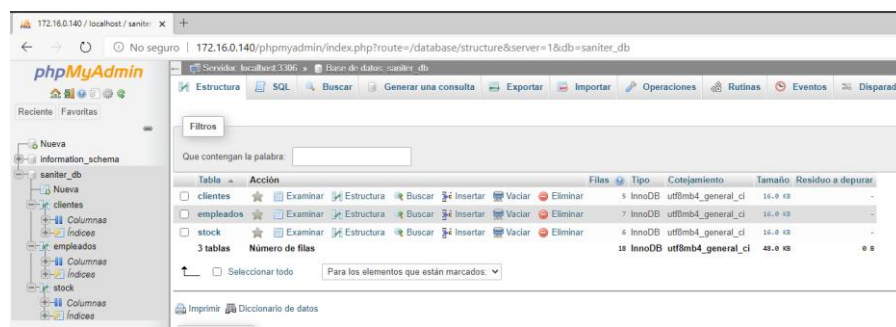


Ilustración 29 – Tablas de la base de datos

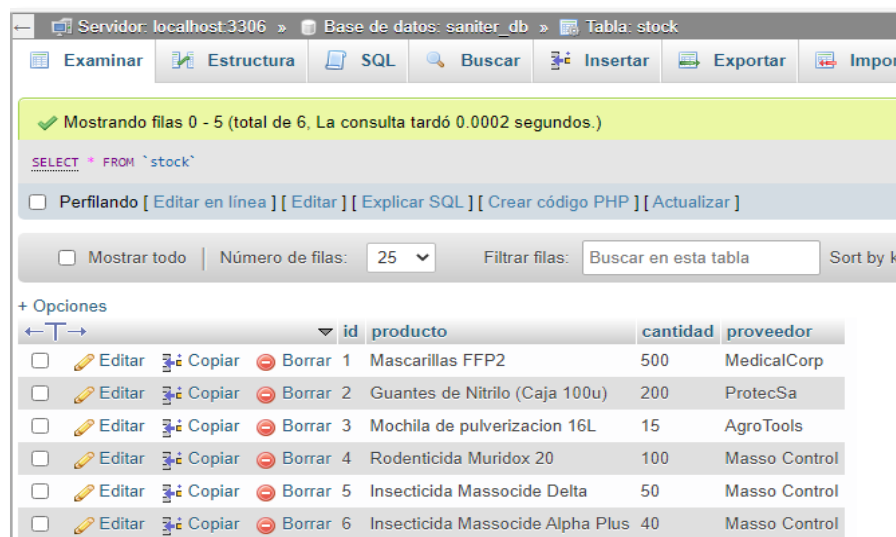


Ilustración 30 - Tabla stock

Mostrando filas 0 - 6 (total de 7, La consulta tardó 0.0002 segundos.)

```
SELECT * FROM `empleados`
```

Perfilando [Editar en línea] [Editar] [Explicar SQL] [Crear código PHP] [Actualizar]

Mostrar todo | Número de filas: 25 | Filtrar filas: Buscar en esta tabla | Sort by key: Ninguna

	id	nombre	puesto	email
☐ Editar ☐ Copiar ☐ Borrar	1	Alberto	Gerente	alberto@saniter.local
☐ Editar ☐ Copiar ☐ Borrar	2	Jose Ramon	Administracion	joseramon@saniter.local
☐ Editar ☐ Copiar ☐ Borrar	3	Lidia	Administracion	lidia@saniter.local
☐ Editar ☐ Copiar ☐ Borrar	4	Beatriz	Sistemas	beatriz@saniter.local
☐ Editar ☐ Copiar ☐ Borrar	5	Carlos	Tecnico Aplicador	carlos@saniter.local
☐ Editar ☐ Copiar ☐ Borrar	6	Cristian	Tecnico Aplicador	cristian@saniter.local
☐ Editar ☐ Copiar ☐ Borrar	7	Alejandra	Tecnico Aplicador	alejandra@saniter.local

Ilustración 31 - Tabla empleados

Mostrando filas 0 - 4 (total de 5, La consulta tardó 0.0001 segundos.)

```
SELECT * FROM `clientes`
```

Perfilando [Editar en línea] [Editar] [Explicar SQL] [Crear código PHP] [Actualizar]

Mostrar todo | Número de filas: 25 | Filtrar filas: Buscar en esta tabla | Sort by key: Ninguna

	id	nombre	NIF	email
☐ Editar ☐ Copiar ☐ Borrar	1	Juan Pérez García	01234567X	juan.perez@gmail.com
☐ Editar ☐ Copiar ☐ Borrar	2	Restaurante La Casina de Lola	B28756322	gestiones@lacasinelola.com
☐ Editar ☐ Copiar ☐ Borrar	3	Centro de Salud Rigoberta Menchú	Q667898737	mantenimiento@salud.madrid.es
☐ Editar ☐ Copiar ☐ Borrar	4	Ayuntamiento de Bureba	P89736555	servicios@ayto-bureba.com
☐ Editar ☐ Copiar ☐ Borrar	5	Colegio Publico María Zambrano	S53677897	info@cpmariazambrano.edu

Ilustración 32 - Tabla clientes

Creación de contenido de la página web

[mp.s.1] Configuración segura inicial

Para completar el despliegue del servidor web, se crea una página web corporativa de Saniter y se aloja en Apache. El desarrollo del código HTML empleado se ha realizado con ayuda de un asistente de IA debido a la falta de tiempo para la elaboración manual de la misma.

El archivo index.html generado se copia en el directorio raíz de Apache (/var/www/html/). Se realizan pruebas para comprobar si

es accesible desde la red interna, introduciendo en el navegador web la dirección: <http://172.16.0.140>.

La web incluye información corporativa de Saniter: servicios ofrecidos, datos de contacto y un formulario de solicitud de presupuesto. Su función dentro del proyecto es doble: por un lado, sirve de superficie de prueba para las auditorías de seguridad, y por otro permite verificar que las reglas de firewall de OPNsense permiten o bloquean el acceso al puerto 80 según lo configurado.

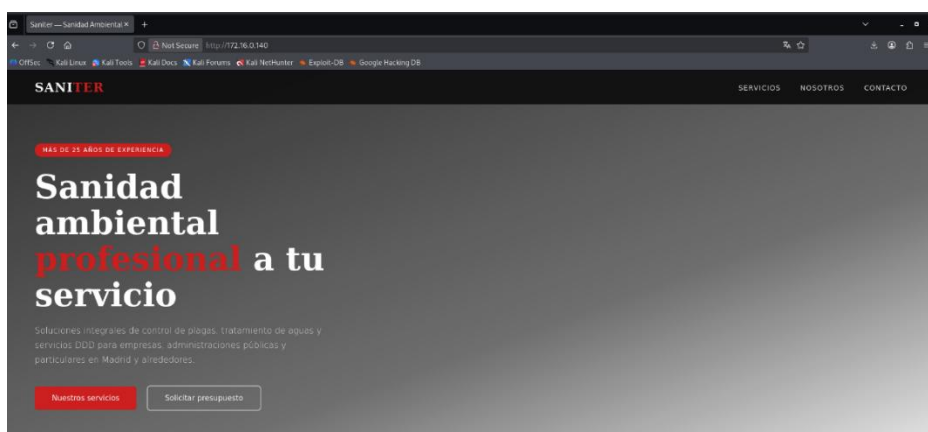


Ilustración 33 - Página web Saniter I

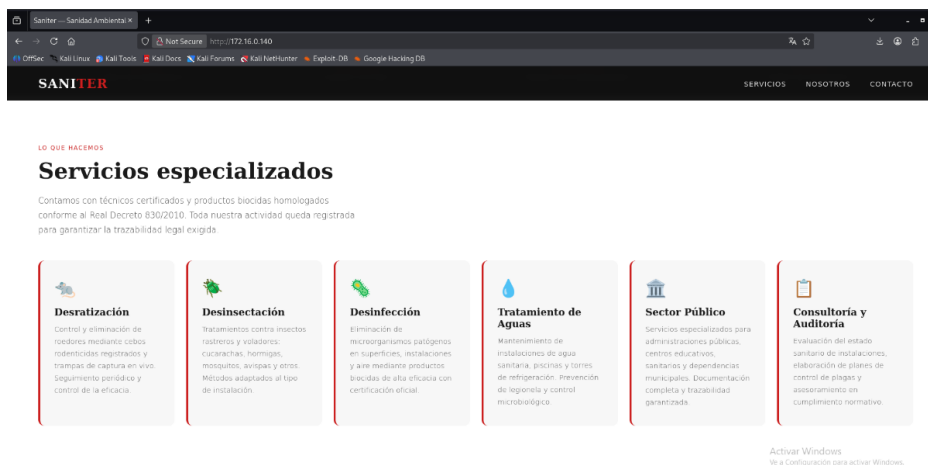


Ilustración 34 - Página web Saniter II

4.3.1.3 Equipo Auditor

Tabla 12 - Características de la VM de Kali Linux - equipo auditor

Software	
Sistema operativo	Kali Linux
Hardware	
Disco duro	80 GB
Memoria RAM	4096 MB
Procesador	2 CPU
Memoria de video	128 MB
Controlador gráfico	VMSVGA
Red	
Adaptador 1	Red interna (Red_saniter_inicial)

Configuración del equipo

Una vez instalado Kali Linux, se fortalece la máquina realizando una actualización de la contraseña, actualización del sistema y descarga y configuración del firewall.

```
(kali@kali)-[~]
$ history
1  xfce4-power-manager --customize
2  passwd
3  sudo apt update && sudo apt full-upgrade -y
4  sudo apt install ufw -y
5  sudo ufw default deny incoming
6  sudo ufw default allow outgoing
7  sudo ufw enable
8  sudo ufw status
9  sudo ufw status verbose
```

Ilustración 35 - Fortalecimiento de Kali Linux

```
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip
```

Ilustración 36 - Comprobación de estado firewall kali linux

Se asigna una IP estática al equipo (172.16.0.200/24), dentro de la red interna de Saniter, ya que la auditoría que se realizará será de caja blanca (white box), ya que se conoce previamente la infraestructura a auditar.

```
sudo ip addr add 172.16.0.200/24 dev eth0
sudo ip link set eth0 up
ip a
```

Ilustración 37 - Asignación IP estática a Kali Linux

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
  ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
  roup default qlen 1000
    link/ether 08:00:27:61:5e:9e brd ff:ff:ff:ff:ff:ff
    inet 172.16.0.200/24 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::8934:2398:417c:cb5/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Ilustración 38 - Comprobación IP configurada

Una vez está configurada la máquina, se procede a descargar e instalar la herramienta GVM (OpenVAS), encargada de llevar a cabo las auditorías.

```
sudo apt update\nsudo apt install -y gvm\nsudo gvm-setup
sudo gvm-check-setup
```

Ilustración 39 - Instalación GVM OpenVAS

```
It seems like your GVM-25.04.0 installation is OK.
```

Ilustración 40 - Comprobación instalación GVM OpenVAS

Desde el navegador de kali, accedemos a la página de inicio indicando la siguiente dirección en la barra de búsqueda:
<https://127.0.0.1:9392>

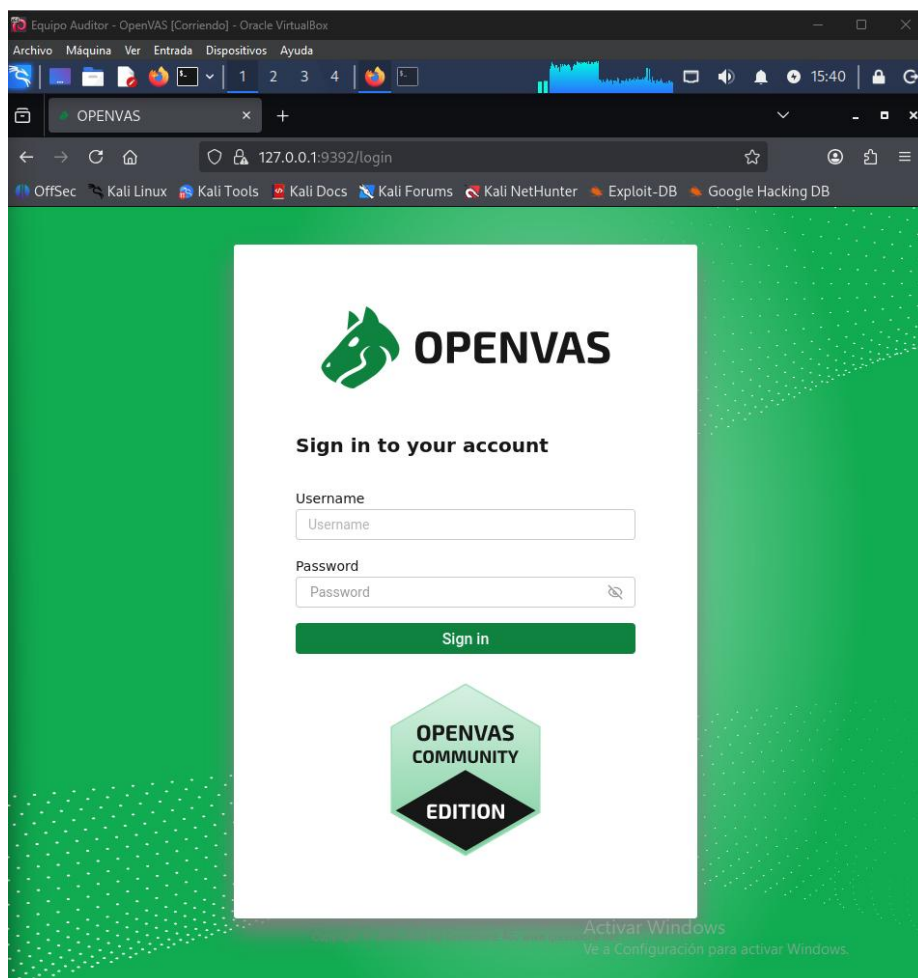


Ilustración 41 - Login de OpenVAS

Se deben actualizar las bases de datos que el equipo auditor emplea a la hora de realizar los escaneos. Cada día se descubren nuevas vulnerabilidades, por lo que es muy importante realizar dicha actualización antes de cada escaneo o auditoría.

Para ello se deben actualizar o sincronizar tres elementos:

- NVT (Network Vulnerability Tests): scripts encargados de realizar las pruebas reales contra los objetivos.
- SCAP (System Content Automation Protocol): base de datos que estandariza los nombres de las vulnerabilidades.
- CERT (Computer Emergency Response Team): alertas y avisos de seguridad emitidos por organismos oficiales.

Se actualizan todos los elementos a través de la consola:


```
(kali@kali)-[~]
$ sudo -u _gvm greenbone-nvt-sync
Trying to acquire lock on /var/lib/openvas/feed-update.lock
Acquired lock on /var/lib/openvas/feed-update.lock
Downloading Notus files from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-da
ta/notus/ to /var/lib/notus
Downloading NASL files from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-da
ta/nasl/ to /var/lib/openvas/plugins
Releasing lock on /var/lib/openvas/feed-update.lock

(kali@kali)-[~]
$ sudo -u _gvm greenbone-scapedata-sync
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
Downloading SCAP data from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-
data/ to /var/lib/gvm/scap-data
rsync: read error: Connection reset by peer (104)
rsync error: error in socket IO (code 10) at io.c(807)
rsync: connection unexpectedly closed (2107 bytes received so far)
rsync error: error in rsync protocol data stream (code 12) at io.c(232)
Releasing lock on /var/lib/gvm/feed-update.lock

(kali@kali)-[~]
$ sudo -u _gvm greenbone-certdata-sync
[sudo] password for kali:
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
Downloading CERT-Bund data from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/cert-
data/ to /var/lib/gvm/cert-data
Releasing lock on /var/lib/gvm/feed-update.lock

(kali@kali)-[~]
$ sudo -u _gvm greenbone-feed-sync --type GVM_DATA
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
Downloading gvm data from rsync://feed.community.greenbone.net/community/data-feed/24.10/ to
/var/lib/gvm/data-objects/gvmd
Releasing lock on /var/lib/gvm/feed-update.lock
```

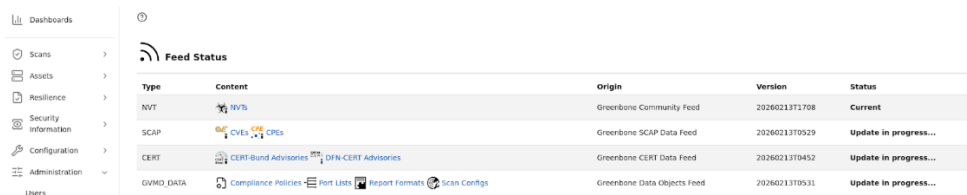
Ilustración 42 - Actualización de Feed OpenVAS

Si se revisa en el panel Feed Status desde el navegador, se puede observar el progreso de actualización. En el apartado Status pueden aparecer tres opciones de mensaje:

- Current: Está actualizado y al día.
- Update in progress: Actualización en curso.
- Old / Out of date: La versión del feed es anterior a la última disponible.

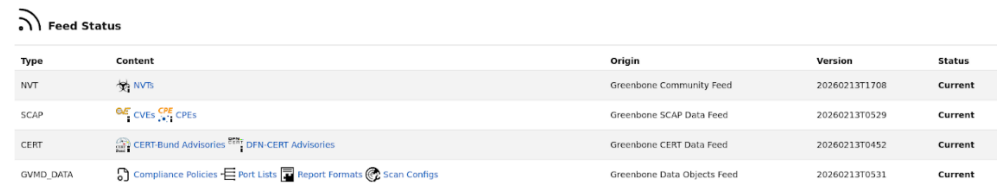
Type	Content	Origin	Version	Status
NVT	NVTs		T	Synchronization issue: Scanner is still starting
SCAP	CVEs, CPEs	Greenbone SCAP Data Feed	20260213T0529	Too old (45 days) Please check the automatic synchronization of your system.
CERT	CERT-Bund Advisories, DFN-CERT Advisories	Greenbone CERT Data Feed	20260213T0452	Too old (45 days) Please check the automatic synchronization of your system.
GVM_DATA	Compliance Policies, Port Lists, Report Formats, Scan Configs	Greenbone Data Objects Feed	20260213T0531	Too old (45 days) Please check the automatic synchronization of your system.

Ilustración 43 - Feed Status OpenVAS sin actualizar



Type	Content	Origin	Version	Status
NVT	NVTs	Greenbone Community Feed	20260213T1708	Current
SCAP	CVEs, CPEs	Greenbone SCAP Data Feed	20260213T0529	Update in progress...
CERT	CERT-Bund Advisories, DFN-CERT Advisories	Greenbone CERT Data Feed	20260213T0452	Update in progress...
GVM/DATA	Compliance Policies, Port Lists, Report Formats, Scan Configs	Greenbone Data Objects Feed	20260213T0531	Update in progress...

Ilustración 44 - Feed Status OpenVAS actualizando



Type	Content	Origin	Version	Status
NVT	NVTs	Greenbone Community Feed	20260213T1708	Current
SCAP	CVEs, CPEs	Greenbone SCAP Data Feed	20260213T0529	Current
CERT	CERT-Bund Advisories, DFN-CERT Advisories	Greenbone CERT Data Feed	20260213T0452	Current
GVM/DATA	Compliance Policies, Port Lists, Report Formats, Scan Configs	Greenbone Data Objects Feed	20260213T0531	Current

Ilustración 45 - Feed Status OpenVAS actualizado

4.3.1.4 Comprobación de conectividad

[op.net.1] Segregación de redes

Antes de continuar con la primera auditoría, se comprueba que todas las máquinas sean visibles entre sí. Para ello se realizan pings desde cada máquina a las demás:

1 Windows Server (172.16.0.100): ping a Kali Linux (172.16.0.200) y a Ubuntu Server (172.16.0.140)

```
PS C:\Users\Administrador> ping 172.16.0.140

Haciendo ping a 172.16.0.140 con 32 bytes de datos:
Respuesta desde 172.16.0.140: bytes=32 tiempo<1m TTL=64
Respuesta desde 172.16.0.140: bytes=32 tiempo=2ms TTL=64
Respuesta desde 172.16.0.140: bytes=32 tiempo=2ms TTL=64
Respuesta desde 172.16.0.140: bytes=32 tiempo=1ms TTL=64

Estadísticas de ping para 172.16.0.140:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 2ms, Media = 1ms

PS C:\Users\Administrador> ping 172.16.0.200

Haciendo ping a 172.16.0.200 con 32 bytes de datos:
Respuesta desde 172.16.0.200: bytes=32 tiempo=2ms TTL=64
Respuesta desde 172.16.0.200: bytes=32 tiempo=1ms TTL=64
Respuesta desde 172.16.0.200: bytes=32 tiempo<1m TTL=64
Respuesta desde 172.16.0.200: bytes=32 tiempo=1ms TTL=64

Estadísticas de ping para 172.16.0.200:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 2ms, Media = 1ms
```

Ilustración 46 - Ping Windows Server a Kali Linux y a Ubuntu Server

2 Ubuntu Server (172.16.0.140): ping a Windows Server (172.16.0.100) y Kali Linux (172.16.0.200)

```
administrador@server-web-saniter:~$ ping 172.16.0.100
PING 172.16.0.100 (172.16.0.100) 56(84) bytes of data.
64 bytes from 172.16.0.100: icmp_seq=1 ttl=128 time=0.901 ms
64 bytes from 172.16.0.100: icmp_seq=2 ttl=128 time=3.59 ms
64 bytes from 172.16.0.100: icmp_seq=3 ttl=128 time=1.85 ms
64 bytes from 172.16.0.100: icmp_seq=4 ttl=128 time=0.709 ms
64 bytes from 172.16.0.100: icmp_seq=5 ttl=128 time=0.622 ms
^C
--- 172.16.0.100 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4010ms
rtt min/avg/max/mdev = 0.622/1.533/3.587/1.115 ms
administrador@server-web-saniter:~$ ping 172.16.0.200
PING 172.16.0.200 (172.16.0.200) 56(84) bytes of data.
64 bytes from 172.16.0.200: icmp_seq=1 ttl=64 time=1.01 ms
64 bytes from 172.16.0.200: icmp_seq=2 ttl=64 time=0.856 ms
64 bytes from 172.16.0.200: icmp_seq=3 ttl=64 time=2.47 ms
64 bytes from 172.16.0.200: icmp_seq=4 ttl=64 time=2.21 ms
64 bytes from 172.16.0.200: icmp_seq=5 ttl=64 time=0.740 ms
^C
--- 172.16.0.200 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4007ms
rtt min/avg/max/mdev = 0.740/1.456/2.467/0.728 ms
```

Ilustración 47 - Ping Ubuntu Server a Kali Linux y a Windows Server

3 Kali Linux (172.16.0.200): ping a Windows Server (172.16.0.100) y a Ubuntu Server (172.16.0.140)

```
(kali@kali)-[~]
$ ping 172.16.0.100
PING 172.16.0.100 (172.16.0.100) 56(84) bytes of data.
64 bytes from 172.16.0.100: icmp_seq=1 ttl=128 time=1.82 ms
64 bytes from 172.16.0.100: icmp_seq=2 ttl=128 time=3.19 ms
64 bytes from 172.16.0.100: icmp_seq=3 ttl=128 time=2.88 ms
64 bytes from 172.16.0.100: icmp_seq=4 ttl=128 time=3.10 ms
64 bytes from 172.16.0.100: icmp_seq=5 ttl=128 time=1.00 ms
^C
--- 172.16.0.100 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4005ms
rtt min/avg/max/mdev = 1.001/2.396/3.185/0.852 ms

(kali@kali)-[~]
$ ping 172.16.0.140
PING 172.16.0.140 (172.16.0.140) 56(84) bytes of data.
64 bytes from 172.16.0.140: icmp_seq=1 ttl=64 time=1.82 ms
64 bytes from 172.16.0.140: icmp_seq=2 ttl=64 time=2.98 ms
64 bytes from 172.16.0.140: icmp_seq=3 ttl=64 time=1.80 ms
64 bytes from 172.16.0.140: icmp_seq=4 ttl=64 time=3.46 ms
64 bytes from 172.16.0.140: icmp_seq=5 ttl=64 time=1.61 ms
64 bytes from 172.16.0.140: icmp_seq=6 ttl=64 time=2.29 ms
64 bytes from 172.16.0.140: icmp_seq=7 ttl=64 time=0.715 ms
^C
--- 172.16.0.140 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 6009ms
rtt min/avg/max/mdev = 0.715/2.095/3.460/0.843 ms
```

Ilustración 48 - Ping Kali Linux a Windows Server y a Ubuntu Server

Se comprueba que todos tienen conectividad y se han configurado correctamente.

4.4 Auditoría inicial

4.4.1 Auditoría inicial Directorio Activo

4.4.1.1 Configuración del escaneo

Se realiza el escaneo del SERVER_AD_01 (Servidor Windows) (172.16.0.100) pero durante la primera ejecución, el escaneo no muestra resultados. Se investiga la causa concluyendo que se debe al bloqueo por parte del firewall de Windows.

Para asegurar que OpenVAS pueda analizar correctamente el servidor, se llevan a cabo nuevas configuraciones para poder realizar una auditoría con autenticación:

[op.vig.1] Detección de deficiencias

- I. Windows Server 2022: Creación de un nuevo usuario y nuevas reglas en el firewall para permitir que el escaneo pueda realizarse sin problemas. Se realizan las siguientes acciones:

- Creación de nuevo usuario para poder realizar una auditoría autenticada.

```
$pass = ConvertTo-SecureString
'OpenVAS.Audit2026!' -AsPlainText -Force

New-ADUser -Name 'svc-openvas' -SamAccountName
'svc-openvas' `

                -AccountPassword $pass -Enabled
$true `

                -PasswordNeverExpires $true `

                -Description 'Cuenta de servicio
para auditorias OpenVAS'

Add-ADGroupMember -Identity "Usuarios COM
distribuidos" -Members "svc-openvas"

Add-ADGroupMember -Identity "Lectores del
registro de eventos" -Members "svc-openvas"
```

```
PS C:\Users\Administrador> $pass = ConvertTo-SecureString 'OpenVAS.Audit2026!' -AsPlainText -Force
PS C:\Users\Administrador> New-ADUser -Name 'svc-openvas' -SamAccountName 'svc-openvas' `
    -AccountPassword $pass -Enabled $true `
    -PasswordNeverExpires $true `
    -Description 'Cuenta de servicio para auditorias OpenVAS'
```

Ilustración 49 - Creación de usuario openvas para auditoria

```
PS C:\Users\Administrador> Add-ADGroupMember -Identity "Usuarios COM distribuidos" -Members "svc-openvas"
PS C:\Users\Administrador> Add-ADGroupMember -Identity "Lectores del registro de eventos" -Members "svc-openvas"
```

Ilustración 50 - Asignación de grupo a usuario openvas

```
PS C:\Users\Administrador> Get-ADPrincipalGroupMembership svc-openvas | Select-Object Name
Name
----
Usuarios del dominio
Usuarios COM distribuidos
Lectores del registro de eventos
```

Ilustración 51 - comprobación de grupos del usuario openvas

- Habilitación de las reglas de firewall Windows Management Instrumentation (WMI) (Gestión e Instrumentación de Windows)
- Habilitación del protocolo ICMPv4 (Detección de disponibilidad. Ping)
- Habilitación de Server Message Block (SMB) o Compartir Archivos. De esta manera se puede realizar un inicio de sesión de manera remota y realizar el escaneo.
- Comprobación de la correcta aplicación de las medidas.

```
Get-NetFirewallRule | Where-Object {
    $_.DisplayName -like "*WMI*" } | Enable-
NetFirewallRule
```

```
Get-NetFirewallRule | Where-Object {
    $_.Protocol -eq "ICMPv4" -and $_.Description -
    like "*echo*" } | Enable-NetFirewallRule
```

```
Get-NetFirewallRule | Where-Object {
    $_.DisplayName -like "*Compartir archivos e
    impresoras*" -or $_.DisplayName -like "*File
    and Printer Sharing*" } | Enable-
NetFirewallRule
```

```
Get-NetFirewallProfile | Select Name, Enabled
```

```
PS C:\Users\Administrador> Enable-NetFirewallRule -DisplayGroup "Instrumentación de administración de Windows (WMI)"
PS C:\Users\Administrador> Get-NetFirewallRule | Where-Object { $_.Protocol -eq "ICMPv4" -and $_.Description -like "echo" } | Enable-NetFirewallRule
PS C:\Users\Administrador> Get-NetFirewallRule | Where-Object { $_.DisplayName -like "Compartir archivos e impresoras" -or $_.DisplayName -like "File and Printer Sharing" } | Enable-NetFirewallRule
PS C:\Users\Administrador> Get-NetFirewallProfile | Select Name, Enabled
```

Ilustración 52 - Habilitación de las reglas de firewall (WMI), protocolo ICMP, SMB.

```
PS C:\Users\Administrador> Get-NetFirewallRule -DisplayGroup "WMI" | Select-Object DisplayName, Enabled
DisplayName                                     Enabled
-----
Instrumental de administración de Windows (ASync de entrada)    True
Instrumental de administración de Windows (WMI de entrada)      True
Instrumental de administración de Windows (WMI de salida)       True
Instrumental de administración de Windows (DCOM de entrada)     True
```

Ilustración 53 - Comprobación de habilitación correcta

- Habilitación de los permisos WMI a través de la interfaz gráfica. Desde la ventana de Control de WMI, se accede a las propiedades y a la pestaña de seguridad.

Dentro del desplegable de Root, se selecciona la carpeta CIMV2 y se accede a la seguridad de la misma, agregando el nuevo usuario creado (svc-openvas) y se seleccionan en permisos de este usuario las opciones “habilitar cuenta” y “llamada remota habilitada”.

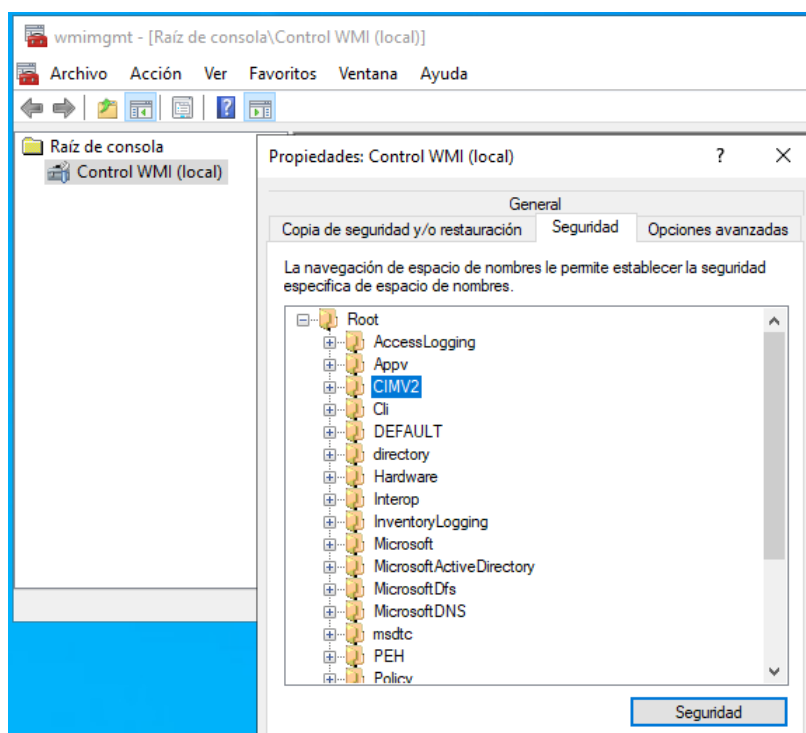


Ilustración 54 - Ruta a permisos WMI

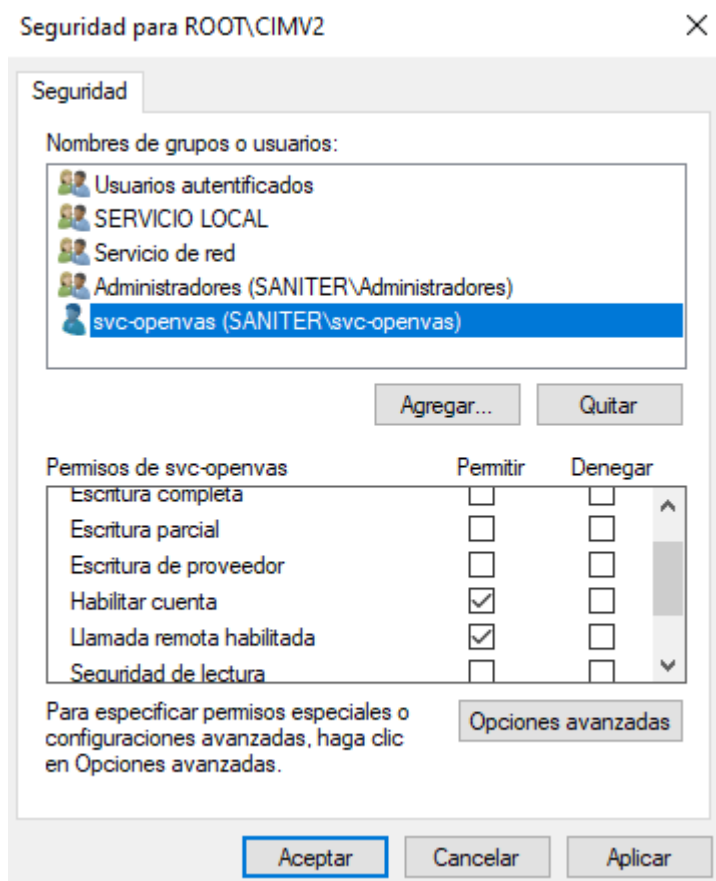


Ilustración 55 - Permisos asignados a usuario openvas

- II. OpenVAS – Kali Linux: Creación de nuevas credenciales y tareas asociadas a la nueva configuración del servidor.
- En la interfaz de GVM se crea una nueva credencial desde el apartado correspondiente (configuración: credenciales). Se asignan los siguientes datos:
 - Name: Credenciales Windows Server – Saniter
 - Type: Username+Password
 - Username: SANITER\svc-openvas
 - Password: La misma usada en powershell para la creación del usuario svc-openvas

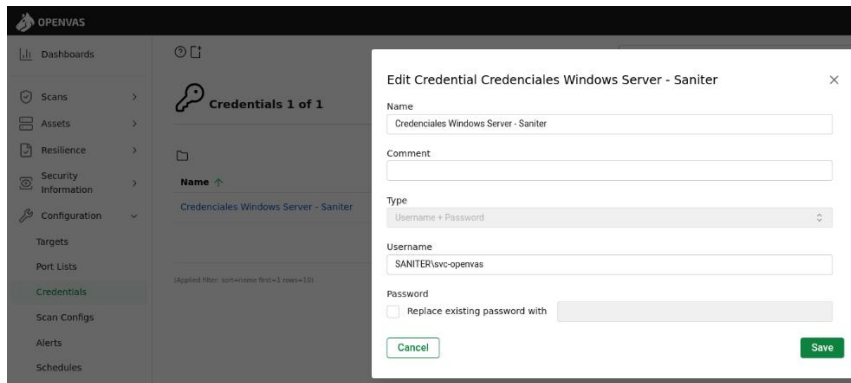


Ilustración 56 - Generación credenciales en OpenVAS para Windows Server

Una vez realizadas todas las nuevas configuraciones para asegurar que se realiza correctamente la auditoría, se crean un nuevo target y una nueva tarea en la plataforma de openVAS:

1) Objetivo-Target

- Name: SERVER-AD-01 (Autenticado)
- Hosts:172.16.0.100
- SMB Credentials: Credenciales Windows Server – Saniter

SERVER-AD-01 (Autenticado)	172.16.0.100	1	All IANA assigned TCP	SMB Credenciales Windows (NTLM): Server - Saniter
----------------------------	--------------	---	-----------------------	---

Ilustración 57 - Target SERVER-AD-01 (Autenticado) en OpenVAS

2) Tarea -Task

- Name: Escaneo inicial_SERVER-AD-01_Autenticado
- Scan Config: Full and fast
- Target: SERVER-AD-01 (Autenticado)

New Task

×

Name

Escaneo inicial_SERVER-AD-01_Autenticado

Comment

Scan Targets

SERVER-AD-01 (Autenticado)

⌵

+

Alerts

⌵

+

Schedule

-

⌵

☐ Once

+

Add results to Assets

☒ Yes ☐ No

Apply Overrides

☒ Yes ☐ No

Min QoD

70

⌵

⌶

Ilustración 58 - Configuración task Auditoria autenticada Windows Server I

Min QoD

70

⌵

⌶

Alterable Task

☐ Yes ☒ No

Auto Delete Reports

☒ Do not automatically delete reports

☐ Automatically delete oldest reports but always keep newest

5

⌵

⌶

reports

Scanner

OpenVAS Default

⌵

Scan Config

Full and fast

⌵

Maximum concurrently executed NVTs per host

4

⌵

⌶

Maximum concurrently scanned hosts

20

⌵

⌶

Cancel

Save

Ilustración 59 - Configuración task Auditoria autenticada Windows Server II

Finalmente, se realiza el escaneo del SERVER_AD_01 (Autenticado) (Servidor windows) (172.16.0.100)

Tabla 13 - Configuración del escaneo autenticado de Windows server

Parámetro	Valor
Nombre del target	SERVER-AD-01 (Autenticado)
IP escaneada	172.16.0.100
IP del equipo auditor	172.16.0.200 (Kali Linux)
Tipo de escaneo	Autenticado (credenciales SMB - usuario svc-openvas)
Perfil de escaneo	Full and Fast
Total resultados sin filtro	29
Resultados confirmados (QoD $\geq$ 70%)	2
Errores durante el escaneo*	23 (NVT timeouts, no afectan a los resultados)

**Nota: Los 23 errores registrados en el informe son todos del tipo NVT timeout: pruebas individuales que superaron el tiempo de espera configurado. Este comportamiento es habitual en escaneos autenticados de Windows Server y no invalida el informe.*

Se aprecia el cambio de la barra de status durante el escaneo:

New → Requested → Queued → Porcentaje de progreso → Done



Ilustración 60 - Estados del escaneo inicial Windows Server

4.4.1.2 Sistema y aplicaciones detectadas

Gracias a la autenticación SMB, OpenVAS ha podido identificar el sistema operativo y los servicios principales del servidor:

Tabla 14 - Sistema detectado en auditoría inicial AD

Elemento detectado	Valor
Sistema Operativo	Windows Server 2022 Standard Evaluation
Rol principal	Active Directory Domain Services
Nombre del host	SERVER-AD-01

4.4.1.3 Puertos abiertos detectados

Se detectan 13 puertos TCP abiertos, todos ellos correspondientes a servicios propios de un Controlador de Dominio Active Directory:

Tabla 15 - Puertos detectados en auditoría inicial AD

Puerto	Servicio	Observación
53/tcp	DNS	Esperado en un Controlador de Dominio.
88/tcp	Kerberos	Esperado. Servicio de autenticación del dominio.
135/tcp	RPC Endpoint Mapper	✗ Permite enumerar servicios internos. A restringir desde WAN.
139/tcp	NetBIOS	✗ Protocolo legacy. Evaluar deshabilitación.
389/tcp	LDAP	Esperado en un Controlador de Dominio.
445/tcp	SMB	✗ Filtrar acceso desde zona WAN en OPNsense.
464/tcp	Kerberos (cambio de clave)	Esperado en un Controlador de Dominio.
593/tcp	RPC over HTTP	✗ Solo necesario si hay clientes remotos.
636/tcp	LDAPS (LDAP sobre TLS)	✓ Comunicación cifrada.

3268/tcp	Global Catalog LDAP	Esperado en un Controlador de Dominio.
3269/tcp	Global Catalog LDAPS	✓ Comunicación cifrada.
5985/tcp	WinRM (PowerShell remoto)	X Restringir acceso desde red externa.
9389/tcp	AD Web Services	Esperado en un Controlador de Dominio.

Debido a la configuración por defecto que tiene el servidor, los resultados sobre los puertos son esperables. Los puertos marcados con **X** en las observaciones son candidatos a restricción mediante reglas de firewall en OPNsense durante la fase de bastionado.

4.4.1.4 Vulnerabilidades confirmadas (QoD ≥ 70%)

Tabla 16 - Vulnerabilidades identificadas en auditoría inicial AD

Severidad	Puerto	Vulnerabilidad	Medida prevista
Media 5.0	135/tcp	DCE/RPC y MSRPC Services Enumeration. El puerto 135 permite a un atacante enumerar todos los servicios RPC activos en el servidor, obteniendo información de la arquitectura interna útil para planificar ataques más sofisticados.	Filtrar acceso al puerto 135 desde zona WAN mediante OPNsense.
Baja 2.6	general/tcp	TCP Timestamps Information Disclosure. El servidor revela información de su tiempo de actividad (uptime) a través de los timestamps TCP.	Ejecutar: netsh int tcp set global timestamps=disabled

En líneas generales, el resultado del servidor Windows es bastante bueno para ser una instalación por defecto. La vulnerabilidad más relevante es la enumeración RPC por el puerto 135, ya que permite a un atacante obtener información de la arquitectura interna del servidor. Ninguna de las vulnerabilidades detectadas es crítica, pero se deben corregir igualmente para cumplir con el ENS. Durante la fase de bastionado se llevarán a cabo las medidas para solucionar las vulnerabilidades.

Status ↑↓	Task ↑↓	Severity ↑↓	Critical ↑↓	High ↑↓	Medium ↑↓	Low ↑	Log ↑↓	False Pos. ↑↓	Actions
Done	Escaneo inicial_SERVER-AD-01_Autenticado	5.0 (Medium)	0	0	1	1	26	0	⚠️

Ilustración 61 - Resultados auditoría Windows Server en OpenVAS

Vulnerability ↑↓	Severity ↓	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓
DCE/RPC and MSRPC Services Enumeration Reporting	5.0 (Medium)	80 %	172.16.0.100		135/tcp

Summary

Distributed Computing Environment / Remote Procedure Calls (DCE/RPC) or MSRPC based service enumeration reporting.

Ilustración 62 - Detalle vulnerabilidad nivel medio I

Impact

An attacker may use this information to gain more knowledge about the remote host and to conduct further attacks based on it.

Solution

Solution Type: ⚡ Mitigation
Filter incoming traffic to this ports.

Ilustración 63 - Detalle vulnerabilidad nivel medio II

4.4.2 Auditoría inicial Ubuntu Server 22.04

4.4.2.1 Configuración del escaneo

Se realiza el escaneo del servidor Ubuntu Server (172.16.0.140)

Tabla 17 - Configuración del escaneo autenticado a Ubuntu Server

Parámetro	Valor
Nombre del target	UbuntuServer Authenticated
IP escaneada	172.16.0.140
IP del equipo auditor	172.16.0.200 (Kali Linux)
Tipo de escaneo	Autenticado (credenciales SSH)
Perfil de escaneo	Full and Fast
Total resultados sin filtro	261
Resultados confirmados (QoD $\geq$ 70%)	5

Nota: En los resultados del informe aparece la dirección 127.0.0.1 como host en lugar de 172.16.0.140. Esto es el comportamiento esperado en escaneos autenticados por SSH: una vez que OpenVAS accede al servidor mediante las credenciales proporcionadas, ejecuta los checks de verificación internamente desde dentro del propio sistema. Esto no invalida el escaneo ya que el tráfico sí se originó desde Kali (172.16.0.200) hacia Ubuntu (172.16.0.140), (confirmado en informe de resultados).

El proceso pasa por los siguientes estados:

New → Requested → Queued → Porcentaje de progreso → Done



Ilustración 64 - Estados de auditoría Ubuntu Server

Inicialmente se realizó un escaneo sin autenticar que mostró resultados limitados, por lo que se optó por configurar un escaneo autenticado para obtener un análisis más completo.

Se configura el target y la tarea en OpenVAS, agregando las credenciales correspondientes al servidor Ubuntu.

Se crea la nueva credencial Ubuntu SSH, la cual permitirá autenticarse en el servidor y poder realizar la auditoría.

Edit Credential Ubuntu SSH
×

Name

Ubuntu SSH

Comment

Type

Username + Password

Username

administrador

Password

☐ Replace existing password with

Cancel

Save

Ilustración 65 - Credenciales en OpenVAs para Ubuntu Server

Se genera el nuevo target (UbuntuServer Authenticated), incluyendo la credencial creada.

Edit Target UbuntuServer Authenticated

✕

Name

UbuntuServer Authenticated

Comment

Hosts

Manual

172.16.0.140

From file

⬆

Exclude Hosts

Manual

From file

⬆

Allow simultaneous scanning via multiple IPs

Yes

No

Port List

All IANA assigned TCP

Alive Test

Use Scan Config Default

Consider Hosts as Alive

Custom

Credentials for authenticated checks

SSH

Ubuntu SSH

on port

22

Elevate privileges

Select a Credential

Cancel

Save

Ilustración 66 - Configuración de Target UbuntuServer Authenticated

Por último, se genera la nueva tarea: *Auditoría inicial Ubuntu Server autenticada*.

Edit Task Auditoria inicial Ubuntu Server autenticada

Name

Auditoria inicial Ubuntu Server autenticada

Comment

Escaneo del servidor Ubuntu desde red interna (172.16.0.200 → 172.16.0.140)

Scan Targets

UbuntuServer Authenticated

Alerts

Schedule

--

☐ Once

Add results to Assets

☒ Yes
☐ No

Apply Overrides

☒ Yes
☐ No

Min QoD

70

Auto Delete Reports

☒ Do not automatically delete reports

☐ Automatically delete oldest reports but always keep newest

5

reports

Scanner

OpenVAS Default

Scan Config

Full and fast

Maximum concurrently executed NVTs per host

4

Maximum concurrently scanned hosts

20

Cancel

Save

Ilustración 67 - Configuración Task Auditoria inicial Ubuntu Server autenticada

4.4.2.2 Sistema y aplicaciones detectadas

Gracias a la autenticación SSH, OpenVAS ha podido inventariar de forma completa el software instalado en el servidor:

Tabla 18 - Sistemas y aplicaciones detectadas en auditoría autenticada a Ubuntu Server

Aplicación detectada	Versión
Sistema Operativo	Ubuntu 22.04 LTS
Apache HTTP Server	2.4.52
phpMyAdmin	5.1.1
PHP	8.1.2
OpenSSH	8.9p1
OpenSSL	3.0.2 / 1.1.1f
MariaDB	Accesible en puerto 3306
sudo	1.9.9
jQuery	3.6.0
Bash	5.1.16

4.4.2.3 Puertos abiertos detectados

Tabla 19- Puertos detectados en auditoría inicial a Ubuntu Server

Puerto	Servicio	Severidad	Observación
22/tcp	SSH OpenSSH 8.9p1	Baja (2.6)	Esperado. Acceso administrativo.
80/tcp	HTTP Apache 2.4.52 + phpMyAdmin	Media (4.8)	X Sin cifrado TLS.
3306/tcp	MariaDB	Detectado	X Visible desde red. Sin restricción de acceso remoto.

La presencia del puerto 3306 abierto y accesible desde la red interna confirma que la base de datos no tiene ninguna restricción de acceso remoto, lo que significa que cualquier equipo de la red podría intentar conectarse directamente a MariaDB sin pasar por la aplicación web.

4.4.2.4 Vulnerabilidades confirmadas (QoD $\geq 70\%$)

Tabla 20 - Vulnerabilidades detectadas en auditoría autenticada inicial de Ubuntu Server

Severidad	Puerto	Vulnerabilidad	CVE	Medida prevista
Media 5.5	general/ tcp	Mitigaciones del Kernel Linux para Speculative Store Bypass (SSB) no aplicadas. El procesador es vulnerable a ataques de canal lateral que podrían permitir a un proceso leer datos de memoria de otros procesos.	CVE-2018-3639*	Actualización del kernel. Limitación en entorno virtualizado.
Media 4.8	80/tcp	Transmisión de credenciales en texto claro por HTTP. phpMyAdmin es accesible sin cifrado, lo que permite interceptar usuario y contraseña mediante un ataque man-in-the-middle.	-	Habilitar HTTPS / TLS en Apache.
Baja 2.6	general/ tcp	TCP Timestamps Information Disclosure. El servidor revela información de su tiempo de actividad	-	Deshabilitar en /etc/sysctl.conf.

		(uptime) a través de los timestamps TCP.		
Baja 2.6	22/tcp	Algoritmos MAC débiles soportados en SSH. El servidor SSH acepta algoritmos de integridad considerados obsoletos (MD5, 96-bit).	-	Deshabilitar en sshd_config.
Baja 2.1	general/icmp	ICMP Timestamp Reply Information Disclosure. El servidor responde a peticiones ICMP de timestamp, filtrando información de tiempo.	CVE-1999-0524	Bloquear ICMP timestamp con firewall.

**Nota: La vulnerabilidad CVE-2018-3639 (Speculative Store Bypass) es una limitación de hardware del procesador físico del equipo anfitrión, no del software instalado en Ubuntu. En un entorno virtualizado de laboratorio su mitigación completa depende de la actualización del microcódigo del procesador del host y queda fuera del alcance de este proyecto. Se documenta como hallazgo, pero no se incluye en el plan de bastionado.*

De todas las vulnerabilidades detectadas, la más importante en la práctica es la de HTTP sin cifrado. phpMyAdmin está accesible por el puerto 80 sin ningún tipo de protección, lo que significa que cualquier equipo de la red interna que capture el tráfico puede ver el usuario y la contraseña de la base de datos en texto claro.

Status ↑↓	Task ↑↓	Severity ↑↓	Critical ↑↓	High ↑↓	Medium ↑↓	Low ↑↓	Info ↑↓	False Pos. ↑↓
Done	Auditoria inicial Ubuntu Server autenticada	5.5 (Medium)	0	0	2	3	45	0

Ilustración 68 - Resultados auditoría en OpenVAS

Summary The remote host is missing one or more known mitigation(s) on Linux Kernel side for the referenced 'SSB - Speculative Store Bypass' hardware vulnerabilities. Detection Result The Linux Kernel on the remote host is missing the mitigation for the "spec_store_bypass" hardware vulnerabilities as reported by the sysfs interface: <pre>sysfs file checked Linux Kernel status (SSH response) ----- /sys/devices/system/cpu/vulnerabilities/spec_store_bypass Vulnerable</pre> Notes on the "Linux Kernel status (SSH response)" column: - sysfs file missing: The sysfs interface is available but the sysfs file for this specific vulnerability is missing. This means the current Linux Kernel doesn't know this vulnerability yet. Based on this it is assumed that it doesn't provide any mitigation and that the target system is vulnerable. - Strings including "Mitigation:", "Not affected" or "Vulnerable" are reported directly by the Linux Kernel. - All other strings are responses to various SSH commands. Product Detection Result Product <code>cpe:/a:linux:kernel</code> Method <code>Detection of Linux Kernel mitigation status for hardware vulnerabilities (OID: 1.3.6.1.4.1.25623.1.0.108765)</code> Log View details of product detection	Detection Method Checks previous gathered information on the mitigation status reported by the Linux Kernel. Details: Missing Linux Kernel mitigations for 'SSB - Speculative Store Bypass'...;OID: 1.3.6.1.4.1.25623.1.0.108842 Version used: 2026-01-14T06:47:41+02:00 Solution Solution Type:  Vendorfix The following solutions exist: - Update to a more recent Linux Kernel to receive mitigations on Kernel level and info about the mitigation status from it - Enable the mitigation(s) in the Linux Kernel (might be disabled depending on the configuration) Additional possible mitigations (if provided by the vendor) are to: - install a Microcode update - update the BIOS of the Mainboard Note: Please create an override for this result if one of the following applies: - the sysfs file is not available but other mitigations like a Microcode update is already in place - the sysfs file is not available but the CPU of the host is not affected - the reporting of the Linux Kernel is not correct (this is out of the control of this VT) References CVE CVE-2018-3639
--	---

Vulnerability ↑↓	Severity ↑↓	QoD ↑↓	Host IP ↑↓
Cleartext Transmission of Sensitive Information via HTTP	4.8 (Medium)	80 %	172.16.0.140

Summary

The host / application transmits sensitive information (username, passwords) in cleartext via HTTP.

Detection Result

The following input fields were identified (URL:input name):

http://172.16.0.140/phpmyadmin/:pma_password
http://172.16.0.140/phpmyadmin/?0=A:pma_password

Detection Method

Evaluate previous collected information and check if the host / application is not enforcing the transmission of sensitive data via an encrypted SSL/TLS connection.

The script is currently checking the following:

- HTTP Basic Authentication (Basic Auth)
- HTTP Forms (e.g. Login) with input field of type 'password'

Details: [Cleartext Transmission of Sensitive Information via HTTP OID: 1.3.6.1.4.1.25623.1.0.108440](#)

Version used: 2023-09-07T07:05:21+02:00

Affected Software/OS

Hosts / applications which doesn't enforce the transmission of sensitive data via an encrypted SSL/TLS connection.

Ilustración 71 - Detalle de la vulnerabilidad de nivel medio II

Vulnerability ↑↓	Severity ↑	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓
ICMP Timestamp Reply Information Disclosure	2.1 (Low)	80 %	172.16.0.140		general/icmp
TCP Timestamps Information Disclosure	2.6 (Low)	80 %	172.16.0.140		general/tcp
Weak MAC Algorithm(s) Supported (SSH)	2.6 (Low)	80 %	172.16.0.140		22/tcp

Ilustración 72 - Vulnerabilidades de nivel bajo en auditoría Ubuntu Server

4.4.3 Resumen comparativo de las auditorías iniciales

La siguiente tabla resume los resultados de las dos auditorías iniciales realizadas, considerándose la línea base del proyecto. Estos datos se compararán posteriormente con los de la post-auditoría para medir la efectividad del bastionado aplicado:

Tabla 21 - Comparativa de auditorías iniciales

Parámetro	Ubuntu Server 22.04	Windows Server 2022
Tipo de escaneo	Autenticado (SSH)	Autenticado (SMB, svc-openvas)
Duración	19 minutos	2 horas 41 minutos
Puertos abiertos detectados	3 (22, 80, 3306)	13 (propios de DC)
Vulnerabilidades Medias	2	1
Vulnerabilidades Bajas	3	1
Severidad máxima confirmada	5.5 (CVE-2018-3639)	5.0 (RPC Enumeration)
Principal riesgo identificado	phpMyAdmin sin cifrado + puerto 3306 accesible desde red	Puerto 135 RPC accesible sin restricción desde exterior
Riesgo global	Medio-Alto	Bajo-Medio

Los resultados de las dos auditorías confirman que ambos servidores tienen vulnerabilidades de nivel medio que justifican el proceso de bastionado. Ubuntu tiene un perfil de riesgo más alto que Windows, principalmente porque tiene la base de datos expuesta en la red y phpMyAdmin accesible sin cifrado. Son exactamente los problemas que se identificaron en el análisis de riesgos previo, validándolo.

4.5 Hardening

4.5.1 Instalación y configuración de OPNsense

[op.net.1] Segregación de redes

[mp.com.1] Perímetro seguro

OPNsense es la herramienta clave y primordial de la solución de seguridad planteada. Actúa como firewall y sustituye al antiguo router, separando la red interna del exterior, y siendo la responsable de la segmentación de la infraestructura.

Nota a destacar: Las direcciones IP de todos los servidores cambian una vez se implanta OPNsense. Al inicio la red inicial (Red_saniter_inicial) es 172.16.0.0/24 y una vez se implemente esta solución, la nueva red interna (red_saniter_ENS) pasa a ser 10.0.0.0/24, debiendo también cambiar las IPs de los activos.

Tabla 22 - Direcciones IP de los equipos

Máquina	IP (red_saniter_inicial)	IP (red_saniter_ENS)
Windows Server 2022	172.16.0.100	10.0.0.20
Ubuntu Server 22.04	172.16.0.140	10.0.0.30
Kali Linux	172.16.0.200	10.0.0.10
OPNsense (LAN)	-	10.0.0.1

4.5.1.1 Creación de la máquina virtual

[op.net.1] Segregación de redes

[mp.com.1] Perímetro seguro

A diferencia del resto de máquinas del proyecto, la creación de la VM de OPNsense requiere una configuración especial en VirtualBox: necesita dos adaptadores de red activos desde el inicio, porque desde el arranque debe tener visibilidad tanto hacia el exterior (WAN) como hacia la red interna (LAN). Sin esta doble interfaz, el proceso de instalación no puede asignar correctamente los roles de cada interfaz.

Tabla 23 - Características de la VM de OPNsense

Software	
Sistema Operativo	OPNsense 26.1
Hardware	
Disco Duro	20 GB (VDI dinámico)
Memoria RAM	4096 MB
Procesador	2 CPU
Aceleración	VT-x/AMD-V + Paginación anidada
Red	
Adaptador 1 (WAN)	Adaptador puente (conexión a internet del host)
Adaptador 2 (LAN)	Red interna (red_saniter_ENS) Modo promiscuo: Permitir todo

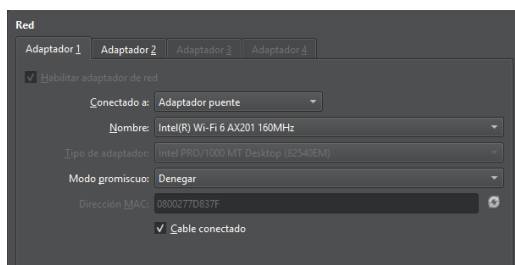


Ilustración 73 - Adaptador 1 VM OPNsense

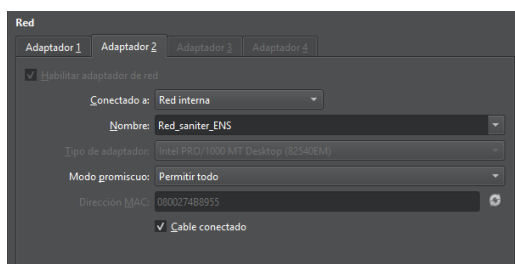


Ilustración 74 - Adaptador 2 VM OPNsense

4.5.1.2 Instalación del sistema

En el caso de OPNsense se muestra el proceso de instalación al ser diferente a los procesos habituales de instalación de los sistemas operativos habituales.

Tras arrancar la máquina virtual desde la imagen ISO, se introducen las credenciales de inicio de sesión indicadas para la instalación (usuario: installer, contraseña: opnsense). Una vez realizada, se solicita el establecimiento de la contraseña del usuario *root* y se reinicia.

Es importante retirar la imagen ISO antes de volver a iniciar la máquina.

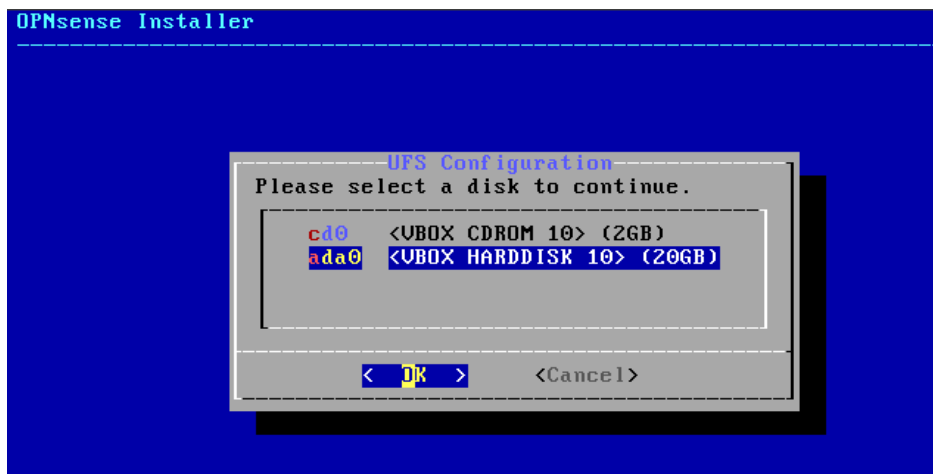


Ilustración 75 - OPNsense installer UFS Configuration I



Ilustración 76 - OPNsense installer UFS Configuration II

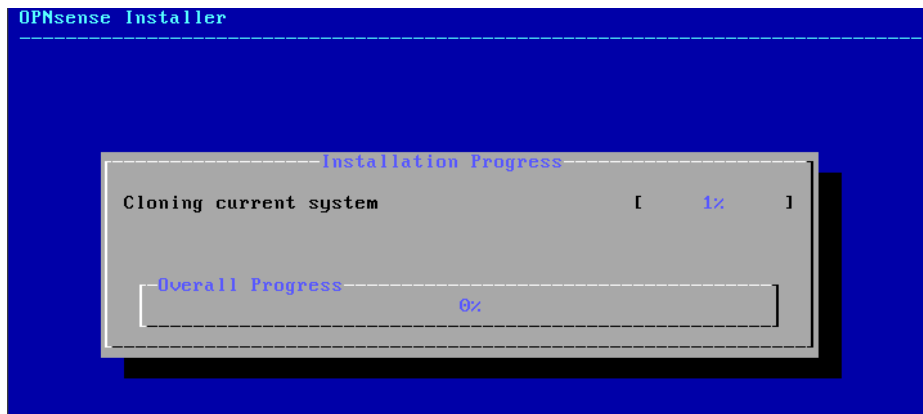


Ilustración 77 - OPNsense installer Instalation progress I

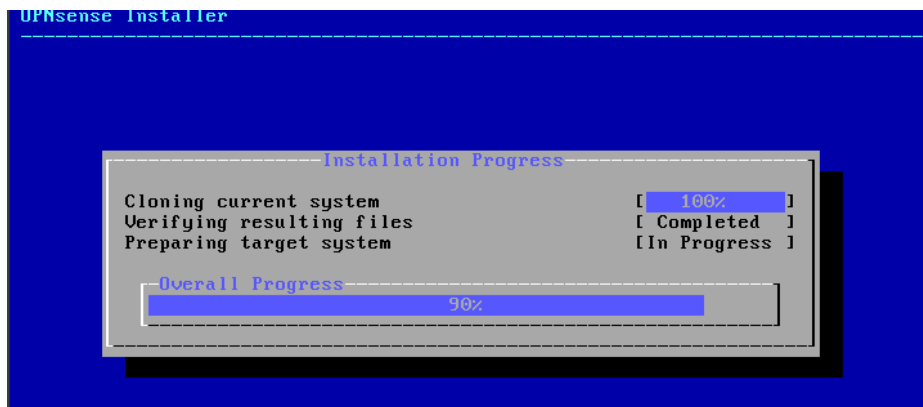


Ilustración 78 - OPNsense installer Instalation progress II

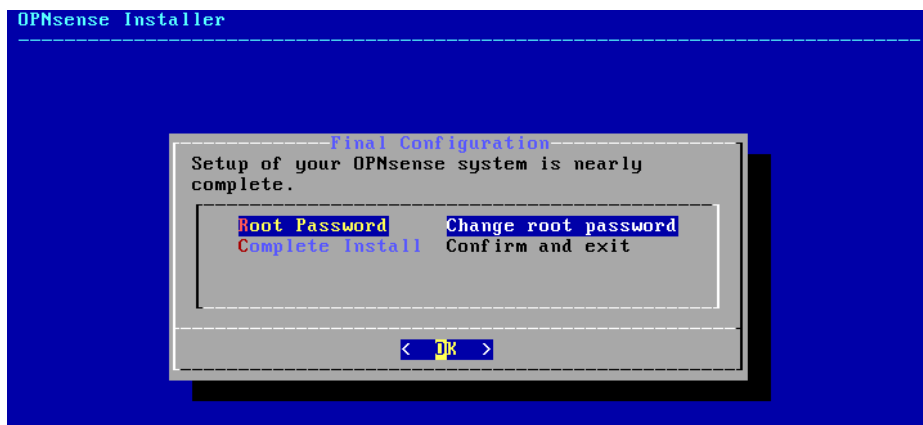


Ilustración 79 - OPNsense installer Final configuration

```

OPNsense - SANITER [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Website:      https://opnsense.org/
Handbook:     https://docs.opnsense.org/
Forums:       https://forum.opnsense.org/
Code:         https://github.com/opnsense
Reddit:       https://reddit.com/r/opnsense

*** OPNsense.internal: OPNsense 26.1 (amd64) ***

LAN (em0)      -> v4: 192.168.1.1/24
WAN (em1)      ->

HTTPS: SHA256 1F 66 B0 48 36 6E CB 1E 90 13 B5 72 AE 04 D0 90
               F5 87 CE 9B 8F 65 CC 6E 95 AF 4C F8 E0 CB 8E 8A

0) Logout
1) Assign interfaces
2) Set interface IP address
3) Reset the root password
4) Reset to factory defaults
5) Power off system
6) Reboot system
7) Ping host
8) Shell
9) pfTop
10) Firewall log
11) Reload all services
12) Update from console
13) Restore a backup

Enter an option:

```

Ilustración 80 - Consola OPNsense: inicio

4.5.1.3 Asignación de interfaces y configuración de red LAN

Tras el reinicio, OPNsense muestra el menú de consola. Se selecciona la opción 1 (Assign interfaces) y se responde de la siguiente manera:

- LAGGs: No.
- VLANs: No.
- WAN interface: em0 (adaptador puente, conectado a internet).
- LAN interface: em1 (red interna empresa_ENS, conectada a los servidores).

```

*** OPNsense.internal: OPNsense 26.1 (amd64) ***

LAN (em1)      -> v4: 192.168.1.1/24
WAN (em0)      -> v4/DHCP4: 192.168.1.201/24
                  v6/DHCP6: 2a0c:5a80:f406:9300:a00:27ff:fe7d:837f/64

HTTPS: SHA256 1F 66 B0 48 36 6E CB 1E 90 13 B5 72 AE 04 D0 90
               F5 87 CE 9B 8F 65 CC 6E 95 AF 4C F8 E0 CB 8E 8A

0) Logout
1) Assign interfaces
2) Set interface IP address
3) Reset the root password
4) Reset to factory defaults
5) Power off system
6) Reboot system
7) Ping host
8) Shell
9) pfTop
10) Firewall log
11) Reload all services
12) Update from console
13) Restore a backup

```

Ilustración 81 - OPNsense LAN y WAN inicial

Para configurar la red LAN, se selecciona la opción 2 (Set interface IP address) para configurar la dirección IP de la interfaz LAN, que será la puerta de enlace de todos los servidores de Saniter:

- Interfaz: LAN.
- IP: 10.0.0.1
- Máscara: 24 (equivalente a 255.255.255.0).
- Gateway: (vacío, la red LAN no necesita gateway propio).
- IPv6: No.
- Servidor DHCP: Sí, con rango de 10.0.0.10 a 10.0.0.100.
- Acceso web: HTTPS. Creando certificado autofirmado

La WAN recibe su IP automáticamente por DHCP del router del host (adaptador puente), proporcionando salida a internet a la red interna a través de OPNsense.

```

Starting web GUI...done.
You can now access the web GUI by opening
the following URL in your web browser:

https://10.0.0.1

** OPNsense.internal: OPNsense 26.1 (amd64) ***

LAN (em1)      -> v4: 10.0.0.1/24
WAN (em0)      -> v4/DHCP4: 192.168.1.201/24
                v6/DHCP6: 2a0c:5a80:f406:9300:a00:27ff:fe7d:837f/64

HTTPS: SHA256 BD BF 32 88 BF 48 86 5C 8A 43 20 D0 F3 9B 90 D1
          A1 0C EE 77 6C 93 D2 78 65 D5 DF 26 A4 B5 F1 D7

0) Logout                      7) Ping host
1) Assign interfaces           8) Shell
2) Set interface IP address    9) pfTop
3) Reset the root password     10) Firewall log
4) Reset to factory defaults   11) Reload all services
5) Power off system            12) Update from console
6) Reboot system               13) Restore a backup
  
```

Ilustración 82 - OPNsense LAN y WAN configuradas

4.5.1.4 Verificación de conectividad con internet

Desde la consola de OPNsense se utiliza la opción 7 (Ping host) para comprobar que el firewall tiene salida a internet: Ping destino: 8.8.8.8.

Se obtiene respuesta satisfactoria, confirmando que la interfaz WAN tiene conectividad y que OPNsense puede actuar como puerta de enlace hacia el exterior.

```

0) Logout
1) Assign interfaces
2) Set interface IP address
3) Reset the root password
4) Reset to factory defaults
5) Power off system
6) Reboot system
7) Ping host
8) Shell
9) pfTop
10) Firewall log
11) Reload all services
12) Update from console
13) Restore a backup

Enter an option: 7

Enter a host name or IP address: 8.8.8.8

PING 8.8.8.8 (8.8.8.8): 56 data bytes
4 bytes from 8.8.8.8: icmp_seq=0 ttl=117 time=4.745 ms
4 bytes from 8.8.8.8: icmp_seq=1 ttl=117 time=5.814 ms
4 bytes from 8.8.8.8: icmp_seq=2 ttl=117 time=3.896 ms

--- 8.8.8.8 ping statistics ---
3 packets transmitted, 3 packets received, 0.0% packet loss
round-trip min/avg/max/stddev = 3.896/4.818/5.814/0.785 ms

```

Ilustración 83 - Comprobación de conectividad

4.5.1.5 Acceso a la interfaz web de administración

Una vez configurada la red, se accede a la interfaz web de OPNsense desde el equipo auditor, que está conectado a la misma red interna empresa_ENS y por lo tanto podrá acceder sin problemas. Desde el navegador de Kali se introduce la siguiente dirección: <https://10.0.0.1>

Se acepta el aviso del certificado autofirmado y se inicia sesión con el usuario root. Se completa el asistente de configuración inicial (Setup Wizard) con los siguientes parámetros:

- Hostname: opnsense | Domain: saniter.local.
- DNS primario: 10.0.0.20 (Windows Server, que actúa como DNS del dominio saniter.local).
- DNS secundario: 8.8.8.8 (Google DNS, como respaldo).
- Timezone: Europe/Madrid.
- WAN: DHCP (IP asignada automáticamente por el router del host).
- LAN: 10.0.0.1/24 (ya configurada desde consola).

Interfaces: Visión General

Estado	Interfaz	Device	VLAN	Tipo de Enlace	IPv4
	WAN (wan)	em0		dhcp	192.168.1.201/24
	LAN (lan)	em1		static	10.0.0.1/24
	Loopback (lo0)	lo0		static	127.0.0.1/8

Ilustración 84 - Plataforma OPNsense: interfaces

4.5.1.6 Configuración de reglas de firewall

Se accede al apartado de reglas de firewall dentro de la interfaz para definir las reglas de filtrado de tráfico que implementan los controles del ENS. El objetivo es que desde la zona WAN solo sea accesible el servidor web (puerto 80/443), y que el resto de servicios críticos (base de datos, Directorio Activo) queden inaccesibles desde el exterior.

Tabla 24 - Reglas de firewall aplicadas

Acción	Interfaz	Protocolo	Origen	Destino	Descripción
Allow	LAN	TCP/UDP	LAN net	10.0.0.20 : 53, 88, 389, 445, 636	Servicios AD (DNS, Kerberos, LDAP, SMB)
Allow	LAN	TCP	LAN net	10.0.0.30 : 80, 443	Acceso web al servidor Ubuntu
Allow	LAN	TCP	10.0.0.10	LAN net : any	Kali auditor - acceso completo
Block	LAN	TCP	LAN net	10.0.0.30 : 3306	Bloquear acceso directo a MariaDB
Block	WAN	TCP	any	10.0.0.20 : 135	Bloquear RPC desde exterior - ENS

Allow WAN TCP any 10.0.0.30 : 80, 443 Acceso web público al servidor Saniter

Nota: en OPNsense las reglas se han creado de forma individual por puerto al no permitir la interfaz especificar múltiples puertos en una sola regla. El efecto final es equivalente a la tabla de planificación mostrada."

Cortafuegos: Reglas: LAN

	Protocolo	Origen	Puerto	Destino	Puerto	Puerta de Enlace	Programar	Descripción
								Reglas generadas automáticamente
								Floating rules
								Rules from Automation
☐	IPv6 *	LAN red	*	*	*	*	*	Default allow LAN IPv6 to any rule
☐	IPv4 TCP/UDP	*	*	10.0.0.20	53 (DNS)	*	*	Servicio AD - DNS
☐	IPv4 TCP/UDP	*	*	10.0.0.20	88	*	*	Servicios AD - Kerberos
☐	IPv4 TCP/UDP	*	*	10.0.0.20	389 (LDAP)	*	*	Servicios AD - LDAP
☐	IPv4 TCP/UDP	*	*	10.0.0.20	445 (MS DS)	*	*	Servicios AD - SMB
☐	IPv4 TCP/UDP	*	*	10.0.0.20/32	636	*	*	Servicios AD -- LDAPS
☐	IPv4 TCP	*	*	10.0.0.30	80 (HTTP)	*	*	Acceso web Ubuntu - HTTP
☐	IPv4 TCP	*	*	10.0.0.30	443 (HTTPS)	*	*	Acceso web Ubuntu - HTTPS
☐	IPv4 TCP/UDP	10.0.0.10	*	*	*	*	*	Kali auditor - acceso completo
☐	IPv4 TCP	*	*	10.0.0.30	3306	*	*	Bloquear acceso directo a MariaDB - ENS

Ilustración 85 - Reglas LAN firewall OPNsense

Cortafuegos: Reglas: WAN

La configuración de la regla del cortafuegos ha cambiado. Debe aplicar los cambios para que tengan efecto.

	Protocolo	Origen	Puerto	Destino	Puerto	Puerta de Enlace	Programar	Descripción
								Reglas generadas automáticamente
								Floating rules
☐	IPv4 TCP	*	*	10.0.0.20	135	*	*	Bloquear RPC desde exterior - ENS
☐	IPv4 TCP	*	*	10.0.0.30	80 (HTTP)	*	*	Acceso web público Saniter - HTTP
☐	IPv4 TCP	*	*	10.0.0.30	443 (HTTPS)	*	*	Acceso web público Saniter -- HTTPS

Ilustración 86 - Reglas WAN firewall OPNsense

4.5.2 Ubuntu Server 22.04

A continuación, se aplican todas las medidas de seguridad sobre el servidor Ubuntu. El orden es importante: primero se cambia la IP para que el servidor quede correctamente en la nueva red, y después se aplican las medidas de bastionado.

4.5.2.1 Cambio de IP a la nueva red

[op.net.1] Segregación de redes

Lo primero de todo, se realiza un cambio en la configuración de la máquina virtual, cambiando la red interna de *red_saniter_inicial* a *red_saniter_ENS*.

Tras realizar este paso, se procede a configurar el servidor. Éste debe pasar de la red inicial (172.16.0.0/24) a la nueva red con OPNsense (10.0.0.0/24). Para ello, se edita el archivo de configuración de red ubicado en la ruta /etc/netplan (99-manual-config.yaml). Para aplicar los cambios es importante ejecutar el comando *sudo netplan apply*.

```
cd /etc/netplan
ls
sudo nano 99-manual-config.yaml
sudo netplan apply
```

Ilustración 87 - Configuración de la IP de Ubuntu Server

```
GNU nano 6.2 99-manual-config.yaml
network:
  version: 2
  ethernet:
    enp0s3:
      dhcp4: no
      addresses:
        - 10.0.0.30/24
      routes:
        - to: default
          via: 10.0.0.1
      nameservers:
        addresses: [10.0.0.20, 8.8.8.8, 8.8.4.4]
```

Ilustración 88 - Contenido archivo 99-manual-config.yaml

Por último, se comprueba que la nueva IP se ha configurado correctamente y está activa (*ip a show enp0s3*) y que existe conectividad con OPNsense y el Directorio Activo (*ping 10.0.0.1*; *ping 10.0.0.20*).

```
administrador@server-web-saniter:/etc/netplan$ ip a show enp0s3
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:18:d7:2b brd ff:ff:ff:ff:ff:ff
    inet 10.0.0.30/24 brd 10.0.0.255 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe18:d72b/64 scope link
        valid_lft forever preferred_lft forever
```

Ilustración 89 - Comprobación de asignación IP Ubuntu Server

```
administrador@server-web-saniter:/etc/netplan$ ping -c 4 10.0.0.1
PING 10.0.0.1 (10.0.0.1) 56(84) bytes of data.
64 bytes from 10.0.0.1: icmp_seq=1 ttl=64 time=1.51 ms
64 bytes from 10.0.0.1: icmp_seq=2 ttl=64 time=2.14 ms
64 bytes from 10.0.0.1: icmp_seq=3 ttl=64 time=3.39 ms
64 bytes from 10.0.0.1: icmp_seq=4 ttl=64 time=4.99 ms

--- 10.0.0.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3808ms
rtt min/avg/max/mdev = 1.509/3.007/4.988/1.328 ms
```

Ilustración 90 - Comprobación conectividad Ubuntu Server con OPNsense

```
administrador@server-web-saniter:~$ ping 10.0.0.20
PING 10.0.0.20 (10.0.0.20) 56(84) bytes of data.
64 bytes from 10.0.0.20: icmp_seq=1 ttl=128 time=0.856 ms
64 bytes from 10.0.0.20: icmp_seq=2 ttl=128 time=1.06 ms
64 bytes from 10.0.0.20: icmp_seq=3 ttl=128 time=1.70 ms
64 bytes from 10.0.0.20: icmp_seq=4 ttl=128 time=1.45 ms
64 bytes from 10.0.0.20: icmp_seq=5 ttl=128 time=1.37 ms
```

Ilustración 91 - Comprobación conectividad Ubuntu Server con Windows Server

4.5.2.2 Configuración del firewall UFW

[op.net.1] Segregación de redes

[mp.com.1] Perímetro seguro

UFW (Uncomplicated Firewall) es el firewall del propio servidor Ubuntu. Actúa como segunda capa de defensa, complementando a OPNsense. Se configura para que solo entren los servicios estrictamente necesarios.

Al inicio está inactivo. Se procede a establecer políticas por defecto y posteriormente permitir o bloquear accesos específicos.

En primer lugar, se deniega todo el tráfico entrante y se permite el saliente. Luego se permiten únicamente los puertos necesarios (22/TCP, 80/TCP y 443/TCP) y se bloquea el acceso externo a la base de datos (3306/TCP).

Se finaliza habilitando el firewall y comprobando su correcta configuración.

```
sudo ufw status
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp comment 'SSH administracion'
sudo ufw allow 80/tcp comment 'HTTP Apache'
sudo ufw allow 443/tcp comment 'HTTPS Apache'
sudo ufw deny 3306/tcp comment 'MariaDB - solo localhost'
sudo ufw enable
sudo ufw status verbose
```

Ilustración 92 - Configuración firewall Ubuntu Server UFW

```
administrador@server-web-saniter:/etc/netplan$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere # SSH administracion
80/tcp ALLOW IN Anywhere # HTTP Apache
443/tcp ALLOW IN Anywhere # HTTPS Apache
3306/tcp DENY IN Anywhere # MariaDB - solo localhost
22/tcp (v6) ALLOW IN Anywhere (v6) # SSH administracion
80/tcp (v6) ALLOW IN Anywhere (v6) # HTTP Apache
443/tcp (v6) ALLOW IN Anywhere (v6) # HTTPS Apache
3306/tcp (v6) DENY IN Anywhere (v6) # MariaDB - solo localhost
```

Ilustración 93 - Comprobación reglas aplicadas UFW

4.5.2.3 Bastionado del servicio SSH

[op.acc.2] Mínimo privilegio

[op.acc.4] Autenticación robusta

El servicio SSH es la puerta de administración remota del servidor. La configuración por defecto tiene varias opciones que deben corregirse ya que son inseguras. Dentro del archivo de configuración de SSH (sshd_config) se van a modificar y añadir la siguiente información:

```
Port 2222
PermitRootLogin no
PasswordAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
AllowUsers administrador
```

```
sudo nano sshd_config
sudo systemctl restart sshd
```

Ilustración 94 - Configuración SSH

```

Include /etc/ssh/sshd_config.d/*.conf

Port 2222
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

LoginGraceTime 30
PermitRootLogin no
#StrictModes yes
MaxAuthTries 3
#MaxSessions 10

```

Ilustración 95 – Contenido archivo sshd_config I

```

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication yes
#PermitEmptyPasswords no

```

Ilustración 96 - Contenido archivo sshd_config II

```

# ForceCommand cvs server
AllowUsers administrador

```

Ilustración 97 - Contenido archivo sshd_config III

Tras realizar estos cambios, debe reiniciarse el servicio SSH y actualizar las reglas de UFW para el nuevo puerto SSH (ya no es el 22, pasa a ser el 2222). Se aplican los siguientes comandos:

```

sudo systemctl restart
sudo ufw delete allow 22/tcp
sudo ufw allow 2222/tcp comment 'SSH nuevo puerto'

```

```

administrador@server-web-saniter:/etc/ssh$ sudo systemctl restart sshd
administrador@server-web-saniter:/etc/ssh$ sudo ufw delete allow 22/tcp
Rule deleted
Rule deleted (v6)
administrador@server-web-saniter:/etc/ssh$ sudo ufw allow 2222/tcp comment 'SSH nuevo puerto'
Rule added
Rule added (v6)
administrador@server-web-saniter:/etc/ssh$

```

Ilustración 98 - Cambio de regla puerto SSH

Durante la auditoría se obtuvieron resultados que indicaban que existían algoritmos MAC débiles. En el mismo archivo de configuración se añade la siguiente información y se reinicia nuevamente:

```
MACs hmac-sha2-512,hmac-sha2-256,umac-128@openssh.com
sudo systemctl restart sshd
```

```
# ForceCommand cvs server
AllowUsers administrador
MACs hmac-sha2-512,hmac-sha2-256,umac-128@openssh.com
```

Ilustración 99 - Algoritmos MAC en sshd_config

```
sudo nano sshd_config
sudo systemctl restart sshd
sudo ufw delete allow 22/tcp
sudo ufw allow 2222/tcp comment 'SSH nuevo puerto'
sudo nano sshd_config
sudo systemctl restart sshd
```

Ilustración 100 - Resumen comandos empleados en configuración SSH

4.5.2.4 Bastionado de MariaDB

[op.acc.2] Mínimo privilegio

[op.acc.1] Identificación de usuarios única

La auditoría inicial detectó el puerto 3306 abierto y accesible desde la red, y un usuario con acceso desde cualquier IP con todos los permisos. Se procede a corregirlo en dos pasos: restringir MariaDB a localhost y crear usuarios con mínimo privilegio.

4.5.2.4.1 Restricción de MariaDB a localhost

Se modifica el archivo de configuración de MariaDB y se realizan las comprobaciones:

```
sudo nano /etc/mysql/mariadb.conf.d/50-server.cnf
sudo bind-address = 127.0.0.1
systemctl restart mariadb
ss -tlnp | grep 3306
```

```
administrador@server-web-saniter:/etc/mysql/mariadb.conf.d$ sudo systemctl restart mariadb
administrador@server-web-saniter:/etc/mysql/mariadb.conf.d$ ss -tlnp | grep 3306
LISTEN 0      80          127.0.0.1:3306  0.0.0.0:*
```

Ilustración 101 - Comprobación puerto 3306

4.5.2.4.2 Eliminación de usuario inseguro y creación de usuario con mínimo privilegio

Se accede a la base de datos para borrar el usuario inseguro `admin_stock`, que tenía acceso desde cualquier IP, y se crea un nuevo usuario específico para el almacén. Solo tendrá acceso desde localhost y con permisos limitados sobre la tabla de stock (SELECT e INSERT). Además, se crea un usuario para la aplicación web (phpMyAdmin), con acceso solo a la base de datos de Saniter

```
sudo mariadb
DROP USER 'admin_stock'@'%';

CREATE USER 'usr_almacen'@'localhost' IDENTIFIED BY
'StockSeguro2026!';

CREATE USER 'usr_webapp'@'localhost' IDENTIFIED BY
'WebApp2026!';

GRANT SELECT, INSERT, UPDATE ON saniter_db.* TO
'usr_webapp'@'localhost';

GRANT SELECT, INSERT ON saniter_db.stock TO
'usr_almacen'@'localhost';

FLUSH PRIVILEGES;

EXIT;
```

```
administrador@server-web-saniter:/etc/mysql/mariadb.conf.d$ sudo mariadb
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 10.6.23-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> DROP USER 'admin_stock'@'%';
Query OK, 0 rows affected (0,007 sec)

MariaDB [(none)]> CREATE USER 'user_almacen'@'localhost' IDENTIFIED BY 'StockSeguro2026!';
Query OK, 0 rows affected (0,004 sec)

MariaDB [(none)]> GRANT SELECT, INSERT ON saniter_db.stock TO 'user_almacen'@'localhost';
Query OK, 0 rows affected (0,003 sec)

MariaDB [(none)]> CREATE USER 'user_webapp'@'localhost' IDENTIFIED BY 'WebApp2026!';
Query OK, 0 rows affected (0,026 sec)

MariaDB [(none)]> GRANT SELECT, INSERT, UPDATE ON saniter_db.* TO 'user_webapp'@'localhost';
Query OK, 0 rows affected (0,003 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0,000 sec)
```

Ilustración 102 - Creación de usuarios en MariaDB

4.5.2.4.3 Ejecutar el script de seguridad de MariaDB

[op.acc.2] Gestión de privilegios: mínimo privilegio

[mp.s.1] Configuración segura inicial

Aunque en el paso anterior ya se han eliminado los usuarios inseguros y se han creado usuarios con mínimo privilegio, MariaDB incluye por defecto una serie de configuraciones y objetos que suponen riesgos adicionales de seguridad: una base de datos de prueba (test) accesible por cualquier usuario, cuentas anónimas sin contraseña y la posibilidad de que el usuario root se conecte de forma remota. El script `mysql_secure_installation` está diseñado específicamente para eliminar todos estos elementos con una sola ejecución guiada.

Su ejecución responde al control [mp.s.1] del ENS (configuración segura inicial): no basta con instalar el servicio y crear los usuarios correctos, también hay que asegurarse de que la instalación base no contiene elementos por defecto que puedan ser explotados. Este script es la herramienta estándar recomendada por la propia documentación de MariaDB.

Las respuestas aplicadas durante la ejecución del script y su justificación son las siguientes:

Tabla 25 - Respuestas ejecución script MariaDB

Pregunta del script	Respuesta	Justificación
Enter current password for root:	(vacío, sin contraseña inicial)	La instalación por defecto de MariaDB en Ubuntu no asigna contraseña al usuario root. Se confirma que no existe contraseña previa.
Switch to unix_socket authentication? [Y/n]	N	Se mantiene la autenticación por contraseña para garantizar la compatibilidad con scripts de backup automatizados que necesitan autenticarse contra MariaDB.
Change the root password? [Y/n]	Y	Se establece una contraseña robusta para el usuario root, eliminando el acceso sin contraseña que existía por defecto. Control [op.acc.4].
Remove anonymous users? [Y/n]	Y	Las cuentas anónimas permiten conectarse a MariaDB sin autenticación. Su eliminación es obligatoria para cumplir el control [op.acc.1].
Disallow root login remotely? [Y/n]	Y	El usuario root no debe ser accesible desde fuera del servidor local. Junto con la restricción bind-address = 127.0.0.1, esto garantiza que no hay acceso remoto privilegiado a la base de datos.
Remove test database and access to it? [Y/n]	Y	La base de datos test es accesible por cualquier usuario y puede usarse como superficie de ataque para explorar la configuración del servidor.
Reload privilege tables now? [Y/n]	Y	Aplica todos los cambios realizados de forma inmediata, sin necesidad de reiniciar el servicio MariaDB.


```
Enter current password for root (enter for none):
OK, successfully used password, moving on...

Setting the root password or using the unix_socket ensures that nobody
can log into the MariaDB root user without the proper authorisation.

You already have your root account protected, so you can safely answer 'n'.

Switch to unix_socket authentication [Y/n] n
... skipping.

You already have your root account protected, so you can safely answer 'n'.

Change the root password? [Y/n] y
New password:
Re-enter new password:
Password updated successfully!
Reloading privilege tables..
... Success!

By default, a MariaDB installation has an anonymous user, allowing anyone
to log into MariaDB without having to have a user account created for
them. This is intended only for testing, and to make the installation
go a bit smoother. You should remove them before moving into a
production environment.

Remove anonymous users? [Y/n] Y
... Success!

Normally, root should only be allowed to connect from 'localhost'. This
ensures that someone cannot guess at the root password from the network.
```

Ilustración 103 - Respuestas script MariaDB I

```
Disallow root login remotely? [Y/n] Y
... Success!

By default, MariaDB comes with a database named 'test' that anyone can
access. This is also intended only for testing, and should be removed
before moving into a production environment.

Remove test database and access to it? [Y/n] Y
- Dropping test database...
... Success!
- Removing privileges on test database...
... Success!

Reloading the privilege tables will ensure that all changes made so far
will take effect immediately.

Reload privilege tables now? [Y/n] Y
... Success!

Cleaning up...

All done! If you've completed all of the above steps, your MariaDB
installation should now be secure.

Thanks for using MariaDB!
```

Ilustración 104 - Respuestas script MariaDB II

4.5.2.5 Bastionado de Apache - Cabeceras de seguridad HTTP

[mp.s.1] Configuración segura inicial

La auditoría detectó que phpMyAdmin es accesible por HTTP sin cifrado. Además, Apache en su configuración por defecto expone información del servidor que un atacante puede usar para identificar vulnerabilidades. Se aplican cabeceras de seguridad y se oculta la información del servidor.

4.5.2.5.1 Ocultar la versión de Apache y del sistema operativo

Se modifican un par de líneas del archivo de configuración de apache:

```
sudo nano /etc/apache2/conf-available/security.conf

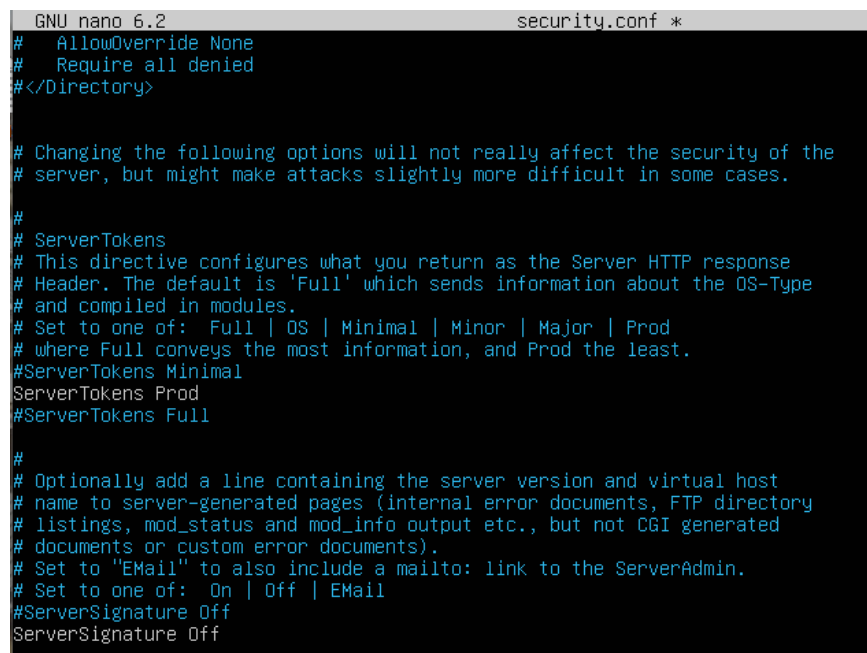
Se modifican las líneas:

ServerTokens Prod

ServerSignature Off
```

```
cd apache2/
cd conf-available/
sudo nano security.conf
```

Ilustración 105 - Configuración seguridad Apache



```
GNU nano 6.2 security.conf *
# AllowOverride None
# Require all denied
#</Directory>

# Changing the following options will not really affect the security of the
# server, but might make attacks slightly more difficult in some cases.
#
# ServerTokens
# This directive configures what you return as the Server HTTP response
# Header. The default is 'Full' which sends information about the OS-Type
# and compiled in modules.
# Set to one of: Full | OS | Minimal | Minor | Major | Prod
# where Full conveys the most information, and Prod the least.
#ServerTokens Minimal
ServerTokens Prod
#ServerTokens Full

#
# Optionally add a line containing the server version and virtual host
# name to server-generated pages (internal error documents, FTP directory
# listings, mod_status and mod_info output etc., but not CGI generated
# documents or custom error documents).
# Set to "EMail" to also include a mailto: link to the ServerAdmin.
# Set to one of: On | Off | EMail
#ServerSignature Off
ServerSignature Off
```

Ilustración 106 - Contenido archivo security.conf

4.5.2.5.2 Habilitar el módulo de cabeceras y configurarlas

Se habilita el módulo de cabeceras y se accede al archivo de configuración para incluir nuevas líneas de información que evitarán dar información sensible.

```
sudo a2enmod headers
sudo nano /etc/apache2/sites-available/000-
default.conf
```

Se añaden las siguientes líneas:

```
Header always set X-Frame-Options 'SAMEORIGIN'
Header always set X-Content-Type-Options 'nosniff'
Header always set X-XSS-Protection '1; mode=block'
Header always set Referrer-Policy 'strict-origin-
```

```
administrador@server-web-saniter:/etc/apache2/conf-available$ sudo a2enmod headers
Enabling module headers.
To activate the new configuration, you need to run:
  systemctl restart apache2
administrador@server-web-saniter:/etc/apache2/conf-available$ systemctl restart apache2
==== AUTHENTICATING FOR org.freedesktop.systemd1.manage-units ====
Authentication is required to restart 'apache2.service'.
Authenticating as: Administrador (administrador)
Password:
==== AUTHENTICATION COMPLETE ====
```

Ilustración 107 - Configuración de los headers en apache

```
<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
    # include a line for only one particular virtual host. For example the
    # following line enables the CGI configuration for this host only
    # after it has been globally disabled with "a2disconf".
    #Include conf-available/serve-cgi-bin.conf
    Header always set X-Frame-Options "SAMEORIGIN"
    Header always set X-Content-Type-Options "nosniff"
    Header always set X-XSS-Protection "1; mode=block"
    Header always set Referrer-Policy "strict-origin-when-cross-origin"
</VirtualHost>
```

Ilustración 108 – Contenido archivo 000-default.conf

4.5.2.5.3 Reinicio de Apache y verificación

Como último paso, se reinicia el servicio y se comprueba que han funcionado las medidas aplicadas.

```
sudo systemctl restart apache2  
curl -I http://10.0.0.30
```

```
administrador@server-web-saniter:/etc/apache2$ sudo systemctl restart apache2  
administrador@server-web-saniter:/etc/apache2$ curl -I http://10.0.0.30  
HTTP/1.1 200 OK  
Date: Fri, 01 May 2026 14:35:05 GMT  
Server: Apache  
X-Frame-Options: SAMEORIGIN  
X-Content-Type-Options: nosniff  
X-XSS-Protection: 1; mode=block  
Referrer-Policy: strict-origin-when-cross-origin  
Last-Modified: Sun, 26 Apr 2026 15:21:54 GMT  
ETag: "3fe1-6505e8eded4e0"  
Accept-Ranges: bytes  
Content-Length: 16353  
Vary: Accept-Encoding  
Content-Type: text/html
```

Ilustración 109 - Reinicio de Apache y comprobación de medidas

4.5.2.6 Deshabilitar TCP Timestamps e ICMP Timestamp

[mp.s.1] Configuración segura inicial

Estas dos vulnerabilidades de nivel Bajo fueron detectadas en la auditoría. Se corrigen con una sola modificación en la configuración del kernel. Se accede al archivo de configuración y se añaden unas líneas, aplicando los cambios al terminar.

```
sudo nano /etc/sysctl.conf  
Se añade al final del archivo:  
#ENS-Deshabilitar TCP Timestamps (CVE info  
disclosure)  
net.ipv4.tcp_timestamps = 0  
#ENS-Deshabilitar respuesta a ICMP timestamp
```

```
GNU nano 6.2 /etc/sysctl.conf *
# redirection. Some network environments, however, require that these
# settings are disabled so review and enable them as needed.
#
# Do not accept ICMP redirects (prevent MITM attacks)
#net.ipv4.conf.all.accept_redirects = 0
#net.ipv6.conf.all.accept_redirects = 0
#_or_
# Accept ICMP redirects only for gateways listed in our default
# gateway list (enabled by default)
# net.ipv4.conf.all.secure_redirects = 1
#
# Do not send ICMP redirects (we are not a router)
#net.ipv4.conf.all.send_redirects = 0
#
# Do not accept IP source route packets (we are not a router)
#net.ipv4.conf.all.accept_source_route = 0
#net.ipv6.conf.all.accept_source_route = 0
#
# Log Martian Packets
#net.ipv4.conf.all.log_martians = 1
#
#####
# Magic system request Key
# 0=disable, 1=enable all, >1 bitmask of sysrq functions
# See https://www.kernel.org/doc/html/latest/admin-guide/sysrq.html
# for what other values do
#kernel.sysrq=438
#
# ENS - Deshabilitar TCP Timestamps (CVE info disclosure)
net.ipv4.tcp_timestamps = 0
# ENS - Deshabilitar la respuesta a ICMP timestamp
net.ipv4.icmp_echo_ignore_broadcast = 1
```

Ilustración 110 - Contenido archivo sysctl.conf

```
administrador@server-web-saniter:/etc/apache2$ sudo sysctl -p
net.ipv4.tcp_timestamps = 0
net.ipv4.icmp_echo_ignore_broadcasts = 1
```

Ilustración 111 - Comprobación de aplicación de medidas

4.5.2.7 Configuración de logs y trazabilidad

[op.exp.8] Registro de actividad

[op.mon.1] Detección de intrusiones

El ENS exige que el sistema registre la actividad de los usuarios para garantizar la trazabilidad. En Ubuntu, el archivo `/var/log/auth.log` ya recoge los eventos de autenticación, pero se debe verificar que está activo y configurar la retención de logs.

```
sudo systemctl status rsyslog
sudo tail -20 /var/log/auth.log
```

```
administrador@server-web-saniter:/etc/apache2$ sudo systemctl status rsyslog
● rsyslog.service - System Logging Service
   Loaded: loaded (/lib/systemd/system/rsyslog.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2026-05-01 13:24:19 UTC; 1h 17min ago
     TriggeredBy: ● syslog.socket
       Docs: man:rsyslogd(8)
             man:rsyslog.conf(5)
             https://www.rsyslog.com/doc/
    Main PID: 667 (rsyslogd)
      Tasks: 4 (limit: 2218)
     Memory: 2.8M
        CPU: 70ms
    CGroup: /system.slice/rsyslog.service
            └─667 /usr/sbin/rsyslogd -n -iNONE

may 01 13:24:19 server-web-saniter systemd[1]: Starting System Logging Service...
may 01 13:24:19 server-web-saniter rsyslogd[667]: imuxsock: Acquired UNIX socket '/run/systemd/journald' for use
may 01 13:24:19 server-web-saniter systemd[1]: Started System Logging Service.
may 01 13:24:19 server-web-saniter rsyslogd[667]: rsyslogd's groupid changed to 113
may 01 13:24:19 server-web-saniter rsyslogd[667]: rsyslogd's userid changed to 106
may 01 13:24:19 server-web-saniter rsyslogd[667]: [origin software="rsyslogd" swVersion="8.2112.0" x-
lines 1-20/20 (END)]
```

Ilustración 112 - Comprobación estado rsyslog

```
administrador@server-web-saniter:/etc/apache2$ sudo tail -20 /var/log/auth.log
May 1 14:34:43 server-web-saniter sudo: pam_unix(sudo:session): session closed for user root
May 1 14:36:23 server-web-saniter sudo: administrador : TTY=ttty1 ; PWD=/etc/apache2 ; USER=root ; COMMAND=/usr/bin/nano /etc/sysctl.conf
May 1 14:36:23 server-web-saniter sudo: pam_unix(sudo:session): session opened for user root(uid=0)
   by administrador(uid=1000)
May 1 14:38:02 server-web-saniter sudo: pam_unix(sudo:session): session closed for user root
May 1 14:38:11 server-web-saniter sudo: administrador : TTY=ttty1 ; PWD=/etc/apache2 ; USER=root ; COMMAND=/usr/sbin/sysctl -p
May 1 14:38:11 server-web-saniter sudo: pam_unix(sudo:session): session opened for user root(uid=0)
   by administrador(uid=1000)
May 1 14:38:11 server-web-saniter sudo: pam_unix(sudo:session): session closed for user root
May 1 14:38:55 server-web-saniter sudo: administrador : TTY=ttty1 ; PWD=/etc/apache2 ; USER=root ; COMMAND=/usr/bin/nano /etc/sysctl.conf
May 1 14:38:55 server-web-saniter sudo: pam_unix(sudo:session): session opened for user root(uid=0)
   by administrador(uid=1000)
May 1 14:39:01 server-web-saniter CRON[2148]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
May 1 14:39:01 server-web-saniter CRON[2148]: pam_unix(cron:session): session closed for user root
May 1 14:39:47 server-web-saniter sudo: pam_unix(sudo:session): session closed for user root
May 1 14:39:50 server-web-saniter sudo: administrador : TTY=ttty1 ; PWD=/etc/apache2 ; USER=root ; COMMAND=/usr/sbin/sysctl -p
May 1 14:39:50 server-web-saniter sudo: pam_unix(sudo:session): session opened for user root(uid=0)
   by administrador(uid=1000)
May 1 14:39:50 server-web-saniter sudo: pam_unix(sudo:session): session closed for user root
May 1 14:41:26 server-web-saniter sudo: administrador : TTY=ttty1 ; PWD=/etc/apache2 ; USER=root ; COMMAND=/usr/bin/systemctl status rsyslog
May 1 14:41:26 server-web-saniter sudo: pam_unix(sudo:session): session opened for user root(uid=0)
   by administrador(uid=1000)
May 1 14:41:52 server-web-saniter sudo: pam_unix(sudo:session): session closed for user root
May 1 14:42:08 server-web-saniter sudo: administrador : TTY=ttty1 ; PWD=/etc/apache2 ; USER=root ; COMMAND=/usr/bin/tail -20 /var/log/auth.log
May 1 14:42:08 server-web-saniter sudo: pam_unix(sudo:session): session opened for user root(uid=0)
   by administrador(uid=1000)
```

Ilustración 113 - Extracto de logs

Se modifica la retención de logs a 90 días en el archivo de configuración logrotate, añadiendo o activando las líneas correspondientes.

```
sudo nano /etc/logrotate.conf

Se añaden o activan las siguientes líneas:

rotate 13

weekly

compress
```

```

GNU nano 6.2 /etc/logrotate.conf *
# see "man logrotate" for details

# global options do not affect preceding include directives

# rotate log files weekly
weekly

# use the adm group by default, since this is the owning group
# of /var/log/syslog.
su root adm

# keep 13 weeks worth of backlogs
rotate 13

# create new (empty) log files after rotating old ones
create

# use date as a suffix of the rotated file
#dateext

# uncomment this if you want your log files compressed
compress

# packages drop log rotation information into this directory
include /etc/logrotate.d

# system-specific logs may also be configured here.

```

Ilustración 114 - Contenido archivo logrotate.conf

4.5.2.8 Plan de backup - Copias de seguridad de la BBDD

[op.cont.2] Copias de seguridad

[mp.info.6] Protección de la información

Se programa una tarea automática diaria que genera un volcado de la base de datos saniter_db y lo almacena localmente. Para ello se crea un directorio donde se guardarán los backups.

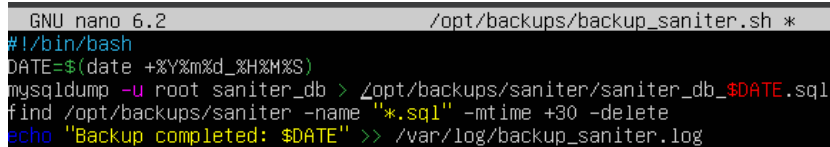
Se genera el script del backup que indicará qué copia se hará, donde se guardará y con qué nombre. Posteriormente, Se otorgan permisos de ejecución y se programa la tarea (todos los días a las 2:00AM) con crontab.

```

sudo mkdir -p /opt/backups/saniter
sudo chmod 700 /opt/backups/saniter
sudo nano /opt/backups/backup_saniter.sh
Script:
#!/bin/bash
DATE=$(date +%Y%m%d_%H%M%S)
mysqldump -u root -skip-password saniter_db >
/opt/backups/saniter/saniter_db_$DATE.sql
find /opt/backups/saniter -name '*.sql' -mtime
+30 -delete
echo 'Backup completado: '$DATE >>
/var/log/backup_saniter.log

sudo chmod +x /opt/backups/backup_saniter.sh
sudo crontab -e
Se añade al final del archivo:
0 2 * * * /opt/backups/backup_saniter.sh

```



```

GNU nano 6.2 /opt/backups/backup_saniter.sh *
#!/bin/bash
DATE=$(date +%Y%m%d_%H%M%S)
mysqldump -u root saniter_db > /opt/backups/saniter/saniter_db_$DATE.sql
find /opt/backups/saniter -name "*.sql" -mtime +30 -delete
echo "Backup completed: $DATE" >> /var/log/backup_saniter.log

```

Ilustración 115 - Script backup_saniter.sh


```
GNU nano 6.2 /tmp/crontab.60056k/crontab
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
0 2 * * * /opt/backups/backup_saniter.sh_
```

Ilustración 116 - Contenido archivo crontab

Para comprobar el correcto funcionamiento del script, se ejecuta manualmente y se accede a la carpeta creada para comprobar la creación de la copia de seguridad.

```
sudo /opt/backups/backup_saniter.sh
ls -lh /opt/backups/saniter/
```

```
administrador@server-web-saniter:/opt/backups$ sudo /opt/backups/backup_saniter.sh
administrador@server-web-saniter:/opt/backups$ ls -lh /opt/backups/saniter
ls: cannot open directory '/opt/backups/saniter': Permission denied
administrador@server-web-saniter:/opt/backups$ sudo ls -lh /opt/backups/saniter
total 8,0K
-rw-r--r-- 1 root root 4,6K may  1 14:59 saniter_db_20260501_145913.sql
```

Ilustración 117 - Ejecución manual scrip backups y comprobación generación archivo

4.5.3 Windows Server 2022 (SERVER-AD-01)

A continuación, se aplican todas las medidas de seguridad sobre el Controlador de Dominio. Al igual que con Ubuntu, primero se actualiza la IP a la nueva red y después se aplican las medidas de bastionado

4.5.3.1 Cambio de IP a la nueva red

[op.net.1] Segregación de redes

En primer lugar, se cambiar la red interna de la máquina virtual: de red_saniter_inicial a red_saniter_ENS.

Se abre ejecuta como administrador la consola de PowerShell y se indican comandos para conocer el nombre del adaptador de red en primer lugar y posteriormente configurar la IP estática. Una vez se han llevado a cabo todos los pasos, se verifica la nueva configuración

```
Get-NetAdapter

New-NetIPAddress -InterfaceAlias 'Ethernet' -
IPAddress 10.0.0.20 -PrefixLength 24 -
DefaultGateway 10.0.0.1
Set-DnsClientServerAddress -InterfaceAlias
'Ethernet' -ServerAddresses
('127.0.0.1','10.0.0.20')
```

```
PS C:\Users\Administrador> Get-NetAdapter

Name                InterfaceDescription      ifIndex Status    MacAddress      LinkSpeed
-----                -
Ethernet            Intel(R) PRO/1000 MT Desktop Adapter 4 Up         08-00-27-AE-17-05 1 Gbps
```

Ilustración 118 - Información tarjeta de red

```
PS C:\Users\Administrador> New-NetIPAddress -InterfaceAlias 'Ethernet' -IPAddress 10.0.0.20 -PrefixLength 24 -DefaultGateway 10.0.0.1
Set-DnsClientServerAddress -InterfaceAlias 'Ethernet' -ServerAddresses ('127.0.0.1','10.0.0.20')

IPAddress           : 10.0.0.20
InterfaceIndex      : 4
InterfaceAlias      : Ethernet
AddressFamily       : IPv4
Type                : Unicast
PrefixLength        : 24
PrefixOrigin        : Manual
SuffixOrigin        : Manual
AddressState        : Tentative
ValidLifetime       : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime   : Infinite ([TimeSpan]::MaxValue)
SkipAsSource        : False
PolicyStore         : ActiveStore

IPAddress           : 10.0.0.20
InterfaceIndex      : 4
InterfaceAlias      : Ethernet
AddressFamily       : IPv4
Type                : Unicast
PrefixLength        : 24
PrefixOrigin        : Manual
SuffixOrigin        : Manual
AddressState        : Invalid
ValidLifetime       : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime   : Infinite ([TimeSpan]::MaxValue)
SkipAsSource        : False
PolicyStore         : PersistentStore
```

Ilustración 119 - Cambio de dirección IP y default gateway

```
PS C:\Users\Administrador> Get-NetIPAddress -InterfaceAlias 'Ethernet'

IPAddress           : 10.0.0.20
InterfaceIndex      : 4
InterfaceAlias      : Ethernet
AddressFamily       : IPv4
Type                : Unicast
PrefixLength        : 24
PrefixOrigin        : Manual
SuffixOrigin        : Manual
AddressState        : Preferred
ValidLifetime       : Infinite ([TimeSpan]::MaxValue)
PreferredLifetime   : Infinite ([TimeSpan]::MaxValue)
SkipAsSource        : False
PolicyStore         : ActiveStore
```

Ilustración 120 - Información de la tarjeta de red

```
PS C:\Users\Administrador> ping 10.0.0.1

Haciendo ping a 10.0.0.1 con 32 bytes de datos:
Respuesta desde 10.0.0.1: bytes=32 tiempo=2ms TTL=64
Respuesta desde 10.0.0.1: bytes=32 tiempo=1ms TTL=64
Respuesta desde 10.0.0.1: bytes=32 tiempo=3ms TTL=64
Respuesta desde 10.0.0.1: bytes=32 tiempo=1ms TTL=64

Estadísticas de ping para 10.0.0.1:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 1ms, Máximo = 3ms, Media = 1ms
```

Ilustración 121 - Comprobación conectividad con OPNsense

4.5.3.2 Reorganización del Directorio Activo - Unidades Organizativas

[op.acc.1] Identificación de usuarios única

[op.acc.2] Mínimo privilegio

En el escenario inicial, todos los usuarios estaban en la carpeta por defecto sin ningún tipo de organización. Se crean Unidades Organizativas (UOs) por perfil de trabajo y se asigna cada usuario a su UO correspondiente para mejorar la clasificación. De esta manera es posible aplicar Políticas de grupo (GPOs) específicas a cada grupo de usuarios.

Desde la consola de PowerShell se crean las nuevas unidades organizativas y se mueven los usuarios a su unidad correspondiente.

Creación de las UOs:

```
New-ADOrganizationalUnit -Name 'Sistemas' -Path
'DC=saniter,DC=local'
New-ADOrganizationalUnit -Name 'Administracion' -
Path 'DC=saniter,DC=local'
New-ADOrganizationalUnit -Name 'Tecnicos' -Path
'DC=saniter,DC=local'
New-ADOrganizationalUnit -Name 'Almacen' -Path
'DC=saniter,DC=local'
```

Cambio de ubicación de los usuarios existentes:

```
Move-ADObject -Identity (Get-ADUser
'Beatriz').DistinguishedName -TargetPath
'OU=Sistemas,DC=saniter,DC=local'
```

```
Move-ADObject -Identity (Get-ADUser
'Alberto').DistinguishedName -TargetPath
'OU=Administracion,DC=saniter,DC=local'
```

```
Move-ADObject -Identity (Get-ADUser
'Alejandra').DistinguishedName -TargetPath
'OU=Administracion,DC=saniter,DC=local'
```

```
Move-ADObject -Identity (Get-ADUser
'JoseRamon').DistinguishedName -TargetPath
'OU=Administracion,DC=saniter,DC=local'
```

```
Move-ADObject -Identity (Get-ADUser
'Carlos').DistinguishedName -TargetPath
'OU=Tecnicos,DC=saniter,DC=local'
```

```
Move-ADObject -Identity (Get-ADUser
'Cristian').DistinguishedName -TargetPath
'OU=Tecnicos,DC=saniter,DC=local'
```

Personal de almacén

```
Move-ADObject -Identity (Get-ADUser
'Lidia').DistinguishedName -TargetPath
'OU=Almacen,DC=saniter,DC=local'
```

```
PS C:\Users\Administrador> New-ADOrganizationalUnit -Name 'Sistemas' -Path 'DC=saniter,DC=local'
PS C:\Users\Administrador> New-ADOrganizationalUnit -Name 'Administracion' -Path 'DC=saniter,DC=local'
PS C:\Users\Administrador> New-ADOrganizationalUnit -Name 'Tecnicos' -Path 'DC=saniter,DC=local'
PS C:\Users\Administrador> New-ADOrganizationalUnit -Name 'Almacen' -Path 'DC=saniter,DC=local'
```

Ilustración 122 - Creación de nuevas Unidades Organizativas

```
PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'Beatriz').DistinguishedName -TargetPath 'OU=Sistemas,DC=saniter,DC=local'
PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'Alberto').DistinguishedName -TargetPath 'OU=Administracion,DC=saniter,DC=local'

PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'Alejandra').DistinguishedName -TargetPath 'OU=Administracion,DC=saniter,DC=local'
PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'JoseRamon').DistinguishedName -TargetPath 'OU=Administracion,DC=saniter,DC=local'
PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'Carlos').DistinguishedName -TargetPath 'OU=Tecnicos,DC=saniter,DC=local'
PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'Cristian').DistinguishedName -TargetPath 'OU=Tecnicos,DC=saniter,DC=local'
PS C:\Users\Administrador> Move-ADObject -Identity (Get-ADUser 'Lidia').DistinguishedName -TargetPath 'OU=Almacen,DC=saniter,DC=local'
```

Ilustración 123 - Cambio de ubicación de los usuarios a sus nuevas Uso

- Usuarios y equipos de Active Directory [SERVER-AD-01] - Consultas guardadas - saniter.local - Administracion - Almacen	Nombre Lidia
- Usuarios y equipos de Active Directory [SERVER-AD-01] - Consultas guardadas - saniter.local - Administracion - Almacen	Nombre Alberto Alejandra JoseRamon
- Usuarios y equipos de Active Directory [SERVER-AD-01] - Consultas guardadas - saniter.local - Administracion - Almacen - Builtin - Computers - Domain Controllers - ForeignSecurityPrincipals - Keys - LostAndFound - Managed Service Accounts - Program Data - Sistemas	Nombre Beatriz
- Usuarios y equipos de Active Directory [SERVER-AD-01] - Consultas guardadas - saniter.local - Administracion - Almacen - Builtin - Computers - Domain Controllers - ForeignSecurityPrincipals - Keys - LostAndFound - Managed Service Accounts - Program Data - Sistemas - System - Tecnicos	Nombre Carlos Cristian

Ilustración 124 - Unidades organizativas y sus usuarios

4.5.3.3 GPO - Política de contraseñas robustas

[op.acc.4] Autenticación robusta

En el escenario inicial todos los usuarios tenían la misma contraseña y con la opción 'La contraseña nunca expira' activada. Se crea una GPO que obliga a usar contraseñas complejas y establece una caducidad.

Desde el editor de directivas de grupo, se crea una Política de grupo en el dominio de Saniter.local. Se le otorga el nombre de 'ENS - Política de Contraseñas' y en edición se navega a Configuración del equipo → Directivas → Configuración de Windows → Configuración de seguridad → Directivas de cuenta → Directiva de contraseñas y se configuran los siguientes valores:

Tabla 26 - Parámetros a configurar en Política de contraseñas

Parámetro	Valor ENS (Cat. Media)	Valor configurado
Longitud mínima de contraseña	8 caracteres	12 caracteres
La contraseña debe cumplir requisitos de complejidad	Habilitada	Habilitada
Vigencia máxima de la contraseña	No definido	90 días
Vigencia mínima de la contraseña	No definido	1 día
Exigir historial de contraseñas	No definido	5 contraseñas
Umbral de bloqueo de cuenta	No definido	5 intentos
Duración del bloqueo de cuenta	No definido	15 minutos

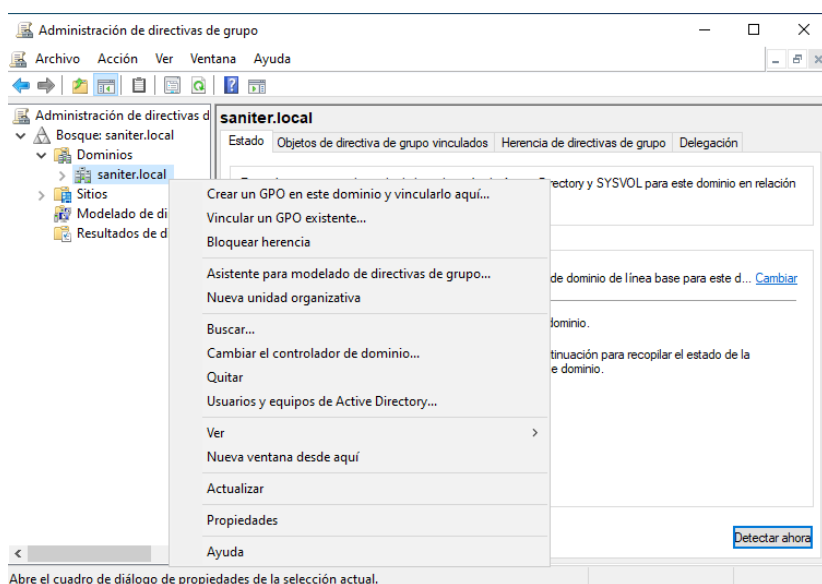


Ilustración 125 - Creación GPO en dominio saniter.local

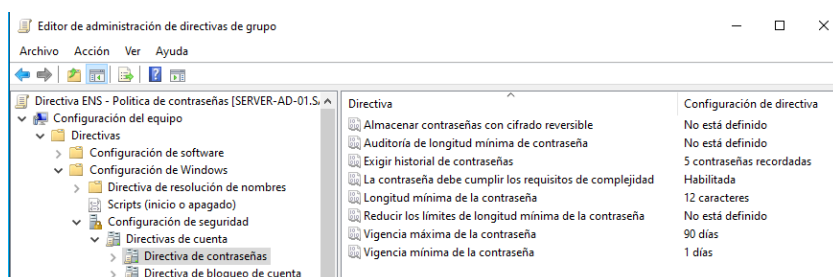


Ilustración 126 - Directiva de contraseñas actualizada

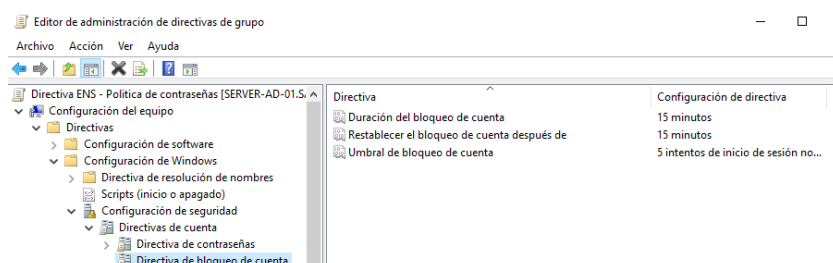


Ilustración 127 - Directiva de bloqueo de cuenta actualizada

Es importante vincular la GPO al dominio y a todas las UOs y forzar la actualización al finalizar.

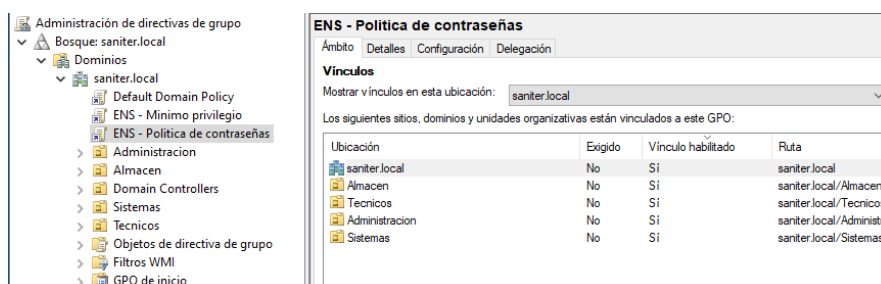


Ilustración 128 - Vínculos de la GPO ENS- Política de contraseñas

```
PS C:\Users\Administrador> gpupdate /force
Actualizando directiva...

La actualización de la directiva de equipo se completó correctamente.
Se completó correctamente la Actualización de directiva de usuario.
```

Ilustración 129 - Actualización forzada correcta

4.5.3.4 GPO - Mínimo privilegio para usuarios estándar

[op.acc.2] Mínimo privilegio

Los usuarios estándar no deben tener derechos de administrador local en sus equipos. Beatriz (Sistemas) es el único usuario que debe mantener privilegios de administración.

Se crea una nueva GPO llamada 'ENS - Mínimo Privilegio' y se vincúlala a las UOs Administración, Tecnicos y Almacen.

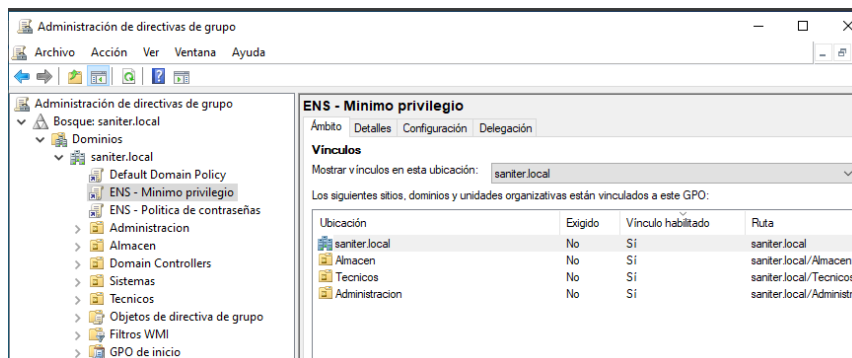


Ilustración 130 - Vínculos de GPO ENS-Mínimo privilegio

Dentro de la GPO se navega a Configuración del equipo → Directivas → Configuración de Windows → Configuración de seguridad → Grupos restringidos y se añade el grupo 'Administradores'

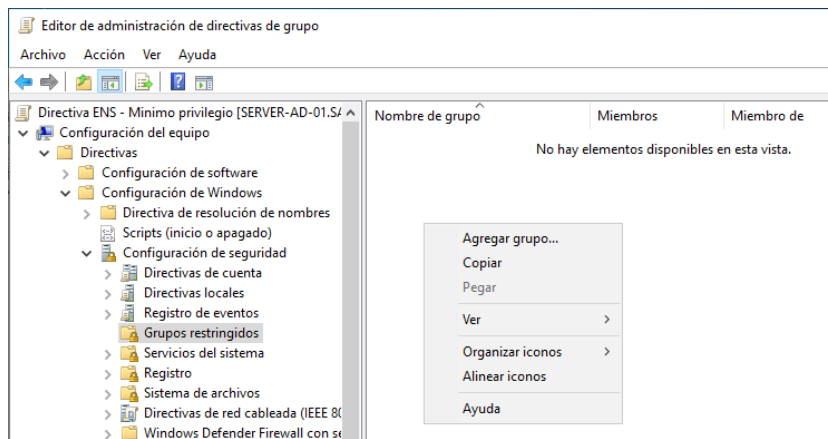


Ilustración 131 - Grupos restringidos

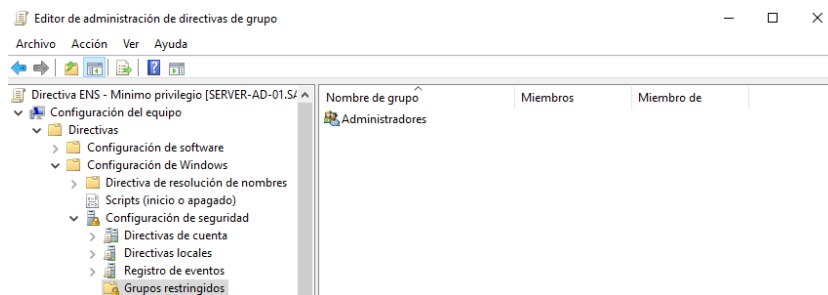


Ilustración 132 - Agregación grupo Administradores en grupos restringidos

Además, se activa el control de cuentas de usuario (UAC) para todos navegando a Configuración del equipo → Directivas → Configuración de Windows → Configuración de seguridad → Directivas locales → Opciones de seguridad.

En este apartado se activa la opción 'Control de cuentas de usuario: ejecutar todos los administradores en modo de aprobación de administrador'. Por último, se forzará la actualización.

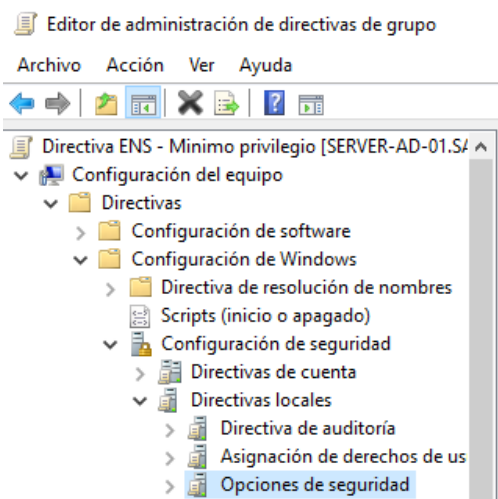


Ilustración 133 - Opciones de seguridad de directivas locales

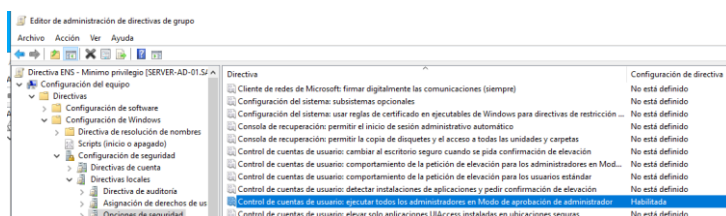


Ilustración 134 - Habilitación de UAC

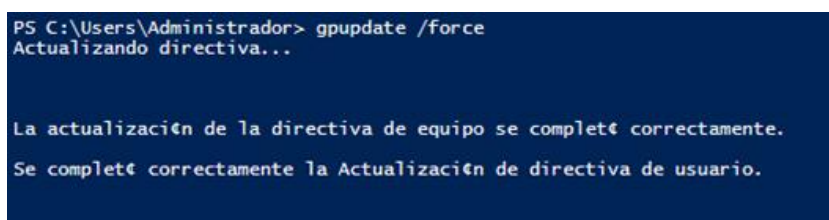


Ilustración 135 - Actualización forzada correcta

4.5.3.5 GPO - Auditoría de eventos (Trazabilidad)

[op.exp.8] Registro de actividad

[op.mon.1] Detección de intrusiones

Se activa la auditoría de inicio de sesión para registrar todos los accesos al dominio, tanto los exitosos como los fallidos. Esto cumple el control de trazabilidad del ENS.

Se crea una nueva GPO llamada 'ENS - Auditoría' y desde el apartado de editar se navega a Configuración del equipo → Directivas → Configuración de Windows → Configuración de

seguridad → Directivas locales → Directiva de auditoría. Una vez en el apartado, se configuran los siguientes eventos:

Tabla 27 - Parámetros a habilitar en Directiva de auditoría

Evento a auditar	Aciertos	Errores
Auditar sucesos de inicio de sesión de cuenta	Sí	Sí
Auditar la administración de cuentas	Sí	Sí
Auditar el acceso a objetos	Sí	Sí
Auditar el uso de privilegios	No	Sí
Auditar eventos del sistema	Sí	Sí

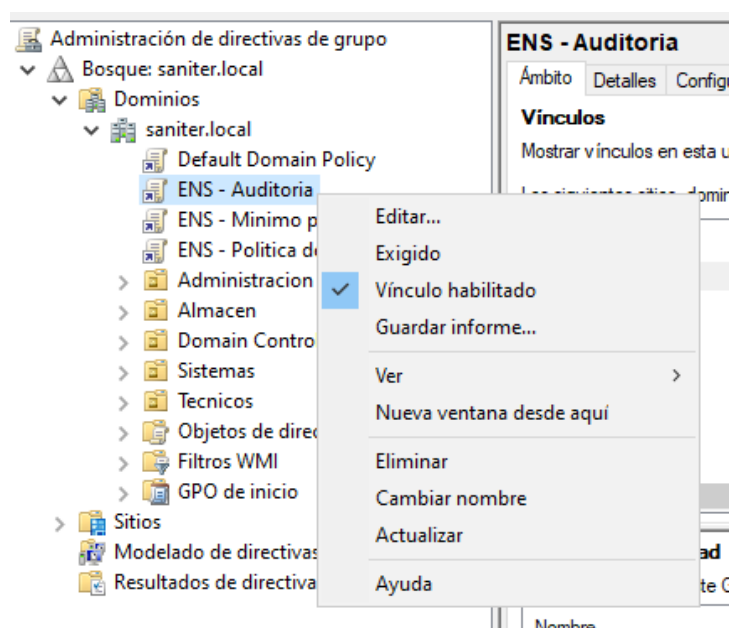


Ilustración 136 - GPO ENS -Auditoria

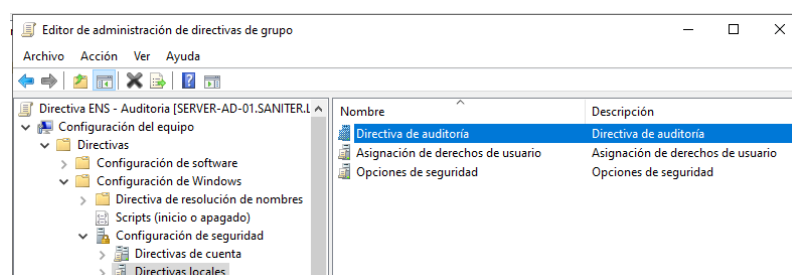


Ilustración 137 - Configuración Directiva de auditoría I

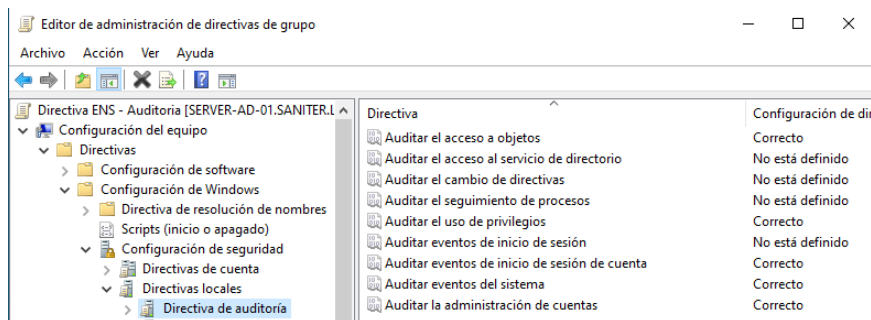


Ilustración 138- Configuración Directiva de auditoría II

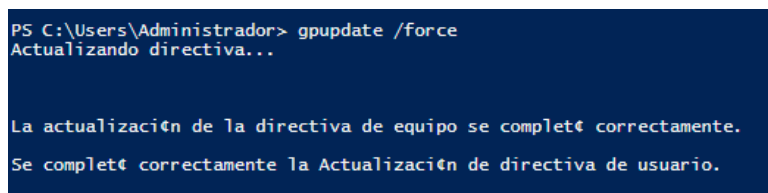


Ilustración 139 - Actualización forzada correcta

Se verifica que los eventos quedan registrados a través del Visor de eventos. Se navega a Registros de Windows → Seguridad. Se pueden observar eventos registrados con diferentes ID. Por ejemplo, eventos con ID 4624 (inicio de sesión exitoso) y 4625 (inicio de sesión fallido).

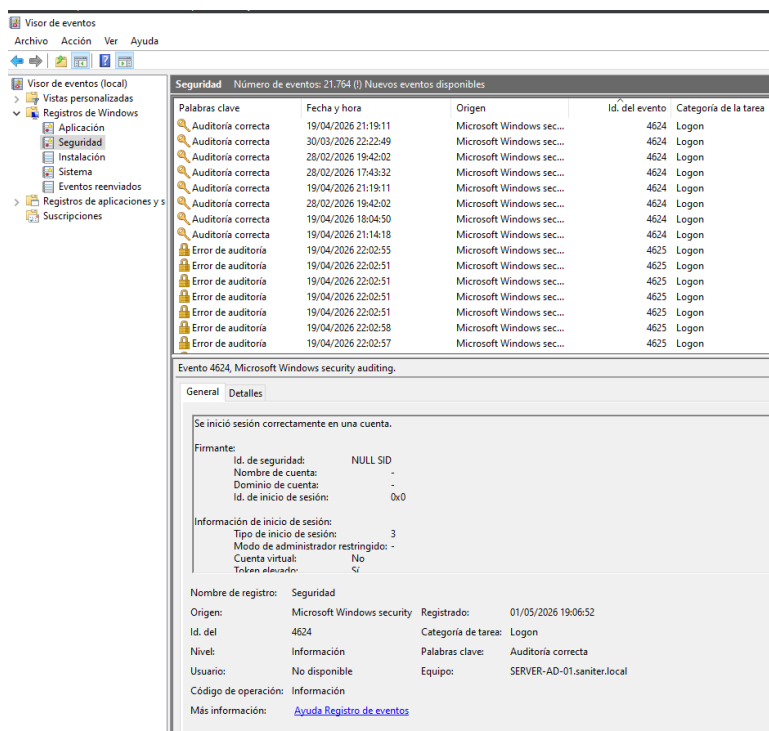


Ilustración 140 - Visor de eventos de Windows

4.5.3.6 Deshabilitación de servicios innecesarios

[mp.s.1] Configuración segura inicial

Es habitual que el Controlador de Dominio tenga varios servicios activos que no son necesarios para su función. Se procede a deshabilitarlos para reducir la superficie de ataque. Se deshabilitan desde la consola de PowerShell, ejecutándola como Administrador.

Los servicios que se desactivan son Print Spooler y Remote Registry.

```
Stop-Service -Name Spooler -Force
Set-Service -Name Spooler -StartupType Disabled

Stop-Service -Name RemoteRegistry -Force
Set-Service -Name RemoteRegistry -StartupType
Disabled

Get-Service Spooler, RemoteRegistry | Select-Object
```

```
PS C:\Users\Administrador> Stop-Service -Name Spooler -Force
PS C:\Users\Administrador> Set-Service -Name Spooler -StartupType Disabled
PS C:\Users\Administrador> Stop-Service -Name RemoteRegistry -Force
PS C:\Users\Administrador> Set-Service -Name RemoteRegistry -StartupType Disabled
PS C:\Users\Administrador> Get-Service Spooler, RemoteRegistry | Select-Object Name, Status, StartType
```

Name	Status	StartType
RemoteRegistry	Stopped	Disabled
Spooler	Stopped	Disabled

Ilustración 141 - Desactivación Print Spooler y Remote Registry

4.5.3.7 Deshabilitación de TCP Timestamps.

[mp.s.1] Configuración segura inicial

Durante la auditoría se detectó una vulnerabilidad de nivel Bajo en relación con los timestamps. Se procede a corregir a través de PowerShell y se verifica la correcta aplicación del cambio.

```
netsh int tcp set global timestamps=disabled

netsh int tcp show global
```

```
PS C:\Users\Administrador> netsh int tcp set global timestamps=disabled
Aceptar
```

```
PS C:\Users\Administrador> netsh int tcp show global
Consultando el estado activo...

Par metros TCP globales
-----
Estado de escalado de lado de recepci n: enabled
Nivel de ajuste autom tico de ventana de recepci n: normal
Proveedor de control de congesti n de complemento: default
Funcionalidad de ECN: enabled
Marcas de hora RFC 1323: disabled
RTO inicial: 1000
Estado de fusi n de segmento de recepci n: enabled
Resistencia RTT sin SACK: disabled
 mero m ximo de retransmisiones SYN: 4
Fast Open: disabled
Reserva Fast Open: enabled
HyStart: enabled
Reducci n de tasa proporcional: enabled
Perfil de velocidad: off
```

Ilustraci n 142 - Deshabilitaci n de TCP Timestamps

4.5.3.8 Restricci n del puerto RPC (135/tcp) - Vulnerabilidad Media

[op.net.1] Segregaci n de redes

La vulnerabilidad Media detectada en la auditor a (DCE/RPC Enumeration, CVSS 5.0) se mitiga restringiendo el acceso al puerto 135 desde la zona WAN. Este paso se hace en OPNsense, no en el propio servidor.

Por ello, se accede a la interfaz web de OPNsense. En el apartado de reglas del Firewall, en el apartado WAN se crea una nueva regla que proteger  el puerto 135 del Directorio Activo desde el exterior.

Ilustración 143 - Edición de regla firewall OPNsense puerto 135

Any Floating	Categories	Inspect	Tree	Search
☐	☐	☐	☐	☐
☐	☐	☐	☐	☐

Ilustración 144 - Regla firewall bloqueo puerto 135

4.5.3.9 Plan de backup - Snapshots

[op.cont.2] Copias de seguridad

Para el servidor Windows, adó que la infraestructura completa está desplegada sobre máquinas virtuales en VirtualBox, la política de copias de seguridad del servidor Windows se implementa mediante instantáneas (snapshots) del hipervisor. Este método permite restaurar el estado completo del servidor en cualquier momento, incluyendo el Directorio Activo, la base de datos NTDS y todas las GPOs configuradas.

Desde la interfaz de VirtualBox se selecciona la VM SERVER-AD-01, y se selecciona en el menú “Máquina” la opción de tomar instantánea. Se le asigna el nombre Post-Hardening Windows Server.

Es importante destacar que, en un entorno de producción real, el backup del estado del sistema de Windows Server se realizaría mediante Windows Server Backup hacia un dispositivo de almacenamiento externo o una carpeta de red dedicada, siguiendo los controles [op.cont.2] y [mp.info.6] del ENS. En este entorno de laboratorio virtualizado, las instantáneas del hipervisor cumplen el mismo propósito de forma equivalente, ya que no ha sido posible configurarlo con Windows Server Backup.

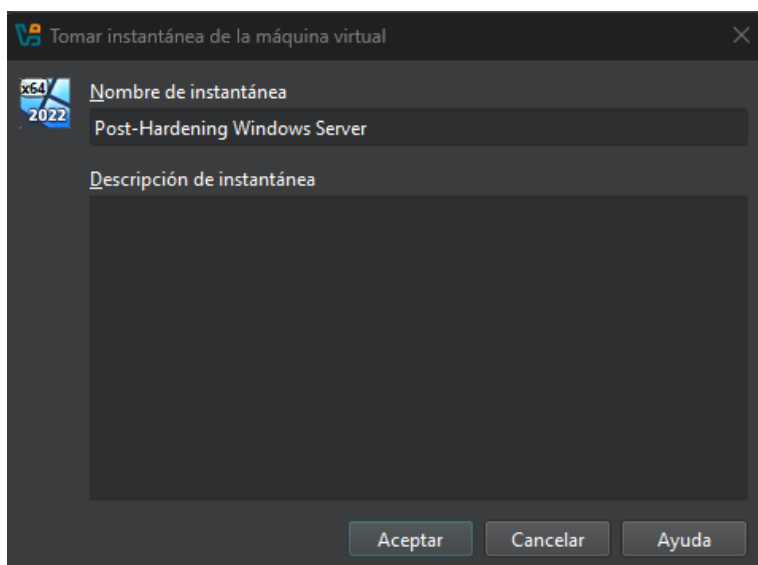


Ilustración 145 - Snapshot Post-Hardening Windows Server

4.6 Post-auditoría y verificación

4.6.1.1 Cambio de IP a la nueva red

El primer paso consiste en cambiar la IP del equipo auditor, para que se encuentre dentro de la nueva red interna creada. Se realiza el cambio en la configuración de red de la máquina virtual cambiando de *Red_saniter_inicial* a *Red_saniter_ENS*.

Dentro del equipo auditor, aplicamos los siguientes comandos para limpiar la dirección IP de la tarjeta de red, añadir la nueva dirección (10.0.0.10), levantar la tarjeta y establecer a OPNsense como el gateway por defecto (10.0.0.1).


```
(kali㉿kali)-[~]
$ sudo ip addr flush dev eth0
[sudo] password for kali:

(kali㉿kali)-[~]
$ sudo ip addr add 10.0.0.10/24 dev eth0

(kali㉿kali)-[~]
$ sudo ip link set eth0 up

(kali㉿kali)-[~]
$ sudo ip route add default via 10.0.0.1
```

Ilustración 146 - Configuración nueva IP en Kali Linux

Se verifica que se ha realizado el cambio correctamente y se comprueba la conectividad con OPNsense y los servidores:

```
(kali㉿kali)-[~]
$ ip a show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:61:5e:9e brd ff:ff:ff:ff:ff:ff
    inet 10.0.0.10/24 brd 10.0.0.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::570f:c1fa:7be5:b8fe/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Ilustración 147 - Comprobación dirección IP

```
(kali㉿kali)-[~]
$ ping -c 4 10.0.0.1
PING 10.0.0.1 (10.0.0.1) 56(84) bytes of data.
64 bytes from 10.0.0.1: icmp_seq=1 ttl=64 time=2.47 ms
64 bytes from 10.0.0.1: icmp_seq=2 ttl=64 time=1.33 ms
64 bytes from 10.0.0.1: icmp_seq=3 ttl=64 time=1.80 ms
64 bytes from 10.0.0.1: icmp_seq=4 ttl=64 time=3.88 ms

— 10.0.0.1 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.330/2.369/3.881/0.962 ms

(kali㉿kali)-[~]
$ ping -c 4 10.0.0.20
PING 10.0.0.20 (10.0.0.20) 56(84) bytes of data.
64 bytes from 10.0.0.20: icmp_seq=1 ttl=128 time=1.24 ms
64 bytes from 10.0.0.20: icmp_seq=2 ttl=128 time=0.748 ms
64 bytes from 10.0.0.20: icmp_seq=3 ttl=128 time=1.04 ms
64 bytes from 10.0.0.20: icmp_seq=4 ttl=128 time=1.58 ms

— 10.0.0.20 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 0.748/1.150/1.575/0.301 ms

(kali㉿kali)-[~]
$ ping -c 4 10.0.0.30
PING 10.0.0.30 (10.0.0.30) 56(84) bytes of data.
64 bytes from 10.0.0.30: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 10.0.0.30: icmp_seq=2 ttl=64 time=1.68 ms
64 bytes from 10.0.0.30: icmp_seq=3 ttl=64 time=1.48 ms
64 bytes from 10.0.0.30: icmp_seq=4 ttl=64 time=1.15 ms

— 10.0.0.30 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 1.121/1.355/1.676/0.231 ms
```

Ilustración 148 - Comprobación conectividad con OPNsense y servidores

Es muy importante hacer permanente la IP, si no al reiniciar ésta se perderá. Se aplica el comando nmcli para fijar la dirección:

```
sudo nmcli con add type ethernet ifname eth0
con-name "red-saniter-ENS" ip4 10.0.0.10/24 gw4
10.0.0.1

sudo nmcli con up "red-saniter-ENS"

ip a show eth0
```

```
(kali@kali)-[~]
$ sudo nmcli con add type ethernet ifname eth0 con-name "red-saniter-ENS" ip4 10.0.0.10/24 gw4 10.0.0.1
Connection 'red-saniter-ENS' (f165bf10-bfd6-4ae3-b7b0-7c9742ad1892) successfully added.

(kali@kali)-[~]
$ sudo nmcli con up "red-saniter-ENS"
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/3)

(kali@kali)-[~]
$ ip a show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:61:5e:9e brd ff:ff:ff:ff:ff:ff
    inet 10.0.0.10/24 brd 10.0.0.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::570f:c1fa:7be5:b8fe/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Ilustración 149 - Fijación de dirección IP

4.6.1.2 Post-auditoría Directorio Activo

4.6.1.2.1 Configuración del escaneo

En este apartado no se muestra el paso a paso de la configuración, ya que es el mismo que se ha seguido en el apartado 4.4.1.1 del documento, siendo la única diferencia las direcciones IP del target y del equipo auditor.

Tabla 28 - Configuración del escaneo de post-auditoria de Windows Server

Parámetro	Valor
Nombre del target	SERVER-AD-01 (Autenticado) - POST
IP escaneada	10.0.0.20
IP del equipo auditor	10.0.0.10 (Kali Linux)
Tipo de escaneo	Autenticado (credenciales SMB - usuario svc-openvas)

Perfil de escaneo	Full and Fast
Total resultados sin filtro	27
Resultados confirmados (QoD $\geq$ 70%)	1
Errores durante el escaneo*	3(NVT timeouts, no afectan a la validez del informe)

Nota: La autenticación SSH registró un fallo (Auth-SSH-Failure) porque Windows Server no dispone de servicio SSH nativo. El escaneo procedió mediante SMB/WMI, que es el método correcto para Windows. Los 3 errores son NVT timeouts de pruebas de larga duración (SMB Brute Force, Shellshock y HTTP Directory Traversal) y no invalidan el resultado global.

4.6.1.2.2 Sistema operativo y puertos detectados

OpenVAS detectó correctamente el sistema operativo del servidor y los 12 puertos TCP abiertos, todos ellos correspondientes a servicios propios de un Controlador de Dominio Active Directory, sin variaciones respecto a la pre-auditoría:

Tabla 29 - SO y puertos detectados en post-auditoría AD

Elemento detectado	Valor
Sistema Operativo	Microsoft Windows (cpe:/o:microsoft:windows)
Puertos TCP abiertos	88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269, 5985, 9389

4.6.1.2.3 Vulnerabilidades confirmadas (QoD $\geq 70\%$)

Tabla 30 - Vulnerabilidades detectadas post-auditoria AD

Severidad	Puerto	Vulnerabilidad	Estado tras bastionado
Media CVSS 5.0	135/tcp	DCE/RPC and MSRPC Services Enumeration. El puerto 135 permite enumerar los servicios RPC activos del servidor.	PERSISTE- Mitigado por regla de OPNsense que bloquea el acceso al puerto 135 desde zona WAN. El puerto sigue abierto en la LAN interna por necesidad funcional del DC.

Nota: La vulnerabilidad DCE/RPC (CVSS 5.0) persiste en el interior de la LAN porque es necesaria para el funcionamiento del Directorio Activo. La medida de mitigación aplicada (regla de bloqueo en OPNsense para tráfico WAN→135) es la correcta según la medida prevista en la pre-auditoría. Desde el exterior, el puerto no es accesible.

4.6.1.3 Post-auditoría Ubuntu Server

4.6.1.3.1 Configuración del escaneo

En este apartado no se muestra el paso a paso de la configuración, ya que es el mismo que se ha seguido en el apartado 4.4.1.1 del documento, siendo la única diferencia las direcciones IP del target y del equipo auditor.

Tabla 31 - Configuración del escaneo de post-auditoria de Ubuntu Server

Parámetro	Valor
Nombre del target	UbuntuServer Authenticated - POST
IP escaneada	10.0.0.30
IP del equipo auditor	10.0.0.10
Tipo de escaneo	Autenticado (credenciales SSH)

Perfil de escaneo	Full and Fast
Total resultados sin filtro	207 (incluyendo logs informativos)
Resultados confirmados (QoD $\geq$ 70%)	2

Nota: Al igual que en la auditoría inicial, OpenVAS ejecuta los checks internamente una vez autenticado por SSH, por lo que en el informe aparece 127.0.0.1 como host. El tráfico de auditoría sí se originó desde Kali (10.0.0.10) hacia Ubuntu (10.0.0.30). Este comportamiento es el esperado en escaneos SSH autenticados.

4.6.1.3.2 Sistema operativo y puertos detectados

Gracias a la autenticación SSH, OpenVAS obtuvo acceso completo al sistema. Los cambios en los puertos visibles respecto a la pre-auditoría son relevantes:

Tabla 32 - Puertos detectados en post-auditoría Ubuntu Server

Puerto	Servicio	Estado en post-auditoría	Observación
2222/tcp	SSH OpenSSH	Activo (nuevo puerto)	Puerto cambiado de 22 a 2222 durante el bastionado. Configurado en sshd_config.
80/tcp	HTTP Apache	Activo	Servicio web mantiene el puerto 80. Sin HTTPS (fuera del alcance del proyecto).

4.6.1.3.3 Vulnerabilidades confirmadas (QoD $\geq 70\%$)

Tabla 33- Vulnerabilidades detectadas en post-auditoría Ubuntu Server

Severidad	Puerto	Vulnerabilidad	CVE	Estado tras bastionado
Media CVSS 5.5	general/ tcp	Missing Linux Kernel mitigations for 'SSB - Speculative Store Bypass'. Vulnerabilidad de hardware del procesador físico del host.	CVE-2018-3639	Persiste - Esperado y documentado. Es una limitación de hardware del equipo anfitrión, no tratable desde el SO virtualizado. Se documenta como hallazgo fuera del alcance.
Media CVSS 4.8	80/tcp	Cleartext Transmission of Sensitive Information via HTTP. phpMyAdmin accesible sin cifrado TLS.	-	Persiste - La implementación de HTTPS quedó fuera del alcance del proyecto por limitaciones de tiempo. Se documenta como mejora futura prioritaria.

4.6.1.4 Comparativa auditoría inicial vs auditoría final – Windows Server

La siguiente tabla muestra la comparativa de los resultados obtenidos en cada una de las auditorías.

Tabla 34 - Comparativa resultados auditorías AD

Parámetro	Pre-auditoría	Post-auditoría	Resultado
IP del target	172.16.0.100 red_saniter_inicial	10.0.0.20 red_saniter_ENS	Red migrada a OPNsense
Duración del escaneo	2 horas 41 minutos	1 hora 25 minutos	Reducción del tiempo
Errores (NVT timeouts)	23	3	Reducción notable
Resultados totales sin filtro	29	27	Estable
Vulnerabilidades Críticas	0	0	Sin cambio
Vulnerabilidades Altas	0	0	Sin cambio
Vulnerabilidades Medias (QoD≥70)	1 (DCE/RPC, CVSS 5.0)	1 (DCE/RPC, CVSS 5.0)	Persiste, pero es mitigada por OPNsense
Vulnerabilidades Bajas (QoD≥70)	1 (TCP Timestamps, CVSS 2.6)	0	Corregida
Severidad máxima confirmada	5.0 (Media)	5.0 (Media)	Estable, riesgo controlado
Puerto 135 accesible desde WAN	Sí (sin restricción)	No (bloqueado por OPNsense)	Mitigado

El bastionado del Directorio Activo ha sido efectivo. La única vulnerabilidad media que persiste (DCE/RPC en puerto 135) es inherente a la función del Controlador de Dominio y ha sido mitigada mediante filtrado perimetral en OPNsense. La vulnerabilidad baja de TCP Timestamps ha sido completamente

eliminada. El servidor Windows se encuentra en un estado de seguridad aceptable para la Categoría MEDIA del ENS.

4.6.1.5 Comparativa auditoria inicial vs auditoría final – Ubuntu Server

La siguiente tabla muestra la comparativa de los resultados obtenidos en cada una de las auditorías.

Tabla 35 - Comparativa resultados auditorías Ubuntu Server

Parámetro	Pre-auditoría	Post-auditoría	Resultado
IP del target	172.16.0.140 red_saniter_inicial	10.0.0.30 red_saniter_ENS	Red migrada a OPNsense
Duración del escaneo	~25 min (aprox.)	19 minutos	Reducción
Errores durante el escaneo	0	0	Sin errores
Resultados totales sin filtro	261	207	Reducción significativa
Vulnerabilidades Críticas	0	0	Sin cambio
Vulnerabilidades Altas	0	0	Sin cambio
Vulnerabilidades Medias (QoD≥70)	2 (SSB + HTTP cleartext)	2 (SSB + HTTP cleartext)	Persisten, pero justificadas
Vulnerabilidades Bajas (QoD≥70)	3 (TCP Timestamps, Weak MAC SSH, ICMP)	0	Corregidas las 3 vulnerabilidades
Puerto 3306 (MariaDB) visible	Sí, accesible desde red	No, bind-address = 127.0.0.1	Corregido
Puerto SSH	22/tcp	2222/tcp	Puerto cambiado

Parámetro	Pre-auditoría	Post-auditoría	Resultado
Algoritmos MAC SSH débiles	Presentes (MD5, 96-bit)	Eliminados	Corregido
TCP Timestamps	Habilitados	Deshabilitados	Corregido
ICMP Timestamp Reply	Habilitado	Deshabilitado	Corregido
Severidad máxima confirmada	5.5 (CVE-2018-3639, hardware)	5.5 (CVE-2018-3639, hardware)	Sin cambio, fuera de alcance

El bastionado de Ubuntu Server ha sido altamente efectivo. De las 5 vulnerabilidades iniciales, 3 han sido completamente eliminadas (100% de las vulnerabilidades bajas). Las 2 vulnerabilidades medias que persisten están justificadas: CVE-2018-3639 es una limitación de hardware del equipo anfitrión y no tiene solución en el entorno virtualizado. La transmisión HTTP sin TLS queda como mejora futura por límites de alcance del proyecto. La eliminación del puerto 3306 de la red representa una mejora de seguridad muy significativa para la protección de la base de datos.

5 Tecnologías

La siguiente tabla recoge las soluciones tecnológicas empleadas., organizadas jerárquicamente desde la infraestructura base hasta las herramientas de auditoría.

Tabla 36 - Soluciones tecnológicas empleadas en el proyecto

	Oracle VM VirtualBox: Software de virtualización de código abierto. <u>Uso en el proyecto:</u> Hipervisor elegido para el despliegue del entorno virtualizado. Versión utilizada: Versión 7.1.0
	OPNsense: Plataforma de enrutamiento y cortafuegos de código abierto. <u>Uso en el proyecto:</u> Seguridad Perimetral. Actúa como firewall y como router. Inspecciona y filtra el tráfico, además de crear y gestionar la segmentación de la red. Versión utilizada: Versión 26.1
	Windows Server 2022: Sistema operativo que actúa como plataforma de servidor empresarial de Microsoft. Gestiona redes, aplicaciones y servicios. <u>Uso en el proyecto:</u> Controlador de Dominio. Gestiona de manera centralizada las identidades y la aplicación de políticas de grupo (GPOs). Versión utilizada: Versión 21H2 (compilación SO 20348.587)

 PowerShell	PowerShell: Lenguaje de scripting y consola de comandos de Microsoft. <u>Uso en el proyecto:</u> Automatización del despliegue de la estructura de Active Directory. Versión: Versión 5.1.20348 (Revisión 558)
	Ubuntu Server: Sistema operativo con infraestructura de servidor. <u>Uso en el proyecto:</u> Servidor web. Aloja el servicio Web y la base de datos de la organización Versión utilizada: Ubuntu 22.04.5 LTS
	Apache HTTP Server: Software de servidor web de código abierto. <u>Uso en el proyecto:</u> Servidor web donde se alojará la web y la interfaz de administración de la base de datos. Gestión de peticiones HTTP. Versión utilizada: Apache 2.4.52
	MariaDB: Sistema gestor de base de datos relacionales de código abierto. <u>Uso en el proyecto:</u> Sistema gestor de la base de datos de la empresa. Versión utilizada: MariaDB 15.1 Distribución 10.6.23
	PHP: Lenguaje de programación para desarrollo web backend de código abierto <u>Uso en el proyecto:</u> Motor que conecta la interfaz web con la base de datos. Versión utilizada: PHP 8.1.2

	phpMyAdmin: Herramienta con interfaz gráfica para administración de bases de datos. Basada en PHP y de código abierto. <u>Uso en el proyecto:</u> Interfaz para la gestión operativa del inventario por parte del personal. Versión utilizada: phpMyAdmin 5.1.1
	Kali Linux: Sistema operativo, distribución de Linux basada en Debian <u>Uso en el proyecto:</u> Equipo auditor. Estación de trabajo equipada con Greenbone (OpenVAS). Es la responsable de realizar el escaneo de vulnerabilidades de la infraestructura. Versión utilizada: 2025.4
	OpenVAS: Escáner de vulnerabilidades. <u>Uso en el proyecto:</u> Herramienta empleada para realizar las auditorías. Escaneo de seguridad perimetral e interno. Versión utilizada: gvm-cli 25.4.5 (API versión 26.9.1)

6 Metodología

Para organizar el trabajo se ha seguido el ciclo PDCA, también llamado Ciclo de Deming. Se emplea esta metodología porque el proyecto tiene dos momentos bien diferenciados: un estado inicial inseguro y un estado final mejorado, y se necesita una forma de estructurar ese proceso que permita comparar los dos puntos y demostrar que los cambios han funcionado. El PDCA encaja bien con esto: parte de un diagnóstico real, actúa sobre él, y luego verifica los resultados. Si se hubiera seguido un enfoque lineal, la post-auditoría final quedaría como un paso más en lugar de ser la prueba de que el ciclo se ha cerrado correctamente.

Las cuatro fases del ciclo aplicadas al proyecto quedan así:

- Plan: analizar la situación de Saniter, identificar qué activos hay, qué riesgos tienen y qué controles del ENS hay que aplicar.
- Do: montar la infraestructura, hacer la auditoría inicial y aplicar el bastionado.
- Check: volver a auditar con OpenVAS para ver si las medidas han reducido las vulnerabilidades.
- Act: documentar los resultados, identificar lo que queda por mejorar y cerrar el proyecto.

Este enfoque encaja además con lo que pide el ENS en sus artículos 7 y 10: gestionar la seguridad basándose en riesgos reales, y mantener un ciclo continuo de prevención, detección y respuesta.

PROMETEO

6.1 Planificación

El proyecto se ha desarrollado a lo largo de aproximadamente 10 semanas, compaginando el trabajo técnico con la redacción de la memoria. A continuación, se muestra la tabla de plan de trabajo con las horas reales estimadas por tarea. Los valores se han calculado teniendo en cuenta el tiempo real de configuración, las incidencias registradas durante el proyecto (re-escaneos, reconfiguración de red, migración de IPs) y el tiempo de documentación de cada apartado:

Tabla 37 - Plan de trabajo

ID	Tarea	Fase PDCA	Duración Prevista	Duración Real
01	Estudio normativo ENS + análisis de riesgos (MAGERIT)	Plan	4 h	5 h
02	Diseño de la arquitectura de red y selección de controles	Plan	3 h	3 h
03	Instalación y configuración VM Windows Server 2022 + AD DS	Do	5 h	5 h
04	Instalación y configuración VM Ubuntu Server + stack LAMP	Do	4 h	5 h
05	Instalación y configuración VM Kali Linux + OpenVAS	Do	3 h	4 h
06	Instalación y configuración VM OPNsense + reglas firewall	Do	4 h	5 h
07	Migración de red (172.16.0.0 → 10.0.0.0) todos los servidores	Do	2 h	3 h
08	Auditoría inicial Ubuntu Server (configuración + escaneo + análisis)	Check	3 h	4 h
09	Auditoría inicial Windows Server (configuración + escaneo + análisis)	Check	3 h	5 h

PROMETEO

ID	Tarea	Fase PDCA	Duración Prevista	Duración Real
10	Bastionado Ubuntu Server (SSH, MariaDB, Apache, sysctl, logs, backup)	Do	4 h	6 h
11	Bastionado Windows Server (IP, UOs, GPOs, servicios, TCP timestamps)	Do	4 h	5 h
12	Post-auditoría Ubuntu Server + análisis comparativo	Check	2 h	3 h
13	Post-auditoría Windows Server + análisis comparativo	Check	2 h	3 h
14	Redacción memoria TFG (todos los apartados)	Act	18 h	22 h
15	Revisión y corrección del borrador, formato, índices	Act	3 h	4 h
16	Repositorio GitHub: organización, README, scripts	Act	2 h	2 h
	TOTAL		66 h	83 h

6.2 Diagrama de Gantt

Se muestra el diagrama de Gantt inicial, con la planificación prevista y el diagrama de Gantt final con la planificación final. El diagrama de Gantt final refleja la planificación real del proyecto una vez concluido, incluyendo las desviaciones respecto al plan inicial. Se muestran las 10 semanas de desarrollo distribuidas por fases PDCA:

PROMETEO

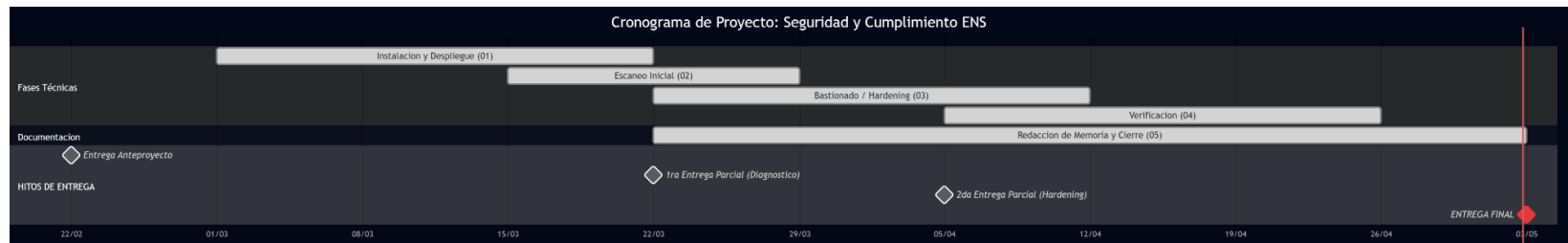


Ilustración 150 - Diagrama de Gantt con planificación inicial



Ilustración 151 - Diagrama de Gantt con planificación final

Las principales diferencias respecto al diagrama de Gantt inicial son:

- La fase de OPNsense y migración de red se extendió a dos semanas (previsto: una) debido a los ajustes necesarios en la configuración de las interfaces y la reconexión de los servidores.
- La auditoría inicial de Windows requirió más tiempo por la necesidad de configurar múltiples veces las credenciales SMB y los permisos WMI.
- La redacción de la memoria comenzó antes de lo previsto (semana 3) pero también se extendió más allá de la fecha inicial por la mayor profundidad de los apartados de bastionado y post-auditoría.

6.3 Presupuesto

El presupuesto del proyecto se ha dividido en diferentes apartados para facilitar su comprensión. Se pretende cuantificar el coste real aproximado que supondría a una empresa especializada en adecuación al Esquema Nacional de Seguridad (ENS) llevar a cabo este proceso en una empresa como Saniter.

Las categorías elegidas han sido: Recursos humanos, infraestructura de hardware y software y licencias. Dado que se ha optado por la utilización de soluciones de código abierto, no existirá coste alguno en el apartado de software y licencias.

Es importante destacar los criterios que se han seguido para la elaboración del presupuesto:

- Gastos de personal: rangos salariales publicados por el Observatorio de las Ocupaciones del Servicio Público de Empleo Estatal (SEPE) para el sector de las Tecnologías de la Información y la Comunicación en España (2024–2025).
- Infraestructura de hardware: Se ha incluido el coste proporcional del hardware durante el tiempo de duración del proyecto, no se aplica el coste total.

6.3.1 Gastos de personal

Tabla 38 - Gastos de personal

Perfil profesional	Horas	Precio/hora	Total
Gerente de proyecto (planificación y ENS)	15 h	45,00 €	675,00 €
Administrador de sistemas (instalación y bastionado)	55 h	25,00 €	1.375,00 €
Auditor de seguridad (escaneos y verificación)	25 h	35,00 €	875,00 €
SUBTOTAL PERSONAL	95 h		2.925,00 €

6.3.2 Infraestructura de hardware

Tabla 39 - Gasto infraestructura de hardware

Concepto	Valor adquisición	Vida útil	Amortización (3 meses)
Servidor host (CPU 8C/16T, 32 GB RAM, 1 TB SSD)	1.200,00 €	36 meses	100,00 €
Periféricos y red	200,00 €	24 meses	25,00 €
SUBTOTAL HARDWARE			125,00 €

6.3.3 Software y licencias

Tabla 40 - Gasto de software y licencias

Software	Tipo de licencia	Coste
Windows Server 2022	Evaluación (180 días)	0,00 €
Ubuntu Server 22.04 LTS	Open Source (GPL)	0,00 €
Kali Linux / OpenVAS	Open Source (GPL)	0,00 €
Oracle VM VirtualBox	Open Source (uso personal)	0,00 €
OPNsense	Open Source (BSD)	0,00 €
SUBTOTAL SOFTWARE		0,00 €

6.3.4 Resumen del presupuesto total

Tabla 41 - Presupuesto total

Categoría	Importe
Recursos humanos	2.925,00 €
Hardware (amortización)	125,00 €
Software y licencias	0,00 €
Gastos indirectos (electricidad, conectividad)	75,00 €
TOTAL (Base imponible)	3.125,00 €
IVA (21%)	656,25 €
PRECIO FINAL DEL PROYECTO	3.781,25 €

6.4 Readme y GIT

El repositorio público del proyecto está disponible en:
<https://github.com/lidiagdcso/saniter-ens>

El repositorio GitHub complementa la memoria del TFG con todos los artefactos técnicos del proyecto: scripts utilizados, configuraciones de referencia y evidencias de las auditorías. Su objetivo es permitir que cualquier organización en una situación similar a Saniter pueda reproducir el proceso de adecuación al ENS.

6.4.1 Estructura del repositorio

Tabla 42 - Estructura repositorio GIT

Carpeta / Archivo	Contenido	Descripción
README.md	Raíz del repositorio	Descripción general del proyecto, arquitectura, requisitos y guía de uso
docs/	Documentación	Memoria del TFG en PDF (entrega final)
scripts/ubuntu/	Scripts Ubuntu	Todos los scripts de configuración y bastionado del servidor Ubuntu
scripts/ubuntu/backup_saniter.sh	Script backup	Script de copia de seguridad automatizada de la base de datos
Scripts/Ubuntu/index.html	Index.html	HTML de la página web
scripts/windows/	Scripts Windows	Scripts PowerShell para AD, GPOs y bastionado del DC
scripts/windows/crear_usuarios_inicial.ps1	Script usuarios inicial	Creación de usuarios en el escenario inseguro inicial
scripts/windows/crear_ous_y_mover_usuarios.ps1	Script UOs	Reorganización del AD en Unidades Organizativas

Carpeta / Archivo	Contenido	Descripción
scripts/windows/bastionado_windows.ps1	Script bastionado	Deshabilitar servicios innecesarios + TCP timestamps
config/sshd_config_bastionado	Config SSH	Archivo sshd_config con las directivas de bastionado aplicadas
config/sysctl_ens.conf	Config kernel	Directivas de sysctl para deshabilitar TCP timestamps e ICMP
config/ufw_rules.sh	Reglas UFW	Secuencia de comandos UFW aplicada en el bastionado de Ubuntu
config/opnsense_firewall_rules.md	Reglas OPNsense	Tabla de reglas de firewall configuradas en OPNsense
auditorias/pre/	Auditorías pre-bastionado	Informes OpenVAS XML de las auditorías iniciales
auditorias/post/	Auditorías post-bastionado	Informes OpenVAS XML de las auditorías post-bastionado
.gitignore	Raíz	Excluye archivos sensibles: contraseñas, claves privadas, snapshots

6.4.2 Contenido del README.md

saniter-ens

Proyecto TFG – Adecuación al ENS Categoría MEDIA

Adecuación al ENS Categoría MEDIA – Saniter

****TFG – ASIR Online**** | Lidia Gallardo Díaz-Cacho | Tutor:
Daniel Espinosa | 2026

Descripción

Proyecto de adecuación de la infraestructura de Saniter (PYME sector sanidad ambiental)

al Esquema Nacional de Seguridad (ENS) Categoría MEDIA, según el RD 311/2022.

Infraestructura virtualizada en VirtualBox siguiendo el ciclo PDCA.

Infraestructura

Máquina	SO	IP (ENS)	Rol
-----	-----	-----	-----
SERVER-AD-01	Windows Server 2022	10.0.0.20	Controlador de Dominio
Ubuntu Server	Ubuntu 22.04 LTS	10.0.0.30	Web + BBDD
Kali Linux	Kali 2025.4	10.0.0.10	Auditor (OpenVAS)
OPNsense	OPNsense 26.1	10.0.0.1	Firewall perimetral

Estructura del repositorio

saniter-ens/

├─ README.md	# Este archivo
├─ .gitignore	# Exclusiones de seguridad
├─ docs/	# Memoria del TFG (PDF)
├─ scripts/	
│ └─ ubuntu/	# Scripts de bastionado Ubuntu

```
|   └─ windows/                # Scripts PowerShell Windows
└─ config/                     # Configuraciones de referencia
└─ auditorias/
    └─ pre/                    # Informes XML pre-bastionado
        └─ post/               # Informes XML post-bastionado
...
---
```

Controles ENS implementados

Código	Medida	
Implementación		
-----	-----	-----

[op.pl.1]	Análisis de riesgos	MAGERIT v3 –
\$4.1.4		
[op.acc.1]	Identificación única	AD + MariaDB
usuarios por rol		
[op.acc.2]	Mínimo privilegio	GPOs + permisos
BBDD		
[op.acc.4]	Autenticación robusta	GPO contraseñas +
SSH hardening		
[op.net.1]	Segregación de redes	OPNsense WAN/LAN
+ UFW		
[op.vig.1]	Detección de deficiencias	OpenVAS pre y
post bastionado		
[mp.com.1]	Perímetro seguro	OPNsense firewall
+ reglas		
[mp.s.1]	Configuración segura inicial	Hardening Ubuntu
y Windows		
[op.cont.2]	Copias de seguridad	mysqldump +
snapshots VirtualBox		

Resultados de las auditorías

Servidor	Vulns. pre	Vulns. post	Reducción	
-----	-----	-----	-----	
Ubuntu Server	5	2	60%	
Windows Server	2	1	50%	

Licencia

Proyecto académico. Uso libre para fines educativos con atribución.

7 Trabajos futuros

Llegar a la Categoría MEDIA del ENS era el principal objetivo, pero no el último, siguiendo la metodología o mentalidad de mejora continua se deben seguir planteando nuevos objetivos. Hay varios pasos que se han dejado fuera del alcance de este proyecto por tiempo o complejidad, y que serían los siguientes pasos lógicos.

Lo primero y más urgente sería separar el servidor web de la base de datos en dos máquinas virtuales distintas. Ahora mismo están juntas en HW-01, y eso hace que, si el servidor web se ve comprometido, el atacante tiene la base de datos al lado. Separarlas reduce mucho ese riesgo.

También falta cifrar las comunicaciones internas. Las conexiones entre el servidor web y la base de datos, y entre los clientes y el Directorio Activo, van sin cifrar dentro de la LAN. Con OPNsense ya se ha mejorado el perímetro externo, pero dentro de la red todavía hay margen de mejora.

Se deberá realizar la segmentación interna mediante VLANs independientes para el servidor web y el Directorio Activo, reduciendo el radio de acción ante un posible compromiso de uno de ellos.

A más largo plazo, sería interesante instalar un SIEM como Wazuh para centralizar todos los logs y tener una visión global de lo que está pasando

en la red en tiempo real. Ahora mismo los logs están repartidos entre el Visor de Sucesos de Windows y /var/log en Ubuntu, lo que hace difícil detectar un incidente si no estás mirando en el sitio correcto.

Por último, una vez que el sistema esté estabilizado y se hayan aplicado todas estas mejoras, tendría sentido analizar si algún activo podría justificar escalar a Categoría ALTA del ENS.

8 Conclusiones

Este proyecto ha demostrado que es posible conseguir que una PYME del sector de la sanidad ambiental cumpla con los requisitos técnicos de la Categoría MEDIA del Esquema Nacional de Seguridad mediante tecnologías de código abierto, sin coste de licencias y con recursos de hardware modestos. El punto de partida era una infraestructura funcional pero insegura: sin limitación de permisos, credenciales compartidas, servicios expuestos y sin ningún mecanismo de auditoría ni trazabilidad. El punto final del proyecto es un entorno seguro, con un bastionado que ha resuelto los problemas previos.

El ciclo PDCA ha sido el hilo conductor de todo el trabajo. La fase de planificación (análisis de riesgos con MAGERIT y categorización del sistema) sentó las bases técnicas y normativas; la fase de ejecución (despliegue e implementación de los controles) materializó las medidas; la fase de verificación (auditorías con OpenVAS) demostró con datos objetivos la reducción de la superficie de ataque; y la fase de actuación (documentación y trabajos futuros) cierra el ciclo y sienta las bases para la mejora continua.

8.1 Resultados objetivos obtenidos

Tabla 43 - Resultados obtenidos

Indicador	Estado inicial	Estado final	Mejora
Vulnerabilidades Ubuntu (QoD $\geq$ 70)	5 (2 medias, 3 bajas)	2 (2 medias, 0 bajas)	Reducción del 60%
Vulnerabilidades Windows (QoD $\geq$ 70)	2 (1 media, 1 baja)	1 (1 media, 0 bajas)	Reducción del 50%
Puerto 3306 (MariaDB) expuesto	Sí, accesible desde red	No, accesible solo localhost	Eliminado
Puerto 135 (RPC) accesible WAN	Sí, sin filtrado	No, bloqueado OPNsense	Mitigado
Algoritmos MAC débiles SSH	Presentes	Eliminados	Corregido
TCP Timestamps (Ubuntu + Windows)	Habilitados en ambos	Deshabilitados en ambos	Corregido
ICMP Timestamp Reply (Ubuntu)	Habilitado	Deshabilitado	Corregido
Puerto SSH	22 (estándar, expuesto)	2222 (no estándar)	Mejorado
Credenciales compartidas BD	Un usuario con acceso total desde cualquier IP	Usuarios por rol con mínimo privilegio	Corregido
Segmentación de red	Red plana 172.16.0.0/24	WAN/LAN con OPNsense (10.0.0.0/24)	Implementada
Política de contraseñas AD	Sin política (contraseña nunca expira)	GPO: complejidad + 90 días + bloqueo	Implementada
Auditoría de eventos (trazabilidad)	Sin configuración	GPO + auth.log + retención 90 días	Implementada
Copias de seguridad automatizadas	Sin backup	mysqldump diario 2:00AM + snapshots VMs	Implementado

8.2 Vulnerabilidades resueltas y no resueltas

Vulnerabilidades resueltas:

- TCP Timestamps en ambos servidores (Ubuntu y Windows): eliminados completamente.
- Algoritmos MAC débiles en SSH de Ubuntu: eliminados restringiendo la lista en sshd_config.
- ICMP Timestamp Reply en Ubuntu: eliminado mediante configuración de kernel.
- Puerto 3306 de MariaDB expuesto en red: eliminado restringiendo bind-address a localhost.
- Puerto 135 (RPC) accesible desde WAN: mitigado mediante regla de bloqueo en OPNsense.
- Credenciales compartidas en base de datos: corregido con usuarios específicos por rol.
- Ausencia de política de contraseñas: corregida con GPO en el dominio saniter.local.

Vulnerabilidades no resueltas (justificadas):

- CVE-2018-3639 (Speculative Store Bypass, CVSS 5.5): limitación del hardware del procesador físico del equipo anfitrión. Su mitigación requiere actualización del microcódigo del procesador del host, algo que queda fuera del alcance de este proyecto.
- Transmisión HTTP sin TLS en phpMyAdmin (CVSS 4.8): la implementación de HTTPS con certificado válido requería infraestructura de PKI o un dominio público, que quedaron fuera del alcance por limitaciones de tiempo y entorno de laboratorio. Se ha identificado como mejora futura prioritaria.

8.3 Resumen de controles ENS aplicados

Tabla 44 - Controles ENS aplicados

Código ENS	Medida Anexo II - RD 311/2022	Apartado donde se implementa
[op.pl.1]	Análisis de riesgos	4.1.4 Análisis de riesgos
[op.exp.1]	Inventario de activos	4.1.1 Identificación de activos críticos
[op.acc.1]	Identificación de usuarios de forma única	4.5.2.4 Bastionado MariaDB 4.5.3.2 Reorganización AD
[op.acc.2]	Gestión de privilegios: mínimo privilegio	4.5.2.4 Bastionado MariaDB 4.5.3.2 Reorganización AD 4.5.3.4 GPO Mínimo privilegio
[op.acc.4]	Autenticación: contraseñas robustas	4.5.3.3 GPO Política de contraseñas 4.5.2.3 SSH bastionado
[op.exp.8]	Registro de actividad: logs del sistema	4.5.2.7 Configuración de logs 4.5.3.5 GPO Auditoría de eventos
[op.mon.1]	Detección de intrusiones	4.5.2.7 Configuración de logs 4.5.3.5 GPO Auditoría de eventos
[op.vig.1]	Detección de deficiencias: escaneos de vulnerabilidades	4.4 Auditoría inicial 4.6 Post-auditoría y verificación
[op.net.1]	Segregación de redes	4.5.1.6 OPNsense - reglas de firewall 4.5.2.2 UFW Ubuntu
[op.cont.2]	Continuidad: copias de seguridad	4.5.2.8 Plan de backup Ubuntu 4.5.3.9 Snapshots VirtualBox
[mp.s.1]	Configuración segura inicial (hardening)	4.5.2.5 Configuración Apache 4.5.3.7 Deshabilitar TCP Timestamps 4.5.2.4.3 mysql_secure_installation 4.5.3.6 Deshabilitación servicios Windows

Código ENS	Medida Anexo II - RD 311/2022	Apartado donde se implementa
[mp.com.1]	Perímetro seguro	4.5.1 OPNsense - instalación y configuración 4.5.2.2 UFW Ubuntu
[mp.info.6]	Protección de la información: copias de seguridad	4.5.2.8 Plan de backup - mysqldump automatizado

En total, el proyecto ha cubierto 13 controles del Anexo II del RD 311/2022 aplicables a la Categoría MEDIA. La implantación de OPNsense como firewall perimetral ha sido el elemento con mayor impacto en la reducción del riesgo, al proporcionar simultáneamente la segregación de red ([op.net.1]), el perímetro seguro ([mp.com.1]) y la base para el filtrado de vulnerabilidades expuestas al exterior. El análisis comparativo de las auditorías pre y post bastionado valida que el sistema ha alcanzado el nivel de seguridad requerido para la Categoría MEDIA del ENS.

9. Referencias

1. **Apache Software Foundation. (2024).** Apache HTTP Server Documentation (versión 2.4). <https://httpd.apache.org/docs/2.4/>
2. **Canonical Ltd. (2024).** Ubuntu Server Documentation. <https://ubuntu.com/server/docs>
3. **Centro Criptológico Nacional. (2022a).** Guía CCN-STIC 801: Responsabilidades y funciones en el ENS. Centro Criptológico Nacional. <https://www.ccn-cert.cni.es/>
4. **Centro Criptológico Nacional. (2022b).** Guía CCN-STIC 802: Guía de aplicación del ENS en Entidades Locales. Centro Criptológico Nacional. <https://www.ccn-cert.cni.es/>
5. **Centro Criptológico Nacional. (2022c).** Guía CCN-STIC 816: Seguridad en Active Directory. Centro Criptológico Nacional. <https://www.ccn-cert.cni.es/>
6. **España. (2010).** Real Decreto 830/2010, de 25 de junio, por el que se establece la normativa reguladora de la capacitación para realizar tratamientos con biocidas. Boletín Oficial del Estado, (170). <https://www.boe.es/eli/es/rd/2010/06/25/830>
7. **España. (2022).** Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad. Boletín Oficial del Estado, (106). <https://www.boe.es/eli/es/rd/2022/05/03/311>
8. **Greenbone AG. (2024).** Greenbone Vulnerability Manager (GVM) Documentation. Greenbone Documentation. <https://docs.greenbone.net/>
9. **Greenbone AG. (2024).** Keeping the Feed Up-to-Date. Greenbone Documentation. <https://docs.greenbone.net/GSM-Manual/read/en/managing-the-feed.html>

10. **MariaDB Foundation. (2024).** MariaDB Server Documentation.
<https://mariadb.com/kb/en/documentation/>

11. **Microsoft. (2024a).** Información general sobre Servicios de dominio de Active Directory. Microsoft Learn. <https://learn.microsoft.com/es-es/windows-server/identity/ad-ds/get-started/ad-ds-overview>

12. **Microsoft. (2024b).** Módulo ActiveDirectory para PowerShell. Microsoft Learn. <https://learn.microsoft.com/es-es/powershell/module/activedirectory/>

13. **Microsoft. (2024c).** Módulo NetTCPIP para la gestión de interfaces de red. Microsoft Learn. <https://learn.microsoft.com/en-us/powershell/module/nettcpip/>

14. **Microsoft. (2024d).** Procedimientos recomendados para proteger Active Directory. Microsoft Learn. <https://learn.microsoft.com/es-es/windows-server/identity/ad-ds/plan/security-best-practices/best-practices-for-securing-active-directory>

15. **Ministerio de Hacienda y Administraciones Públicas. (2012).** MAGERIT v3. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: El Método. Secretaría General Técnica.
https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html

16. **MITRE Corporation. (2018).** CVE-2018-3639: Speculative Store Bypass. National Vulnerability Database (NVD).
<https://nvd.nist.gov/vuln/detail/CVE-2018-3639>

17. **NIST. (2024).** Common Vulnerability Scoring System (CVSS) v3.1: Specification Document. <https://www.first.org/cvss/specification-document>

18. **OffSec. (2024).** GVM / OpenVAS en Kali Linux. Kali Tools.
<https://www.kali.org/tools/gvm/>

- 19.OPNsense Project. (2024).** OPNsense Documentation: Firewall Rules. <https://docs.opnsense.org/manual/firewall.html>
- 20.OpenSSH Project. (2024).** sshd_config man page. OpenBSD Manual Pages. https://man.openbsd.org/sshd_config
- 21.phpMyAdmin Team. (2024).** phpMyAdmin Documentation (versión 5.1). <https://docs.phpmyadmin.net/en/latest/>